



Industrial Control System (ICS) Cybersecurity Evaluation (401 – Virtual) Trainee Guide



R01M00

ICS Cybersecurity Evaluation (401 Virtual) Training

Disclaimer	5
Introduction	6
Course Requirements	7
Trainee Guide	7
Cyber Security Evaluation Tool CSET®	8
How to Login to NetLab	8
LO1. Apply Components of an ICS Evaluation.....	9
ICS Evaluation Components	9
What are Cybersecurity Performance Goals (CPGs)?	9
CPGs Compared to 401 Questions	10
Managing Risk	10
Assessment vs. Analysis and Evaluation	10
Why Establish an ICS Evaluation Program?	10
Changing the Culture	11
ICS Evaluation Components	12
Evaluation Entry Qualifiers / Organizational and Technical	12
ICS Cybersecurity Policy and Procedure	13
Establish Expected Outcomes and Products.....	13
Criticality Analysis	14
Perfume Specialty Chemical Scenario	14
LO2. Identify Assets Within ICS Networks	17
Identify Assets	17
Asset Inventory	17
Asset Inventory Prioritization Activity	18
Common Issues.....	18
Cybersecurity Performance Goals (CPGs).....	19
LO3. Create a Segmented Network Using Taught Principles	20
Network Segmentation.....	20
Network Segmentation Exercise	29
Common Issues	31
Cybersecurity Performance Goals (CPGs).....	31
LO4. Understand Wireless Vulnerabilities in ICS Environments	32
Wi-Fi Assessment: Concepts and Analysis	32
Radio Spectrum	32
Omni-Directional Antennas	33

ICS Cybersecurity Evaluation (401 Virtual) Training

Directional Antennas.....	33
Wi-Fi Access Points (APs)	34
Wi-Fi Spectrum	34
Wi-Fi Encryption Types.....	35
Beacons	36
Probe Request.....	36
Wi-Fi Threats	37
Wi-Fi Analyzers for Android	44
Wi-Fi Monitoring Hardware	44
IEEE 802.11[x] Support Tools.....	45
Common Issues	45
Cybersecurity Performance Goals (CPGs).....	45
LO5. Evaluate Network Monitoring in ICS Environments	46
Philosophies	47
Network Monitoring Types	47
Logging Architecture	48
Monitoring Control System.....	51
Evaluating Network Monitoring.....	51
Network Monitoring Policy.....	51
Data	52
Log Sources.....	52
Snort IDS/IPS	52
What to Monitor?	53
Network Monitoring Concerns.....	53
How is Incident Response Supposed to Work?.....	53
Incident Response Plan	53
Incident Response Questions	54
Cybersecurity Performance Goals (CPGs).....	55
LO6: Identify Risk Using OPSEC and OSINT	57
Threats	57
Threat Example	58
ICS Incidents	58
Operations Security (OPSEC).....	59
Identify Critical Information (CI).....	60
Identify CI (Continued).....	62

ICS Cybersecurity Evaluation (401 Virtual) Training

Open-Source Intelligence (OSINT)	62
OSINT Historical Examples.....	62
Hawaii Emergency Management Agency OPSEC Exercise.....	66
Analyze Threats.....	67
Analyze Vulnerabilities.....	67
Assess Risk	67
Apply Countermeasures.....	67
Common Issues.....	68
OPSEC Exercise – VLP	69
Cybersecurity Performance Goals (CPGs).....	69
LO7. Evaluate Adversarial Risk to an ICS Environment.....	71
Phishing Exercise	72
Adversarial Tactics and Techniques	72
Common Issues.....	81
Cybersecurity Performance Goals (CPGs).....	81
LO8. Determine ICS Dependencies	83
Infrastructure and Dependencies	83
Dependency and Dependency Types	84
Deer Island Treatment Plant Wastewater Collection and Treatment	86
Define Business Process Functions.....	88
Define Auxiliary Functions: What Other Factors Are Around the Process?	88
Understand Criticality and Risk	88
Interdependencies Exercise	89
Common Issues.....	89
LO9. Analyze Supply Chain Risk	90
Why Attack the Supply Chain?.....	90
Vulnerabilities	91
Supply Chain Considerations.....	91
Use Cases	92
Supply Chain Exercise.....	93
Third-Party Access Considerations	93
Onsite Access.....	93
Remote Access.....	94
Third-Party Access Use Case - Trisis.....	94
Self-Reflection Scenario.....	95

ICS Cybersecurity Evaluation (401 Virtual) Training

Common Issues	96
Cybersecurity Performance Goals (CPGs).....	96
LO10. Provide Risk Management and Mitigation Methods.....	98
Manage Risk.....	98
Continuous Monitoring	100
Management Respond.....	100
Responding to 'Risk'	101
Recommend Points of Contact	101
Report Recommendations / Document Actions.....	101
Review / Update	102
CSET® Guide Introduction	103
Disclaimer	103
Learning Objectives	103
1. Discuss the purpose and benefits of CSET®	104
2. Describe the steps to conduct a CSET® evaluation.....	107
Executive Summary Report	123
Site Detail Report.....	125
Acronyms.....	128
CSET® Report.....	129
LO2 Evaluation Questions	129
LO3 Evaluation Questions	130
LO4 Evaluation Questions	130
LO5 Evaluation Questions	131
LO6 Evaluation Questions	132
LO7 Evaluation Questions	132
LO8 Evaluation Questions	133
LO9 Evaluation Questions	134
Final Exercise	135
Team Members.....	135
Appendix A. Content References	139
Appendix B: OSINT Framework and Google Hacking Exercise	140
Appendix C. Network Architecture Examples.....	144
Appendix D: Cross-Sector Dependencies Sample Exercise Answer.....	146
Appendix E. Cybersecurity Performance Goals (CPGs).....	147
Appendix F. How to Login to NetLab.....	150

ICS Cybersecurity Evaluation (401 Virtual) Training

Disclaimer

This presentation is intended for informational and discussion purposes only.

The U.S. Department of Homeland Security (DHS) does not provide any warranties of any kind regarding this information. In no event shall the United States Government or its contractors or subcontractors be liable for any damages, including but not limited to, direct, indirect, special or consequential damages, arising out of, resulting from, or in any way connected with this information, whether or not based upon warranty, contract, tort, or otherwise, whether or not arising out of negligence, and whether or not injury was sustained from, or arose out of the results of, or reliance upon the information.

The display of the DHS official seal or other DHS visual identities, including the Cyber and Infrastructure Security Agency (CISA) name or logo shall not be interpreted to provide any person or organization the authorization to use the official seal, insignia or other visual identities of the DHS, including CISA. The DHS seal, insignia, or other visual identities shall not be used in any manner to imply endorsement of any commercial product or activity by DHS, CISA or the United States Government. Use of the DHS seal without proper authorization violates federal law (e.g., 18 U.S.C. §§ 506, 701, 1017), and is against DHS policies governing usage of its seal.

DHS does not endorse any commercial product or service, including any subjects of analysis. Any reference to specific commercial products, processes, or services by service mark, trademark, manufacturer, or otherwise, does not constitute or imply their endorsement, recommendation, or favoring by DHS.

Training personnel do not discriminate on the basis of race, color, religion, national origin, sexual orientation, physical or mental disability, or gender expression/identity. Nor do they possess proprietary interest in any product, instrument, device, service or material discussed in this course.



ICS Cybersecurity Evaluation (401 Virtual) Training

Introduction

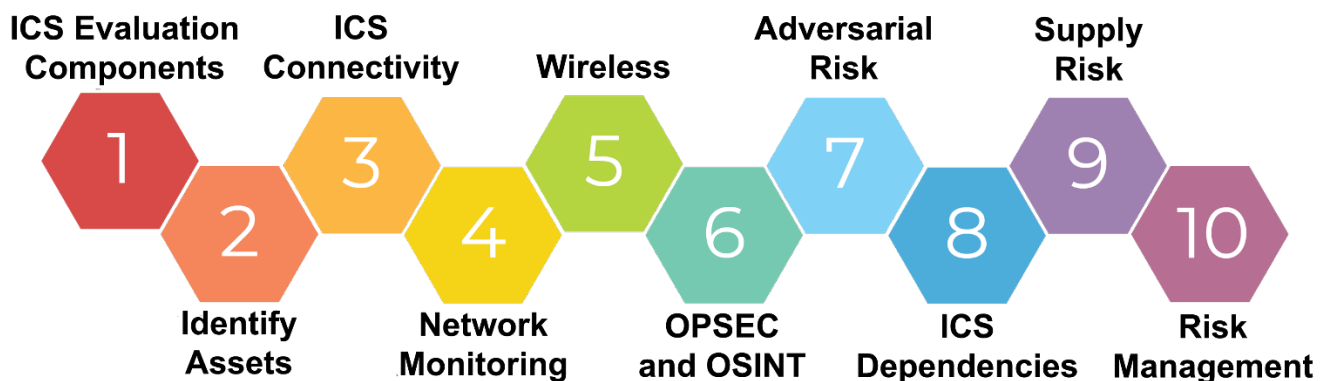
The purpose of this course is to provide training on analyzing, evaluating, and documenting the cybersecurity posture of an ICS system for internal and/or external recommended changes. Specifically, the course will utilize a repeatable process to analyze cybersecurity weaknesses and threats, evaluate and map findings, and document potential mitigations. Trainees will also be able to download an evaluation tool, Cybersecurity Evaluation Tool (CSET®), to get experience conducting and generating a report to present to upper managers.

During this course, trainees will gain real-world experience in analyzing ICS cyber-weaknesses and threats, documenting mitigation possibilities, and providing ongoing resolutions to strengthen the cybersecurity posture of an evaluated ICS system environment.

Learning objectives

At the end of this course, trainees will be able to:

1. Apply components of an ICS evaluation
2. Identify assets within ICS networks
3. Create a segmented network
4. Evaluate network monitoring in ICS environments
5. Integrate wireless application and vulnerabilities in ICS environments
6. Identify risk using OPSEC and OSINT
7. Evaluate adversarial risk to an ICS environment
8. Determine ICS dependencies
9. Analyze supply chain risks
10. Provide risk management and mitigation methods for a given scenario



ICS Cybersecurity Evaluation (401 Virtual) Training

Course Requirements

CISA encourages active and full participation in this course. However, we also realize motivations for completing the course may vary. Ultimately, the level at which you choose to participate is completely up to you, the trainee. However, if you wish to earn Continuing Education Units (CEU) as part of this course, then meeting all the requirements will be important.

Modules

This course contains 10 content modules. Each module may contain multiple videos and activities. Trainees can expect to spend up to 1 hour each to complete each content module.

If a trainee wishes to earn CEUs, skipping videos and activities is prohibited.

Can I still attend a live event? Registrants of this virtual training are eligible to attend the live (classroom) version of this course whether or not they complete all sessions.

Instructional / technical support

If you have questions related to the course content or require technical support, contact one of our instructional support staff at nhs-training@inl.gov

Continuing education units

Our organization is accredited by the International Association for Continuing Education and Training (IACET) and is accredited to issue IACET CEU.

Our organization is authorized by IACET to offer **1.0** CEUs. This number is based on **10** student engaged contact hours.

At the conclusion of this course, trainees will receive a certificate of completion that can be used to provide evidence of completion of continuing education requirements.

NOTE: CEUs will not be given for partial completion of this course.



Trainee Guide

This guide contains content taught in the online version of the course. The activities used in the course are located on the CISA VLP as downloadable PDFs or NetLab activities. **We recommend downloading and completing the activities as trainees navigate through each video within each module.** Trainees may print this Trainee Guide or use the PDF version. This guide is for trainee benefit only.



ICS Cybersecurity Evaluation (401 Virtual) Training

Cyber Security Evaluation Tool CSET®

During this training, we will be utilizing the CSET® tool to perform an evaluation. The version will be 11.5.0.0 and can be downloaded from the VLP in the CSET® Walkthrough module.



After completing course modules 1 through 10 and the CSET® walkthrough, trainees will engage in a simplified simulation of a cybersecurity evaluation using this tool.

While it is not necessary for the course completion, trainees are welcome to download the latest released version of the tool at <https://cset-download.inl.gov/download>

How to Login to NetLab

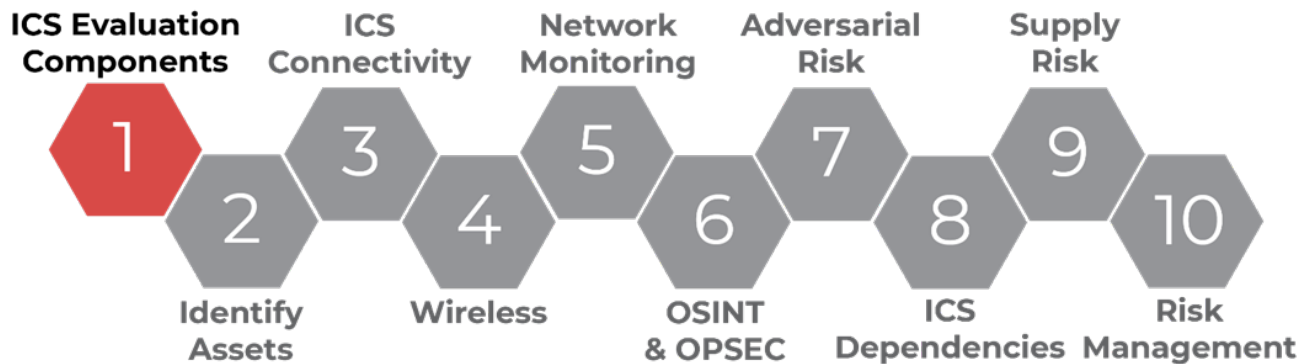
Instructions can be found in Appendix F of this trainee guide.



ICS Cybersecurity Evaluation (401 Virtual) Training

LO1. Apply Components of an ICS Evaluation

ICS Evaluation Components



What are Cybersecurity Performance Goals (CPGs)?

When conducting a course evaluation, there are a variety of question sets available depending on the type of evaluation you are conducting, how in-depth you want to be, and what requirements you need to meet. For this course, the 401 Virtual question set was created. However, CISA created a set of questions that can be used as well in industry called the Cybersecurity Performance Goals. We will include the CPGs at the end of each module that they align with so you can familiarize yourself with them.

- A prioritized subset of cybersecurity practices
- For IT and OT
- Prioritized for risk reduction
- Informed by threats observed by CISA and its government and industry partners
- Applicable across all CI sectors
- Intended to meaningfully reduce risks to both CI operatives and the American people

IDENTIFY

1:A

ASSET INVENTORY

OUTCOME	
Better identify known, unknown (shadow), and unmanaged assets, and more rapidly detect and respond to new vulnerabilities.	
TIP or RISK ADDRESSED	SCOPE
- Hardware Additions (T2200) - Exploit Public-Facing Application (T0819, ICS T0819) - Internet Accessible Device (ICS T0803)	IT and OT assets

RECOMMENDED ACTION
Maintain a regularly updated inventory of all organizations (including IPNs), including OT. This inventory is updated on monthly for both IT and OT.

1:B

ORGANIZATIONAL CYBERSECURITY LEADERSHIP

OUTCOME	
A single leader is responsible and accountable for cybersecurity within an organization.	
TIP or RISK ADDRESSED	SCOPE
Lack of sufficient cybersecurity accountability, investment, or effectiveness.	N/A

RECOMMENDED ACTION
A named role/position/title is identified as responsible and accountable for cybersecurity activities. This role is responsible for managing cybersecurity operations at the senior level, budget resources, or leading strategy development to inform.

1:C

OT CYBERSECURITY LEADERSHIP

OUTCOME	
A single leader is responsible and accountable for OT-specific cybersecurity within an organization with OT assets.	

RECOMMENDED ACTION

ICS Evaluation Components



ICS Cybersecurity Evaluation (401 Virtual) Training

CPGs Compared to 401 Questions

How are CPGs incorporated into the 401-question set?

1. The 401-question set is more detailed
2. CPGs incorporated where appropriate
3. CPGs will be noted in the question set where it relates

Managing Risk

$$\text{Risk} = \text{Threats} \times \text{Vulnerabilities} \times \text{Consequences}$$

This equation is a simple structure to focus cybersecurity efforts to directly impact risk.

When each variable is considered and addressed, it helps to mitigate and defend critical infrastructure by reducing the overall risk.

Assessment vs. Analysis and Evaluation

Assessment

- Generally, a 'point-in-time' activity
- Compliance against (internal or external) standards
- Diagnostic in nature – 'scored' against a process
- Measurement – absolute per standard
- Security posture re-assessed at long-term intervals

Analysis & Evaluation

- Emphasis in ongoing, over-time activity
- Not compliance focused – incorporated as required
- Judgmental in nature – measured against product value
- Measurement – comparative against business objectives
- Security posture re-evaluated continuously

Why Establish an ICS Evaluation Program?

According to a statement made by John Fryer, Senior Director of Product Management & Marketing at Stratus Technologies, *the number of connected devices by 2020 will range from 50 billion to more than 200 billion – “Many of these devices will be industrial machines – from production line equipment to pipeline pumps and monitors – transforming manufacturing and process automation.”*

Many evaluation programs / systems are based on compliance. The process taught in this class is meant to be a business enabler and is not focused on regulatory compliance.

ICS Evaluation
Components



ICS Cybersecurity Evaluation (401 Virtual) Training

Having said that, this course incorporates regulatory considerations in evaluation phases, and this focus is designed to help an organization understand its vulnerabilities and risks and show how organizations can provide recommendations to continually improve cybersecurity posture.

Protect Crown Jewels

- 60% of small companies that suffer a cyberattack are out of business within 6 months

Cybercrime Is Real

- Damage from ransomware attacks estimated to be \$400-500 billion annually, though not all this damage is reported

Not IF, but When?

- Time an organization is compromised before discovering a cyber breach averages 21-23 days
- 91% of public-facing ICS components are remotely exploitable
- 42% of small business have been the target of cyberattack in the U.S. in 2020

Process to Manage Cyber Risk

- 38% of IT organizations do not have defined process for reviewing their cybersecurity incident response plans

IMPORTANT: No organization will ever be ‘completely’ secure. However, if the only reason an organization evaluates its own systems is based on regulation, they are more vulnerable than secure. Creating an ICS cybersecurity self-evaluation process is critical to sustainable practice.

Changing the Culture

“Cooperation on a consistent security strategy across both IT and OT is essential for the future.”

“For IT security pros that want to start to cooperate on security with OT, learning about how OT works is a great starting place.”

This CPG incorporates Changing the Culture by recommendation a “pizza party” or other social event annually to encourage IT/OT relationships.

1.D

IMPROVING IT AND OT CYBERSECURITY RELATIONSHIPS		ID.GV-2, PR.AT-5
OUTCOME		RECOMMENDED ACTION
Improve OT cybersecurity and more rapidly and effectively respond to OT cyber incidents.		Organizations sponsor at least one “pizza party” or equivalent social gathering per year that is focused on strengthening working relationships between IT and OT security personnel and is not a working event (such as providing meals during an incident response).
TTP or RISK ADDRESSED Poor working relationships and a lack of mutual understanding between IT and OT cybersecurity can often result in increased risk for OT cybersecurity.	SCOPE All IT and OT security personnel	

COST: \$\$\$\$ **IMPACT:** MEDIUM **COMPLEXITY:** LOW

- Low Cost
- Medium Impact
- Low Complexity

ICS Evaluation
Components



ICS Cybersecurity Evaluation (401 Virtual) Training

ICS Evaluation Components

There are many components that make up an ICS evaluation. Most important is to ensure an organization has an established process, or methodology, for performing evaluation. These components include:

- Evaluation entry qualifiers – what items must be evaluated to consider evaluation successful.
- Evaluation roles – who is doing what, when is it being done, and what is the team structure.
- Evaluation methodology should span the entire lifecycle of the system from acquisition through retirement of assets.
- Expected outcomes and products should be understood such as – risk management parameters, evaluation metrics, and whether a formal reporting mechanism is required.

Evaluation Entry Qualifiers / Organizational and Technical

Many of these qualifiers come from the Defense-in-Depth Strategy Elements found in the NCCIC_ICS-CERT_Defense_in_Depth_2016_S508C.pdf. That document broke up elements into Organizational and Technical Qualifiers an evaluator should use when the goal is to fully complete an evaluation.

Evaluating an ICS environment is not an exact science. As such, the idea of having qualifiers to bind your evaluation topics and resulting artifacts will vary by the business / industry / sector. The table below is provided as an example and is not meant to be prescriptive.

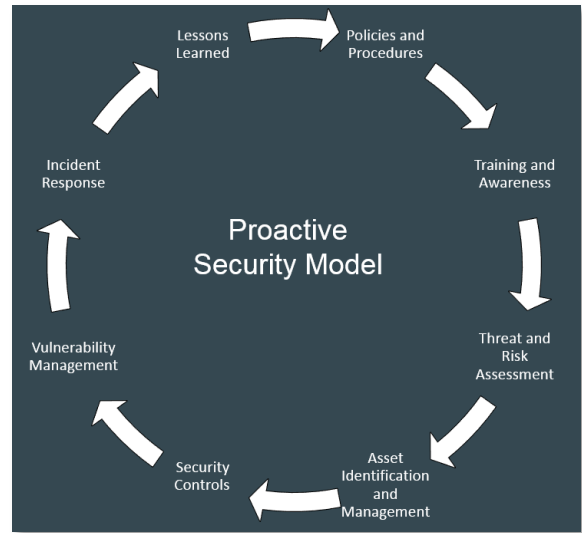
Organizational Evaluation (Qualifiers) *	Technical Evaluation (Qualifiers)*
Leadership-Mgmt. Roles/Responsibilities	IT/OT Technical Roles/Responsibilities
Ownership of ICS Assets	Existing Infrastructure
Business Policies and Procedures	Hardware Inventory
Asset Classification Policy	Software Inventory
Business Impact Analysis	Data Storage
ICS Cybersecurity Plan	Back Up Processes
Disaster Recovery Plan (DRP)	Disaster Recovery Mechanisms
Continuity of Operations Plan (COOP)	User Access
Business Continuity Plan (BCP)	Identification and Authentication
Technical Procedures / Policies / SOPs	Maintenance / Upgrades
Change Management Plan	Cloud Presence / IoT Integration
Configuration Management Plan	Systems Administration
Incident Response Plan	Technical Change Control Points
Continuous Monitoring Plan	Technical Configuration Control Points

ICS Cybersecurity Evaluation (401 Virtual) Training

ICS Cybersecurity Policy and Procedure

ICS Uniqueness:

- ICS / supervisory control and data acquisition (SCADA) lack standard security guidelines, not uniform like IT systems
- Companies may need to create / maintain system-specific ICS cybersecurity practices
- These business practices should be documented, enforced, and updated regularly
- Establishing policy, procedure, and/or process
- Evaluation best not performed as a 'one-off'
- ICS cybersecurity success requires establishing / maintaining ICS cybersecurity policy



Establish Expected Outcomes and Products

Qualitative vs. Quantitative

When it comes to understanding how to 'report' evaluation outcomes it is very important to understand qualitative vs. quantitative reporting. It is always nice to be able to report to managers a quantitative number, but, for the most part, all aspects of risk management are generally qualitative.

Reporting Outcomes: Considering the evaluation process is meant to result in recommendations, it is critical to ensure these recommendations are:

- **Standardized** – you would not want to do three different evaluations and have the same findings without a standardized approach to risk mitigation.
- **Practical** – your recommendations should balance the complexity of the solution as well as the cost-effectiveness of the solution as part of the consideration.
- **Reliable / Repeatable** – the results of your recommendations, when tested should perform in a reliable state. It is a good idea to recommend tested solutions vs. just hypothetical solutions that could cause more harm than help. Results should be repeatable each time.
- **Valid** – It is critical you make sure you can validate your claim when making a recommendation. Seek outside help and do not just rely on textual recommendations. Consider suggesting to businesses they also validate internal recommendations before implementing a solution.

Evaluation Products:

- Issues and findings report
- Final report
- Update or establish cybersecurity policy and procedures

ICS Evaluation
Components



ICS Cybersecurity Evaluation (401 Virtual) Training

Criticality Analysis

- Prioritization of business functions based on:
 - Programs – set(s) of related measures or activities with a specific long-term aim
 - Systems – discrete resources organized to support a program
 - Subsystems – major subdivision of a system performing specific system functions
 - Components – discrete, identifiable asset that represents building blocks of the system
 - Subcomponents – major subdivision of components that support component functions
- Priority to business is based on:
 - Importance to supplying product (goals and objectives) of an organization
 - Impact that inadequate operation or loss may present to those goals

References:

1-NISTIR 8179 Criticality Analysis Process Model Prioritizing Systems and Components, April 2018

2-The model does not require organizations to use standard or identical definitions of program, system, subsystem, component, or subcomponent to allow organizations the flexibility of using their existing definitions; however, the model was developed with the assumption the systems and components evaluated would be technological in nature (IT/OT)

Perfume Specialty Chemical Scenario

This is a simple scenario to practice with. Applying to your own organization will have many more functions, components, and subcomponents to consider.

Perfume Specialty Chemical is a company specializing in the manufacture, sales, and distribution of a variety of perfumes and other body products. The company has a large domestic sales network with over a dozen storage warehouses and three manufacturing plants. Two of the three manufacturing plants are located outside of the United States – one in Toronto, Canada and another in Beijing, China. A sales team resides in both San Diego, CA and New York City, NY.

ICS Evaluation
Components



ICS Cybersecurity Evaluation (401 Virtual) Training

Identify Business Purpose and Functions

What is the primary business purpose and the main business functions of Perfume Specialty Chemical?

➤ Major Business Purpose: Create 'perfume'

➤ Major business 'functions' listed:

➤ Perfume manufacturing/blending



➤ Perfume business/sales



➤ Perfume distribution



➤ Perfume feedback storage



After identifying the business functions, outline the relationship between them.

➤ Draw connecting lines representing process flow

➤ Perfume manufacturing/blending

➤ Perfume business/sales is connected upward and downward

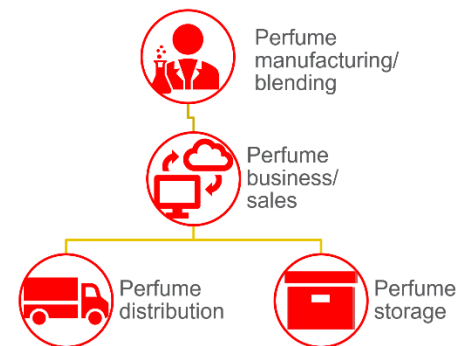
➤ Perfume has both a distribution and storage component

➤ Based on the example to the right:

➤ Which is the most critical function?

➤ What are the major systems in the diagram?

➤ What are the subsystems in the diagram?



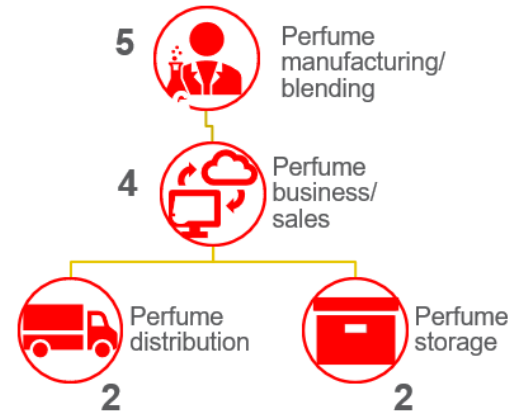
Consider which functions are the most important and which are less important. This does not mean something is unimportant, but rather that there is a ranking of importance.

ICS Evaluation
Components



ICS Cybersecurity Evaluation (401 Virtual) Training

- Assign a priority for each function:
 - Ranked 1 (least important) to 5 (most important)
 - Ask yourself, "If I lose this function..."
 - What happens to business purpose? Does it stop? Does it slow down?
 - What happens to the other functions?
 - What is the overall business impact?
- Criticality mapping can be used to:
 - Identify true 'impact' of critical risk
 - Establish priority order for which system(s) to evaluate
 - Establish priorities for risk mitigation and resource allocation
 - Establish priorities for process modifications and change management



Analyze Business Purpose Review

- Which programs(s) are most critical to my organization?
 - If I lose one of these programs, what is the business impact?
- What are the most critical systems?
 - If I lose one of these systems, what is the business impact?
- What are the most critical subsystems?
 - If I lose one of these subsystems, what is the business impact?

Cyber Security Evaluation Tool (CSET®)

- Self-contained software tool (runs on a desktop or laptop)
- Provides a systematic, repeatable approach for evaluating security posture
- Guides asset owners and operators step-by-step to evaluate ICS security practices



The CSET® introduction utilizes the CSET® Guide located after LO10 in the back of this Trainee Guide.

ICS Evaluation
Components

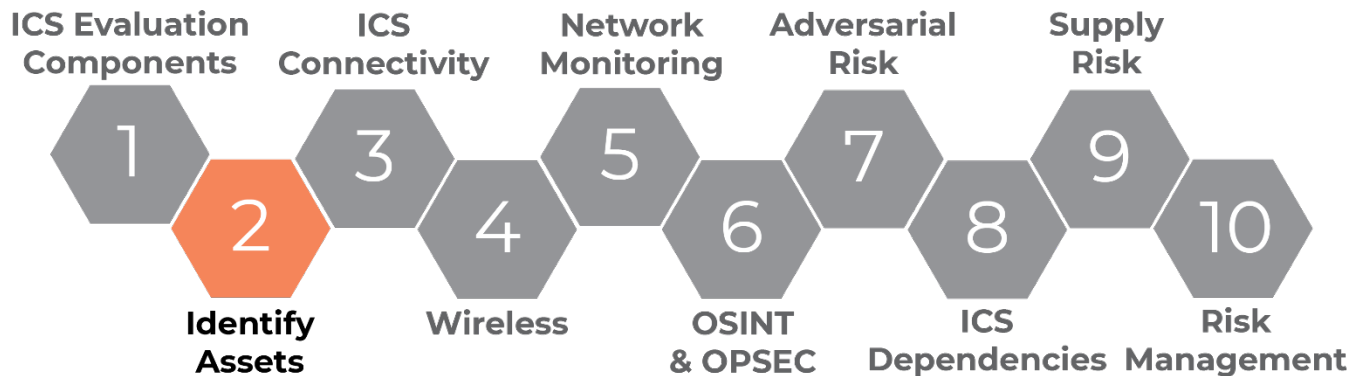


ICS Cybersecurity Evaluation (401 Virtual) Training

LO2. Identify Assets Within ICS Networks

Once critical areas of your business and your evaluations are focused, you will move on to identifying assets. This is critical to your evaluation because you cannot defend what you do not know.

Identify Assets



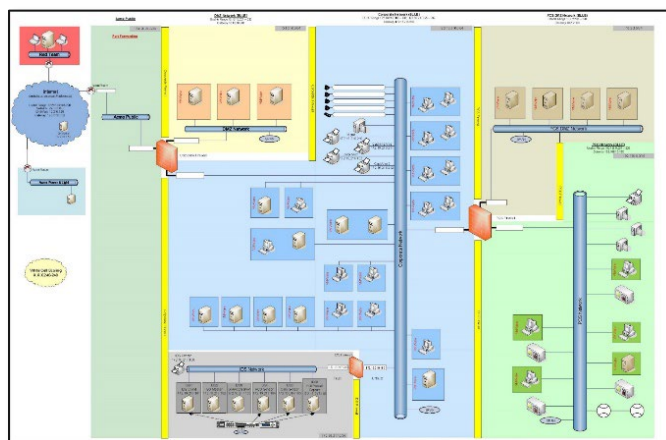
Asset Inventory

It's accurate and complete...right?

- Asset inventory is vital, but many times elusive
- You cannot defend what you do not know

“Understanding and solving the asset inventory and device visibility problem is critical in managing a business’ security program.”

– Implementation guide to ICS



Identify
Assets



ICS Cybersecurity Evaluation (401 Virtual) Training

Asset Inventory Management versus Inventory Management

It is important not to confuse general inventory with asset inventory. Below is a table to help differentiate each one.

Asset Inventory Management	Inventory Management
Something the organization operates	Something the organization consumes
Tracking sensitive information	Tracking items in stock
Analyzing what to secure	Analyzing usage

What is exactly is an ICS asset inventory?

A repository of all relevant information about hardware and software that is in current operation.

Why is your asset inventory challenging?

- Dual-homing and isolation
- Mixtures of old and new devices from multiple vendors, lack of up-to-date diagrams, unique industry and application-specific protocols (some of which are not IP-based), and the difficulty in conducting physical inventories in dispersed or hostile environments compound these challenges.



Asset Inventory Prioritization Activity

You can find and download this activity as a PDF from the VLP.

Common Issues

What might be some common issues you will face in your own organizations?

- ✓ No process governing the implementation of remote access
- ✓ Remote Access does not use multifactor authentication
- ✓ Control System resides on same system / network as Enterprise/IT network
- ✓ Laptops can be used across domains
- ✓ No notification of user / employee change
- ✓ No mobile device policy

Identify
Assets



ICS Cybersecurity Evaluation (401 Virtual) Training

Cybersecurity Performance Goals (CPGs)

This is one of the CPGs associated with asset inventory management. You will complete an evaluation using CSET® at the conclusion of this training.

1.A	ASSET INVENTORY		ID.AM-1, ID.AM-2, ID.AM-4, DE.CM-1, DE.CM-7
	OUTCOME		RECOMMENDED ACTION
	Better identify known, unknown (shadow), and unmanaged assets, and more rapidly detect and respond to new vulnerabilities.		Maintain a regularly updated inventory of all organizational assets with an IP address (including IPv6), including OT. This inventory is updated on a recurring basis, no less than monthly for both IT and OT.
	TTP or RISK ADDRESSED	SCOPE	
	- Hardware Additions (T1200) - Exploit Public-Facing Application (T0819, ICS T0819) - Internet Accessible Device (ICS T0883)	IT and OT assets	

MEDIUM-LOW COST

HIGH IMPACT

MEDIUM

COMPLEXITY

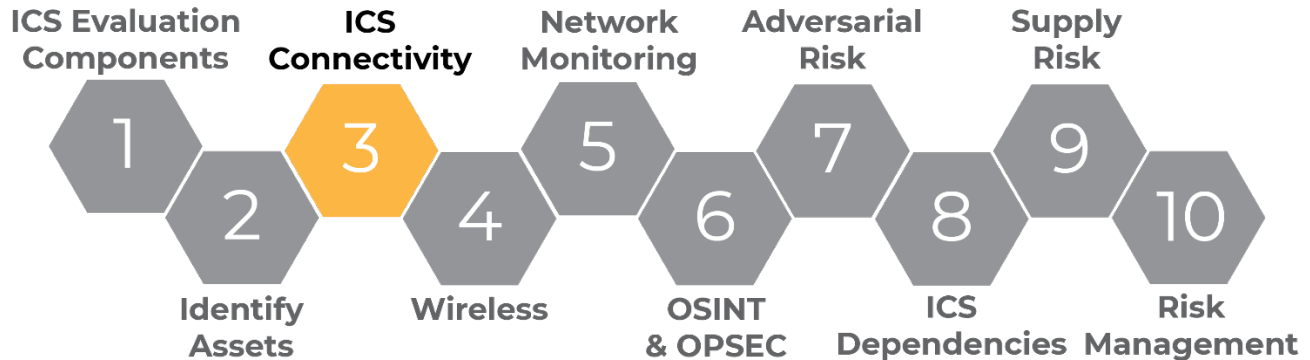
Identify
Assets



ICS Cybersecurity Evaluation (401 Virtual) Training

LO3. Create a Segmented Network Using Taught Principles

Now that we have identified and prioritized our assets, next we determine how/if these assets are connected appropriately. This brings us to determining ICS connectivity.



Network Segmentation: Examining captured packets from an existing network can help reveal if other networks exist. How is the network designed? Is it a single network or is it divided into several? Why divide it into more than one network? Another hands-on demo will encourage you to consider ways to further segment an existing design and rebuild it into your own network.

Critical Data Points: Significant connections for mission success. What data paths traverse the network segments that represent critical data? Are these fragile links well understood? Are they documented? Which personnel are aware of them? Is there a plan to recover these paths if something goes wrong? These are some example concerns to consider. There may not be a perfect answer to each, but simply bringing the concerns to light, sets in motion the steps needed to help an organization become ready.

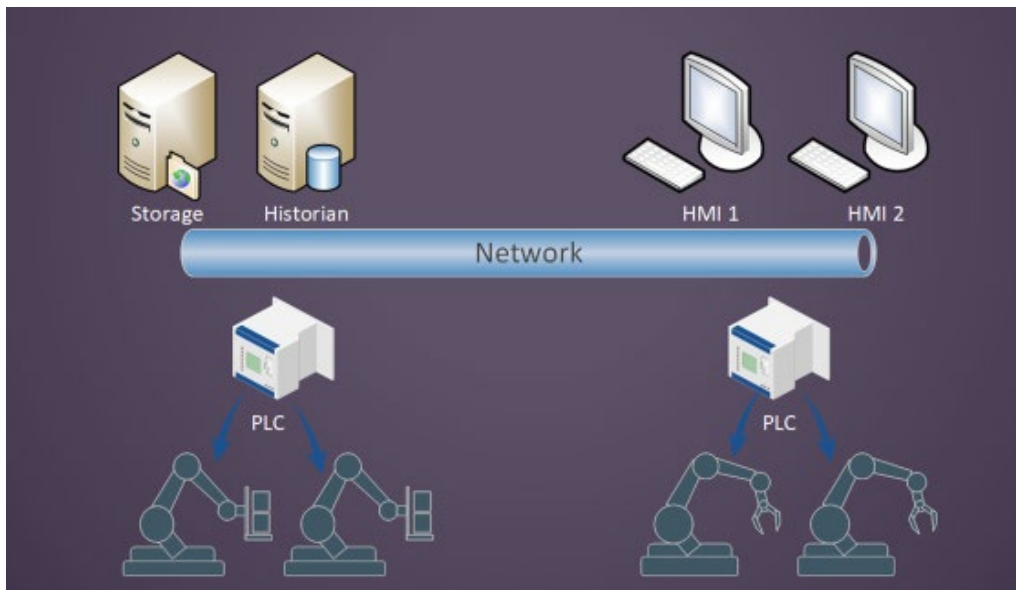
Network Segmentation

A control system can exist on a single network. However, that may not be the wisest design plan. It is a single network to target. Instead of a single network, smaller networks connected by routes, performed by routers or firewalls, can provide barriers with rules. This is a common concept in network security. Network security can be applied to control system networks.

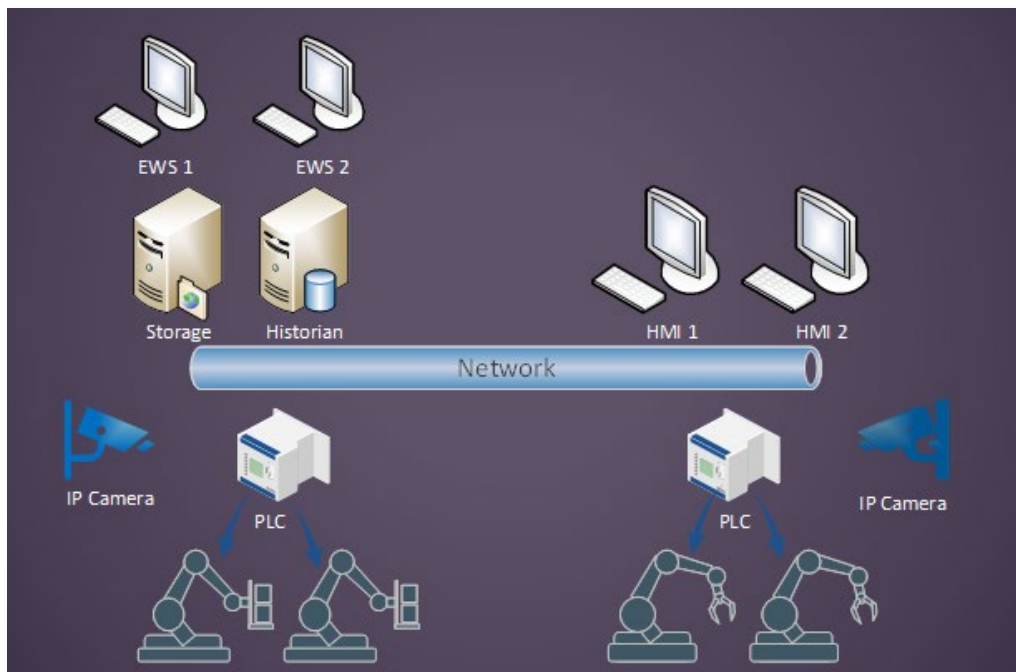
ICS
Connectivity



ICS Cybersecurity Evaluation (401 Virtual) Training

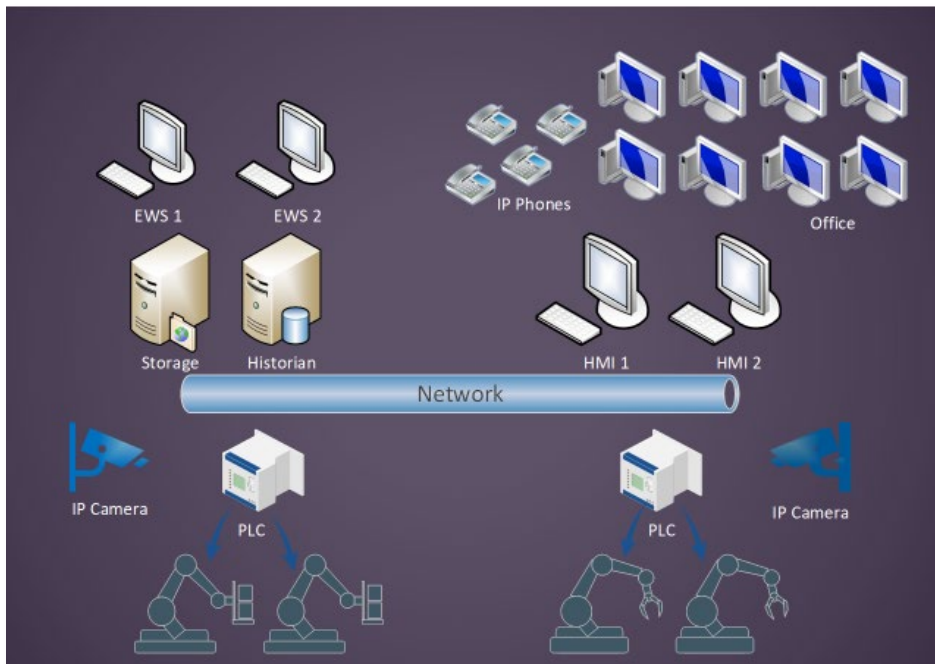


Let's look at a simple network, built with no segmentation. This is a relatively simple ICS network. A couple of PLCs driving some factory equipment, a pair of HMI stations to operate from, and a Historian collecting data from the operation and storing it to a server for safe keeping. This is a single network. Nothing is segmented. All devices above and below the network pipe are connected to the same low-level network.

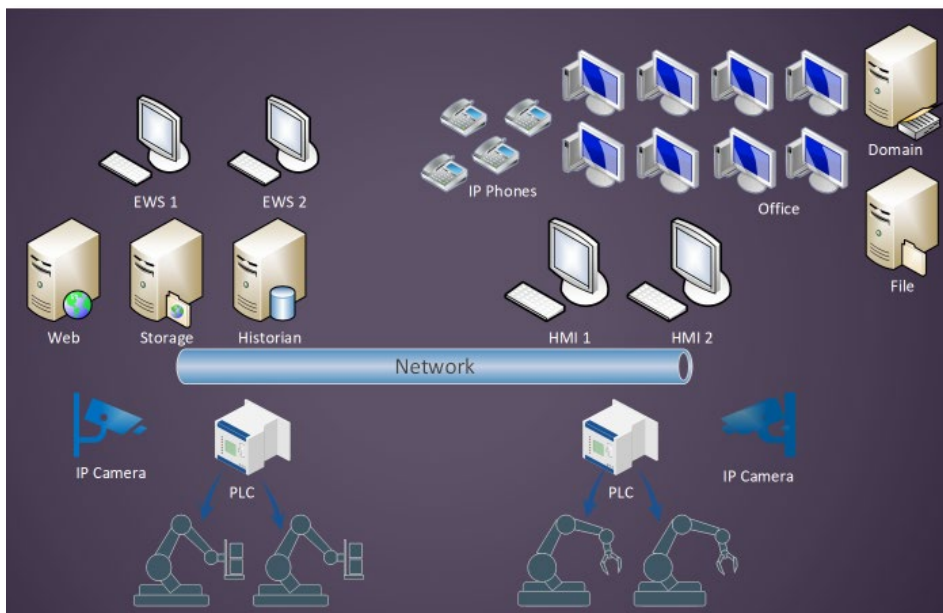


After some time passes, we added a couple of Engineering Workstations (EWS) for new crew positions. Policies are implemented that require more security, resulting in new IP surveillance equipment. Where do these new devices connect? The company just adds them to the existing network.

ICS Cybersecurity Evaluation (401 Virtual) Training

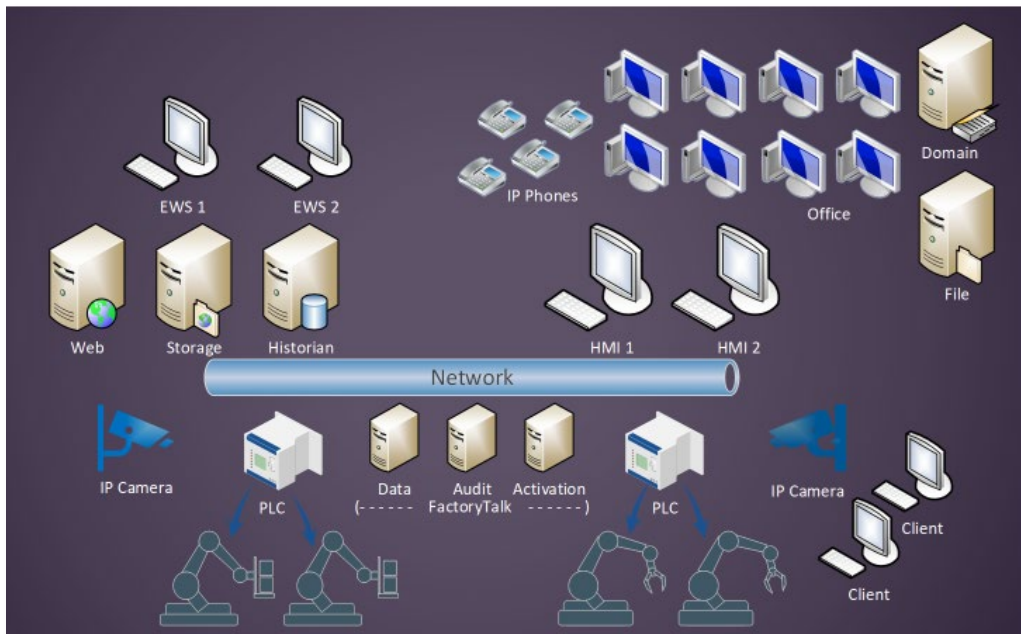


More time passes and production is going well. More workforce is needed. New employees will need desktop computers. Additionally, to serve the various departments, an IP phone system is deployed.

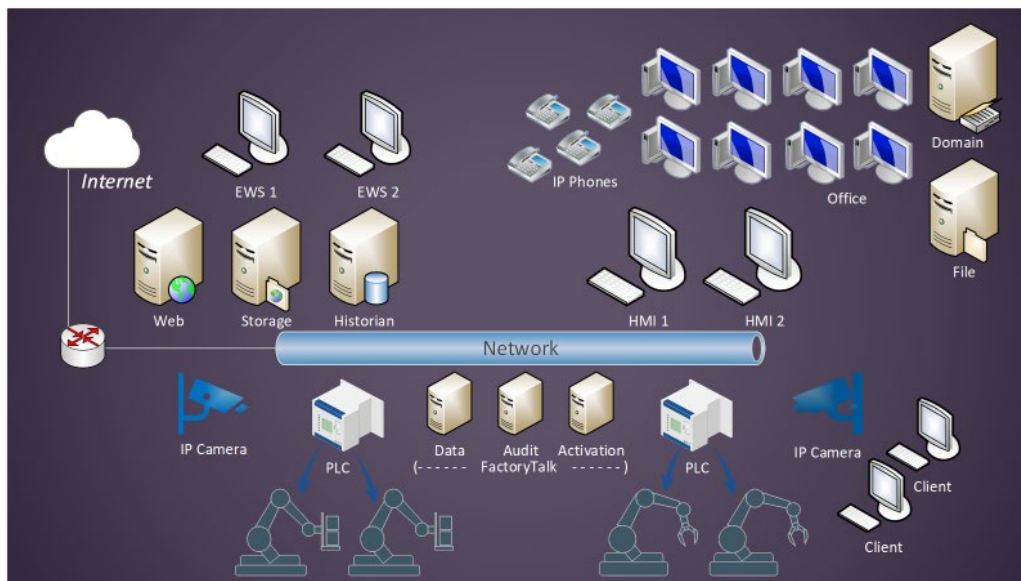


Later, it is decided a dedicated IT staff is needed. To support the staff, a Domain Controller is set up and integrated with desktops and equipment. Employees need to store and exchange a variety of files on a File Server. Being able to view the data from production can be complicated, so IT creates a web server to make it presentable in visually appealing dashboards. The data for the dashboards is pulled from the Historian database.

ICS Cybersecurity Evaluation (401 Virtual) Training



More advanced OT equipment is needed in manufacturing. New components are deployed, resulting in more servers and operation client terminals.



Finally, the employees are going to need Internet access for communicating with businesses. All these additions are added to the same base network we started with. It is getting crowded on this network. Our network is singular, and now only one device isolates this control system from the public Internet.

ICS Cybersecurity Evaluation (401 Virtual) Training

The resulting network appears rather crowded:

- Forward or reverse attacks need only circumvent one point
- Difficult to control access across employee positions
- Troubleshooting may be challenging
- Difficult to grow

Let's attempt to segment this...but how?

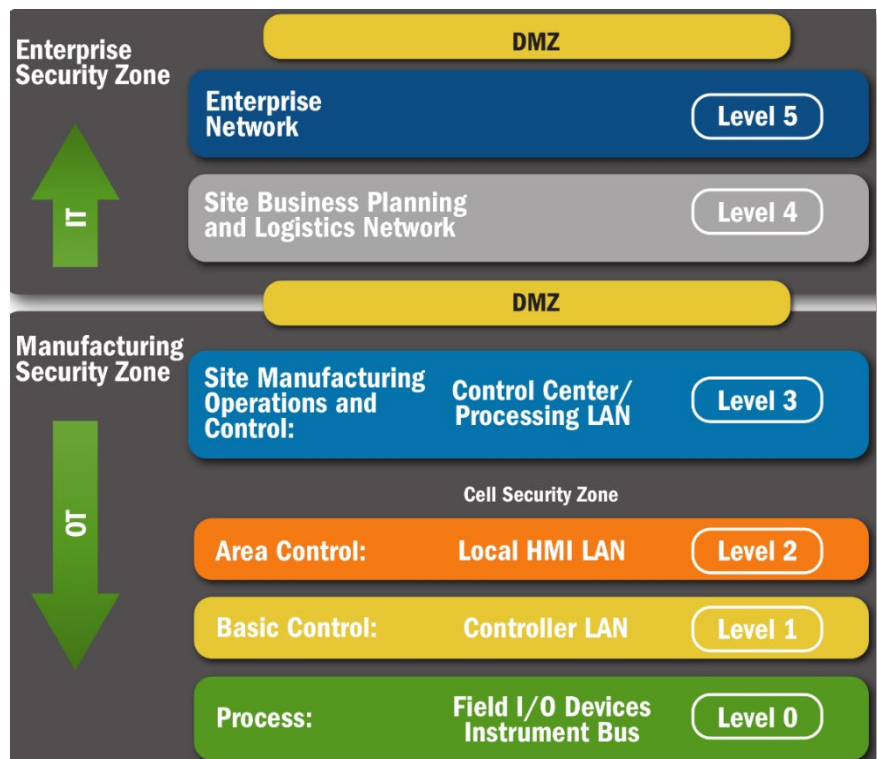
There is no single answer for how to segment such a network. Here is one idea. It is an architecture design provided by DHS. Dividing networks into zones can assist in creating security boundaries. Understanding how to segment networks is vital to creating architectural zones within and around control system environments.

The basic idea is to introduce a DMZ between IT and OT operations. This idea can be applied in multiple areas of the same production, depending on needs. It creates the ability to introduce access control between segments. Not all segmenting ideas require placing a DMZ buffer between them.

Debate over the relevance of the Purdue Model does exist.

Depending on your

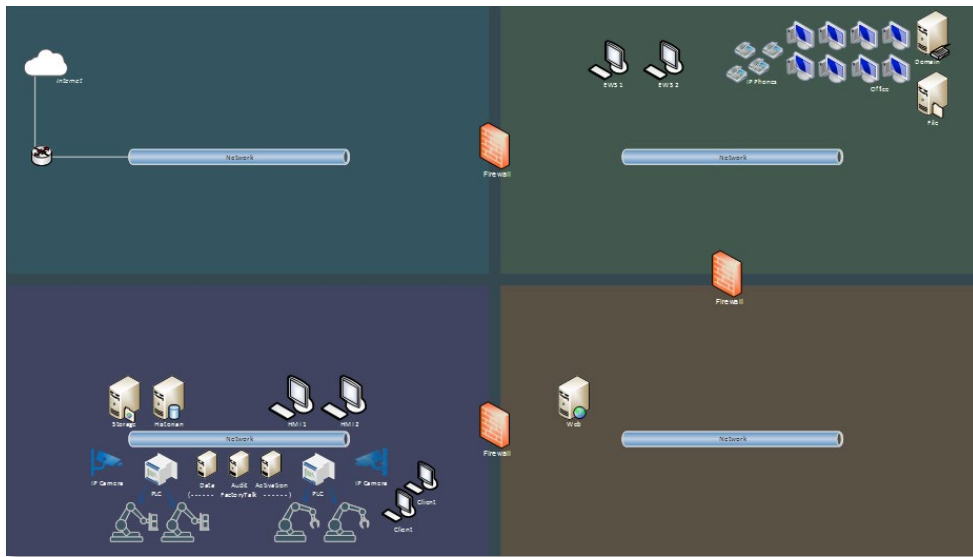
organization's design needs, it can give or take value from this debate. Regardless, using it can still be a first step in further improving your security model. It can also be a great introduction to someone who has never experienced network segmentation.



Reference: NCCIC_ICSCERT_Defense_in_Depth_2016_S508C.pdf; page 18

ICS Cybersecurity Evaluation (401 Virtual) Training

Looking back at the same network we saw grow, we attempted to segment this into smaller, more controllable zones. When evaluating a network, you may or may not encounter similar designs.

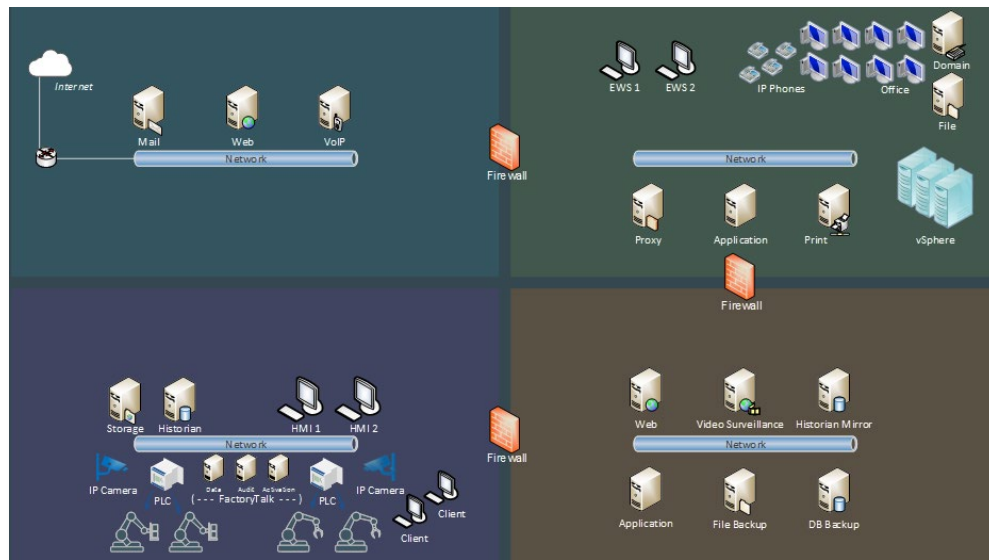


Critical Data Paths

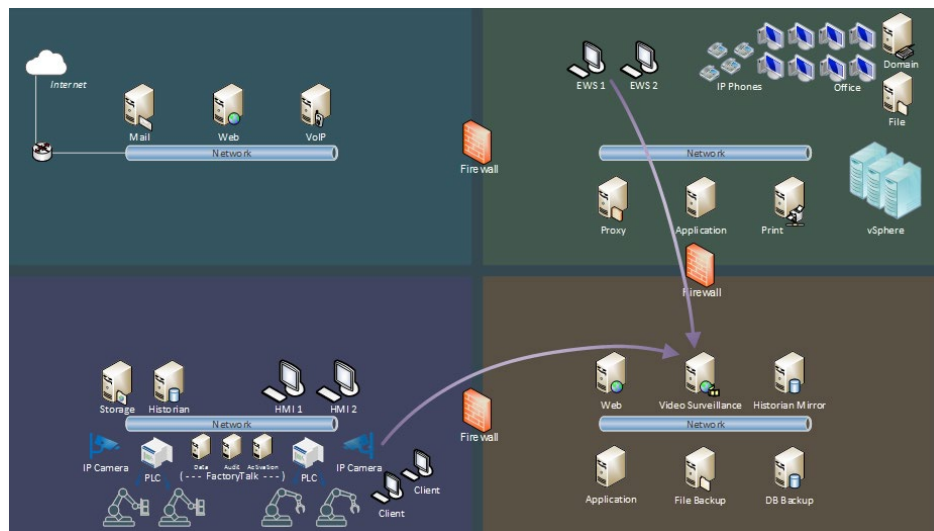
All the mission critical data that flows within your network makes up your critical data paths. With improved segmentation, we can

- Restrict access more realistically
- Monitor network connections
- Troubleshoot
- Scale our network with company growth better

ICS Cybersecurity Evaluation (401 Virtual) Training



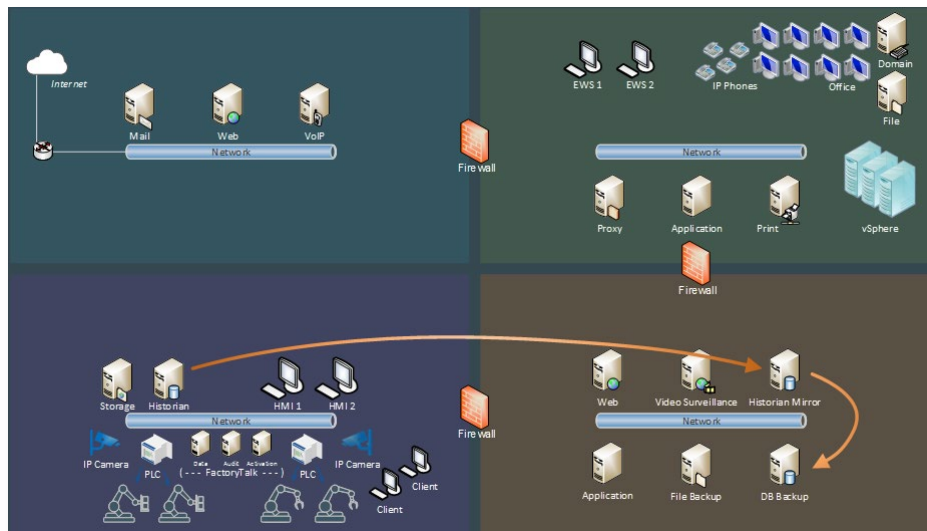
Now, a security officer can monitor last night's surveillance video, which was delivered to video storage.



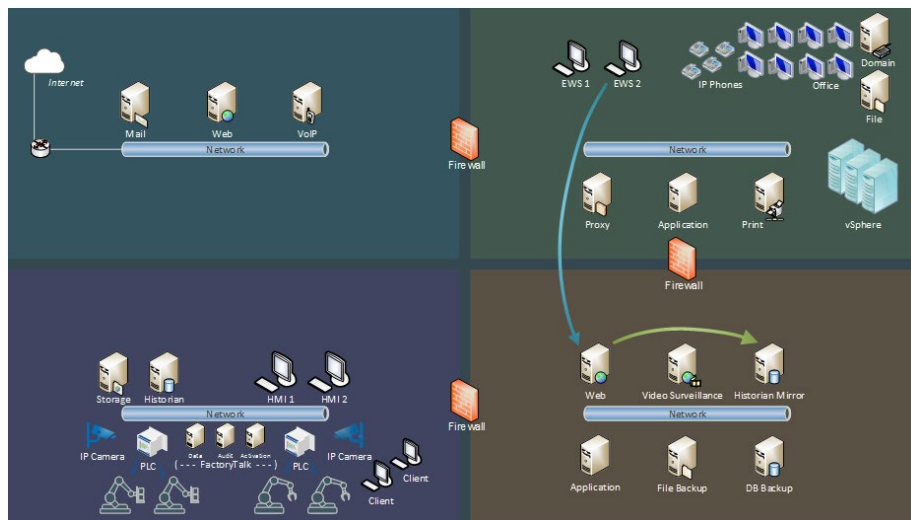
Note the direction of the arrows indicating which device is initiating the connection, and where it is going for access. In other words, the video footage is not pushed from the production network to the engineering workstation. It is accessed via the access controls available in the segmented networks. These data paths traverse firewalls with access rules.

Historian data are sent to another Historian to mirror the data. A backup is replicated for long-term storage.

ICS Cybersecurity Evaluation (401 Virtual) Training

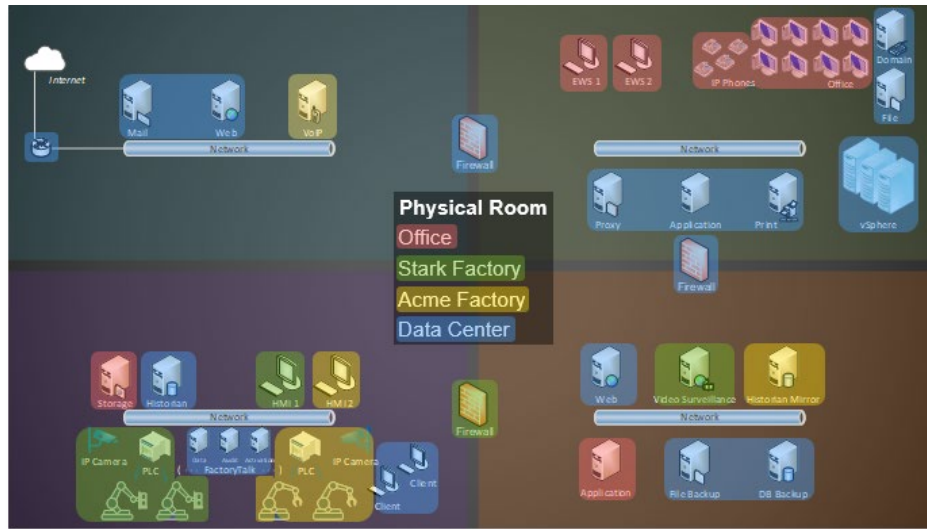


An engineer monitors the past week's results from production by accessing a web server. The web server accesses the database mirror for the engineer's queries. It does not query the primary Historian in the production network. The web server can do this, even though the networks have been segmented.



Logical vs. Physical location. When reading this map, the segments do not necessarily suggest physical placement. Note the colored highlights, and the matching physical room name. When reading our network segmentation map, this can illustrate how different hosts connected to a common segment are not actually in the same room next to each other.

ICS Cybersecurity Evaluation (401 Virtual) Training



The above is achieved more realistically, by implementing network segmentation.

ICS Cybersecurity Evaluation (401 Virtual) Training

Real-World Examples

Example 1: Ukrainian Kyivoblenergo Power Grid - December 23, 2015

- Open-source information available from RTU vendors
- VPNs (plural) into the ICS network, lacked multifactor authentication
- **Firewall allowed egress, aiding remote connectivity** 👎
- No network security monitoring

Consequence: Power interruptions to 225,000 customers across various locations

Reference: E-ISAC, Analysis of the Cyber Attack on the Ukrainian Power Grid, March 18, 2016

Example 2: RWE AG Power Plant - April 26, 2016 (media reported)

- Infected with W32.Ramnit and Conficker
- USB drives also discovered, containing copies of same malware
- **Infected ICS hosts, were normally isolated networks** 👍
- **Infected office hosts, passing the USB drives, also were isolated networks** 👍

Consequence: Lack of Internet connectivity for the segments rendered the infection harmless. Cybersecurity increased upon discovery, without being overwhelmed.

Reference: Reuters, 'German nuclear plant infected with computer viruses', April 26, 2016

Network Segmentation Exercise



You will be given questions to guide you as you improve the network segmentation of a provided network diagram. A debrief video will follow the activity. Activity resources can be found on the CISA VLP.

ICS
Connectivity

3

ICS Cybersecurity Evaluation (401 Virtual) Training

Labels

Zones

Corporate
Public
DMZ
IT
IDS
Process

Devices

Internet
Router
Mail
VoIP
DNS
Web
Database
Database Backup
Historian
Historian Mirror
HMI
Proxy
Print
VPN
Domain Controller
File
File Backup
vSphere
Log
IDS
Surveillance
Printer
Office Workstation
IP Phone
Network
SPAN
Firewall
PLC
Engineer Workstation|

ICS Cybersecurity Evaluation (401 Virtual) Training

Common Issues

- ✓ Existing staff have technical capacity to operate the existing implementation, but not recreate it.
- ✓ Staff do not have knowledge of control system network traffic in detail.
- ✓ Packets are believed to be captured for analysis but are not capturing correctly.
- ✓ Documentation struggles to exist, due to continued irregular adjustments to the existing design.
- ✓ Purdue model, or similar segmentation, is not observed in the network.
- ✓ Public traffic can be accessed from OT-based network hosts.
- ✓ Critical data points are not understood.
- ✓ Restarting a system is the only known solution to combating a critical data flow issue.
- ✓ Fear of debugging systems exists across the IT and OT staff.

Cybersecurity Performance Goals (CPGs)

This is one of the cybersecurity performance goals associated with network segmentation. You will complete an evaluation using CSET® at the conclusion of this training.

2.F-	NETWORK SEGMENTATION		PR.AC-5, PR.PT-4
	OUTCOME		RECOMMENDED ACTION
	Reduce the likelihood of threat actors accessing the OT network after compromising the IT network.		All connections to the OT network are denied by default unless explicitly allowed (e.g., by IP address and port) for specific system functionality. Necessary communications paths between the IT and OT networks must pass through an intermediary, such as a properly configured firewall, bastion host, "jump box," or a demilitarized zone, which is closely monitored, captures network logs, and only allows connections from approved assets.
	TTP or RISK ADDRESSED	SCOPE	
	• Network Service Discovery (T1046) • Trusted Relationship (T1199) • Network Connection Enumeration (ICS T0840) • Network Sniffing (T1040, ICS T0842)	IT and OT assets, where safe and technically capable	

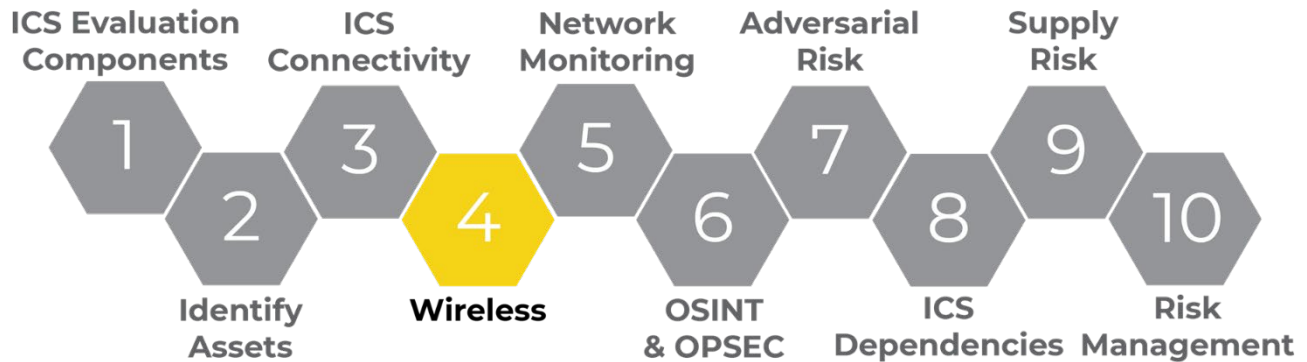
MEDIUM-HIGH COST
HIGH IMPACT
HIGH COMPLEXITY



ICS Cybersecurity Evaluation (401 Virtual) Training

LO4. Understand Wireless Vulnerabilities in ICS Environments

Many, many Wi-Fi enabled devices exist – some of which we are not even aware of. As such, it is important we take wireless devices into account in our evaluations. In this section we will discuss wireless evaluation concepts, tools, and analysis.



Wi-Fi Assessment: Concepts and Analysis

- High-level Wireless Communications Discussion
- IEEE 802.11 Protocols, a.k.a., Wi-Fi, and Threats

Radio Spectrum

The image below depicts the frequency allocation map of the U.S. radio spectrum. Other frequency allocation maps exist for other countries as they use other parts of the spectrum differently than the U.S. However, most of the world uses the same frequencies as the U.S.



<https://www.ntia.doc.gov/files/ntia/publications/2003-allochrt.pdf>

Wireless

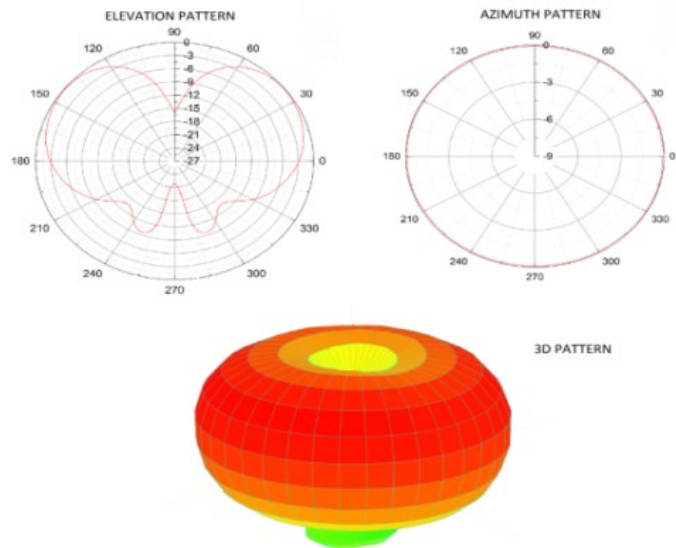


ICS Cybersecurity Evaluation (401 Virtual) Training

Omni-Directional Antennas

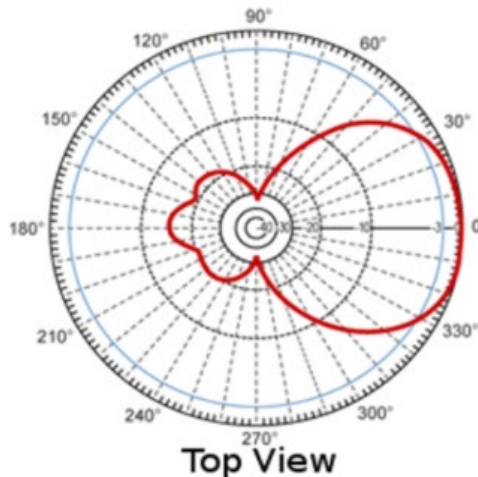
When transmitting, an omni-directional antenna transmits in the shape of a donut – meaning it will transmit radio waves in all directions. Think of it like a lightbulb. If you were to connect a lightbulb to a lamp in the middle of a room, the light would emanate in every direction, including upward. The same is true of an omni-directional antenna, except radio waves will also travel through walls and glass and be received by radio devices in other rooms. Omni-directional antennas can also transmit as far as a mile with Wi-Fi. Additionally:

- The closer you get to the transmitting antenna, the higher the power level.
- Most devices, including cell phones, Wi-Fi access points, laptops, etc., incorporate some form of an omni-directional antenna.
- Omni-directional signals are not easily located as they can come from just about anywhere.



Directional Antennas

Unlike an omni-directional antenna, a directional antenna can only transmit in one direction. Think of a directional antenna as being like a flashlight. When you turn on a flashlight you can only send light in one direction.



There is some residual light that shines behind the flashlight but most of the light can be seen in front. A directional antenna does something similar. It can transmit in one direction and receive from one direction. It can receive from behind, but like a flashlight, the signal will much weaker.



A directional antenna is very useful in locating a transmitter because when it is pointed in a certain direction, it will only receive a signal from that direction. If monitoring the power level of transmitted signals, the levels will rise significantly as the antenna is pointed in the direction of a transmitting device. It is very effective in giving you a general direction of a transmitted signal.

Wireless

4

ICS Cybersecurity Evaluation (401 Virtual) Training

Wi-Fi Access Points (APs)

As indicated, there are a number of devices with Wi-Fi built into them. What we have found at locations around the country is unexpected Wi-Fi access points (APs) built into industrial equipment, such as fuel processing and delivery, building access controls, and package delivery systems. Each had either no encryption nor authentication, or very weak security. We recommend configuring the Wi-Fi access point so it uses some form of encryption, and not a default password.



As you well know, smart phones can be used as a Wi-Fi hotspot as well. Most of the time these are secured. In rare cases, however, someone will leave their Wi-Fi hotspot on and configured with no security. We still see many smart phones with hotspots turned on and unsecured, unbeknownst to the user. You may see this in an airport or other areas, and it will say something like “Bob’s iPhone.”

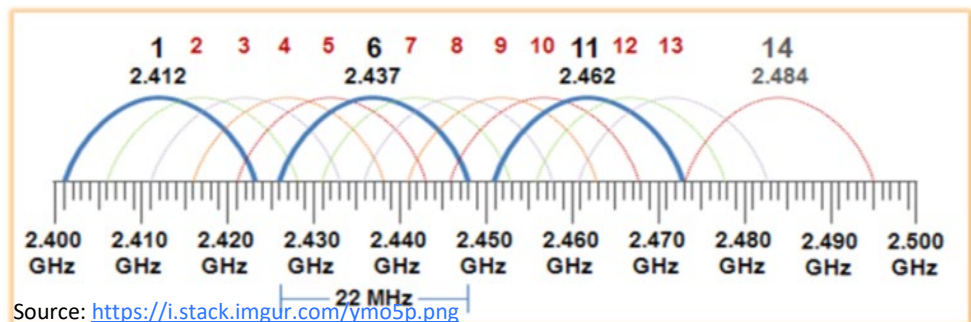
IOT devices are very prevalent and are used as subcomponents of a system, such as appliances and industrial equipment. One very popular device is the ESP8266, which can have a full Wi-Fi access point communications stack and provide full Wi-Fi functionality.

Of course, late model vehicles also have Wi-Fi, Bluetooth, etc. Rental cars can pose a threat of malware delivery if these features are used.

Wi-Fi Spectrum

There are two spectrum bands on which Wi-Fi runs. The first, and most popular, is 2.4 GHz, which operates from around 2.412 GHz to 2.495 GHz. There are 11 channels in the U.S. and 14 channels in other countries (for example, Japan). The main channels in use in the U.S. are Channels 1, 6, and 11. Other channels can be used, but most people do not use them due to overlapping issues, which can cause network congestion if the two APs are in close proximity. There is even more congestion when two wireless APs are using the same channel in close proximity. Most default to Channel 6, and so we find most operators and users plug in a wireless access point, configure the name, leave the channel alone, and cause network congestion or interference. Other channels can be used as long as the channels do not overlap.

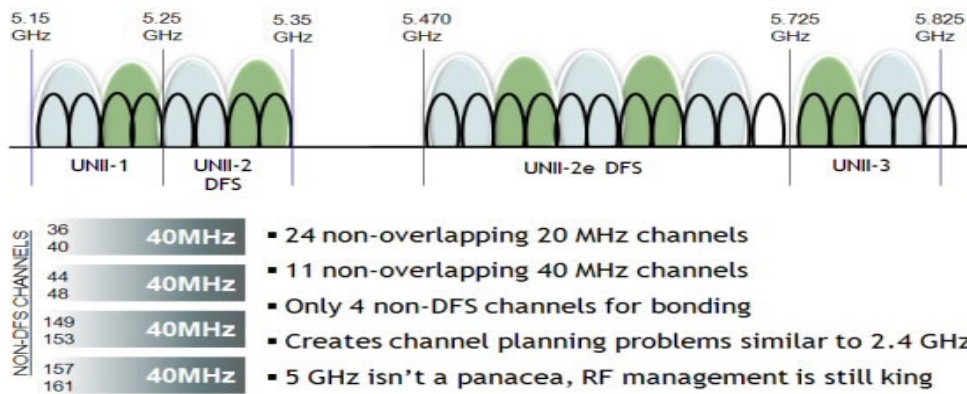
For 2.4 GHz bands, the channel width is usually 20-40 MHz depending on the wireless AP manufacturer and the IEEE 802.11 protocol being used.



Wireless



ICS Cybersecurity Evaluation (401 Virtual) Training



Source: Network World <http://images.techhive.com/images/idge/imported/article/nww/2010/08/080210-infog-1-100272864-orig.jpg>

The second spectrum band Wi-Fi runs is 5 GHz. There are 24 channels at 20 MHz and 11 at 40 MHz. The 5 GHz bands have 20 MHz channels, but also even wider channels up to 160 MHz for more bandwidth and throughput. Basically, the AP uses a larger pipe to send data (and possibly multiple antennas) to transmit on a wider channel.

Wi-Fi Encryption Types

Open – No encryption.

Wired Equivalent Privacy (WEP) – Developed in 1997 and proven to be weak and easily breakable. An attacker can break through it in a matter of minutes.

Wi-Fi Protected Access (WPA) – Developed as a second-generation to WEP. Additional encryption was applied to the same algorithms, but it's not much stronger than WEP.

Wi-Fi Protected Access Version 2 (WPA2) – A complete rewrite of the algorithm in 2004. Worked for years without problem, but there are some issues with it.

Wi-Fi Protected Setup (WPS) – Uses an 8-digit code to protect the passing of a secret key between two parties (usually the AP and the connecting device such as a laptop).

Wi-Fi Protected Access Version 3 (WPA3) – Next generation of WPA. Provides many updates to protect users, such as stronger encryption and better password usage.

Wi-Fi CERTIFIED Enhanced Open – A Wi-Fi alliance certification that preserves the convenience open networks offer while reducing some of the risks.

ICS Cybersecurity Evaluation (401 Virtual) Training

Beacons



An AP is constantly broadcasting its own information, so clients are aware of its existence. This broadcast is called a beacon so devices such as smart phones, laptops, and tablets will be able to access it and know about its capabilities. The broadcast typically transmits every 50 to 100 ms, depending on configuration. This broadcast usually contains the name, the source MAC (BSSID), destination MAC, power, channel, encryption type, cipher type, auth type, name (ESSID), and some other items.

Wi-Fi clients do not transmit the beacon unless they are acting as a hot spot or AP. As such, a client does transmit when it is trying to find an AP. When a client sees an AP, it will try to connect to it from a list of APs it has connected to in the past. Otherwise, it will list the known APs to the user in the immediate area where it is receiving a signal.

Probe Request



Usually, when the Wi-Fi client is not connected to an AP, the client will send out probe requests in two ways:

- A general broadcast to all APs in RF range (FF:FF:FF:FF:FF:FF) to get a response from any AP
- A probe request to a specific AP by ESSID and by MAC address.

In a general broadcast, all APs respond with a Probe Response that looks very similar to a Beacon.

Wireless



ICS Cybersecurity Evaluation (401 Virtual) Training

In a Probe Response from a specific AP, the request is ignored by all APs whose name and/or MAC address do not match. The request is also addressed to the specific client that made the request, even though all others can still see both the request and the response.

This means that when operating in monitor mode, an adversary could discover more information about a client's / victim's whereabouts or internal Wi-Fi APs not necessarily meant for public consumption.

Non-broadcasting APs attempting to hide the SSID can have their SSID revealed by clients performing probe requests. The SSID is revealed whenever a client attempts to connect to the AP, which by protocol, always sends the SSID in clear text as the encryption key-exchange has not occurred yet.

Capturing specific AP probe requests is quite helpful to an Evil Twin attacker since it contains the SSID and the MAC address of the intended AP. Both Aircrack-ng and Kismet can correlate captured SSID names to AP MAC addresses attempting to hide and uncover hidden SSIDs.

It is a good idea to turn off the Wi-Fi, Bluetooth, and Location awareness on clients that do not need connectivity at certain moments of the day. Plus, it saves on battery power since the client is constantly transmitting probe requests and processing probe responses while client Wi-Fi is on.

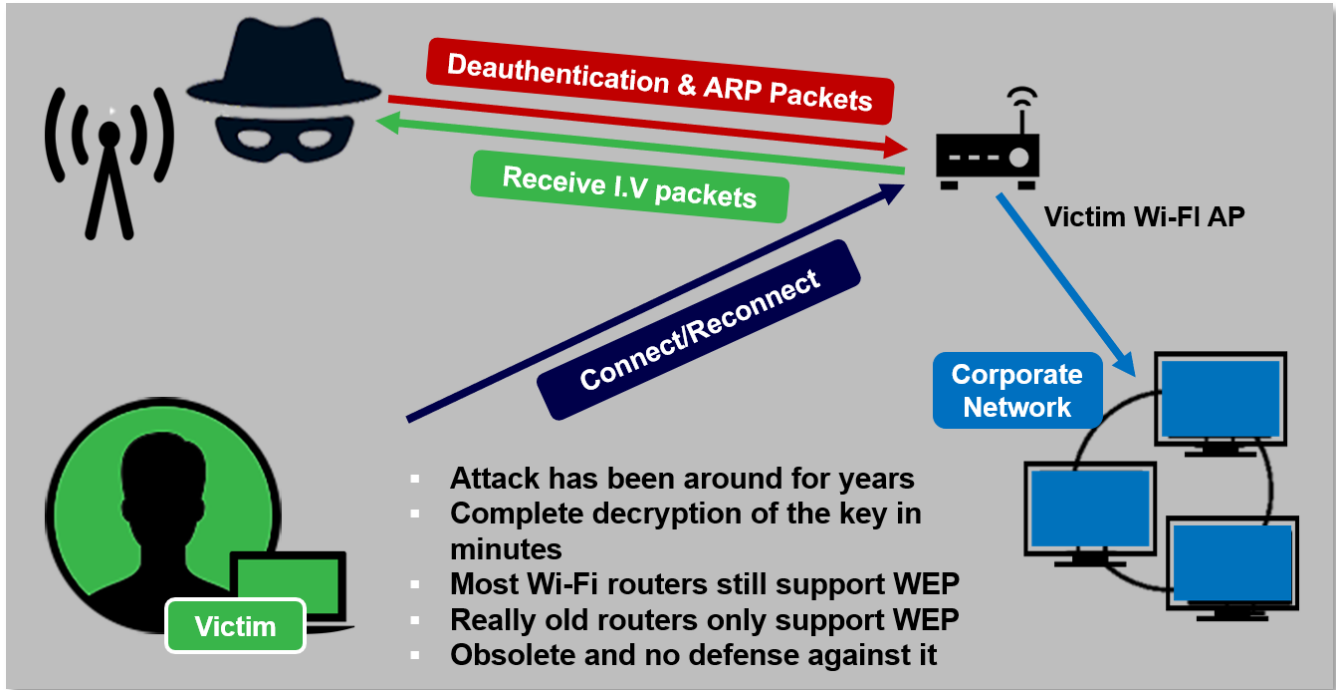
Wi-Fi Threats

There are several different ways in which an attacker can access your network. Let's cover some of those attack types.

- WEP Attack
- WPS Attack
- Wi-Fi Deauthentication DoS
- Evil Twin (Machine-in-the-Middle) Attack
- WPA/WPA2 Handshake Attack
- QPA2 Key Reinitialization Attack or KRACK

ICS Cybersecurity Evaluation (401 Virtual) Training

WEP Attack



If an access point is configured with WEP, then it will literally be minutes before it is broken into by an attacker. WEP has been deprecated for many years.

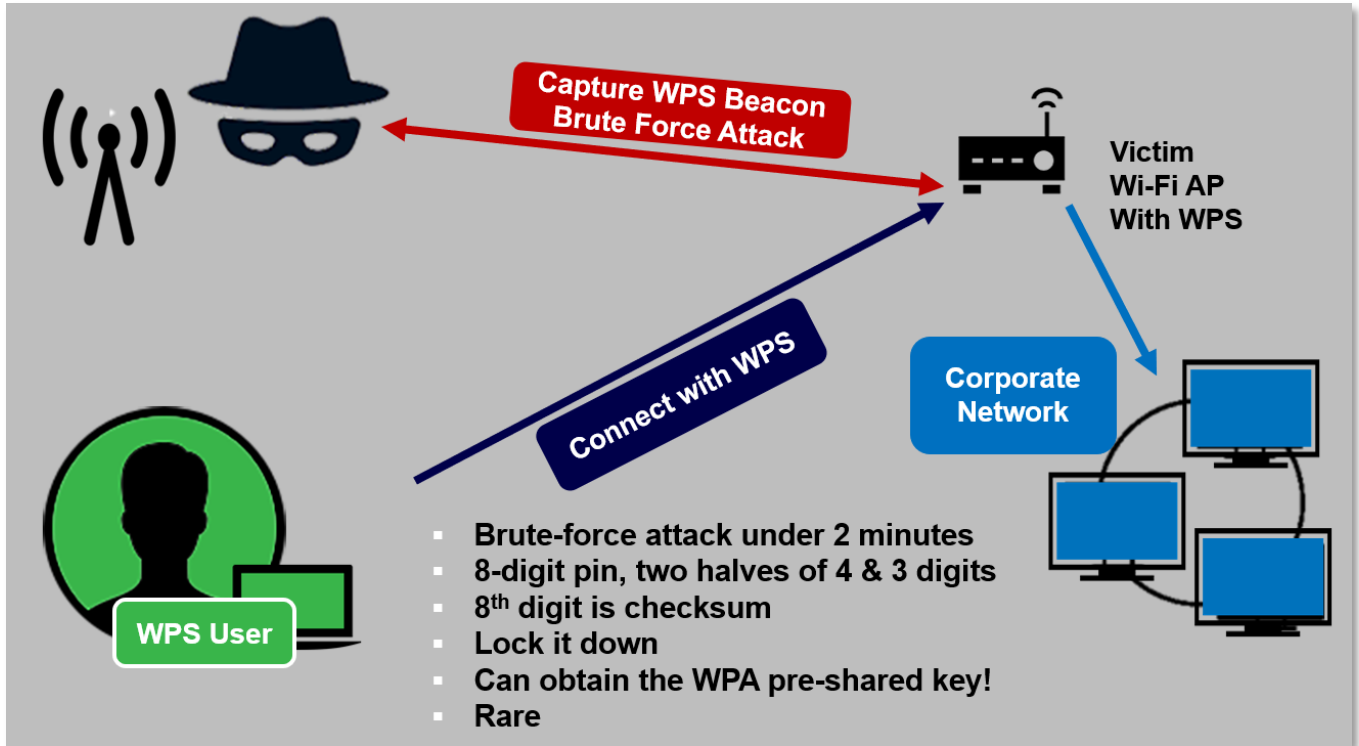
If the Wi-Fi access point is very popular, all the attacker must do is sit and listen for what is called the initialization vector packets. After the attacker collects enough of these IV packets, they run a cracking program that will use statistical analysis to derive the WEP encryption key. Then all that is left to do is to login to the victim's Wi-Fi access point.

If the access point is not very popular and not many people access it, the attacker can then collect the right packets and force the access point to deliver the number of IV packets required to crack the encryption key.

So, the way to do this is to force an unsuspecting user to disconnect from the Wi-Fi access point by sending a deauthentication (deauth) packet, which will force the unsuspecting Wi-Fi user to handshake with the access point again, which generates another set of ARP packets that can be used by the attacker to generate more IV packets. The attacker will send an enormous number of artificially generated ARP packets to the access point, which then causes the IV to be generated. This process can be automated so it only takes a few minutes to collect enough data to decrypt the key. Once there is enough IV data, it is literally seconds for the decryption of the key to take place.

ICS Cybersecurity Evaluation (401 Virtual) Training

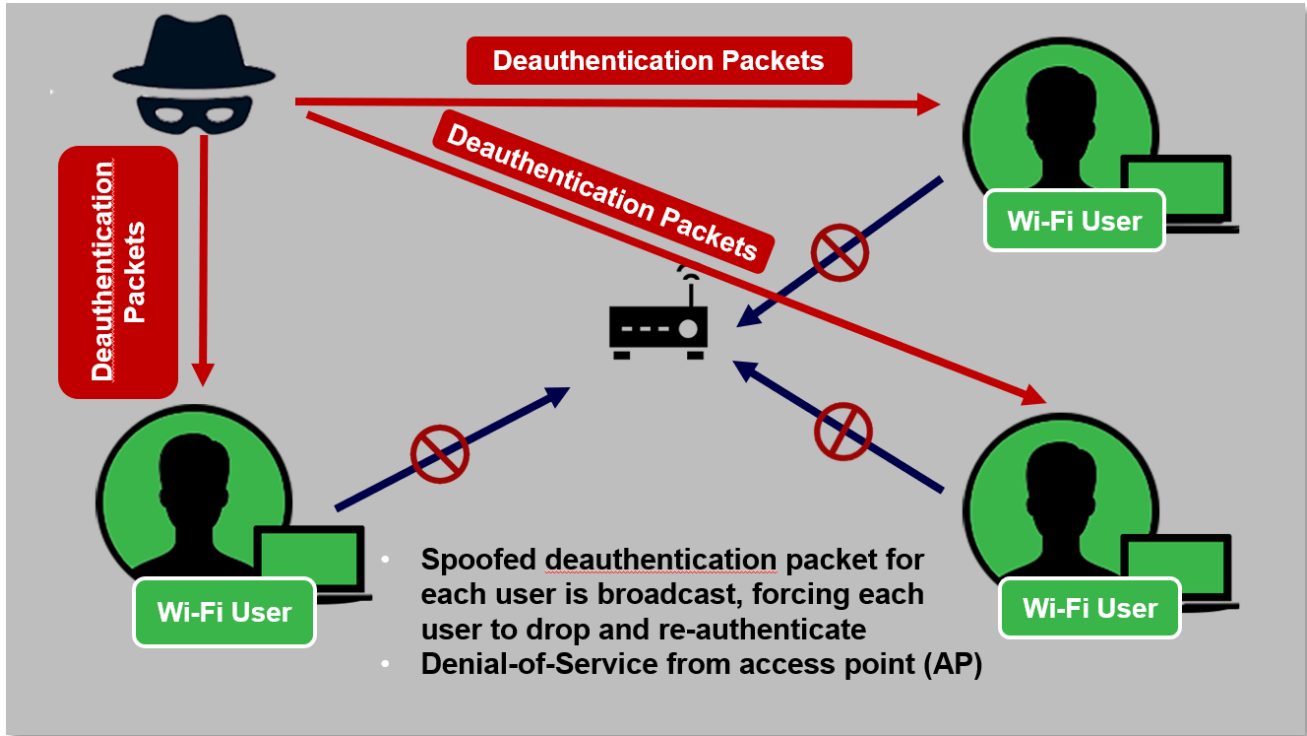
WPS Attack



This attack type only requires WPS beacon. Typically, the WPS beacon is broadcast when the button on the Wi-Fi access point is pressed.

ICS Cybersecurity Evaluation (401 Virtual) Training

Wi-Fi Deauthentication DoS

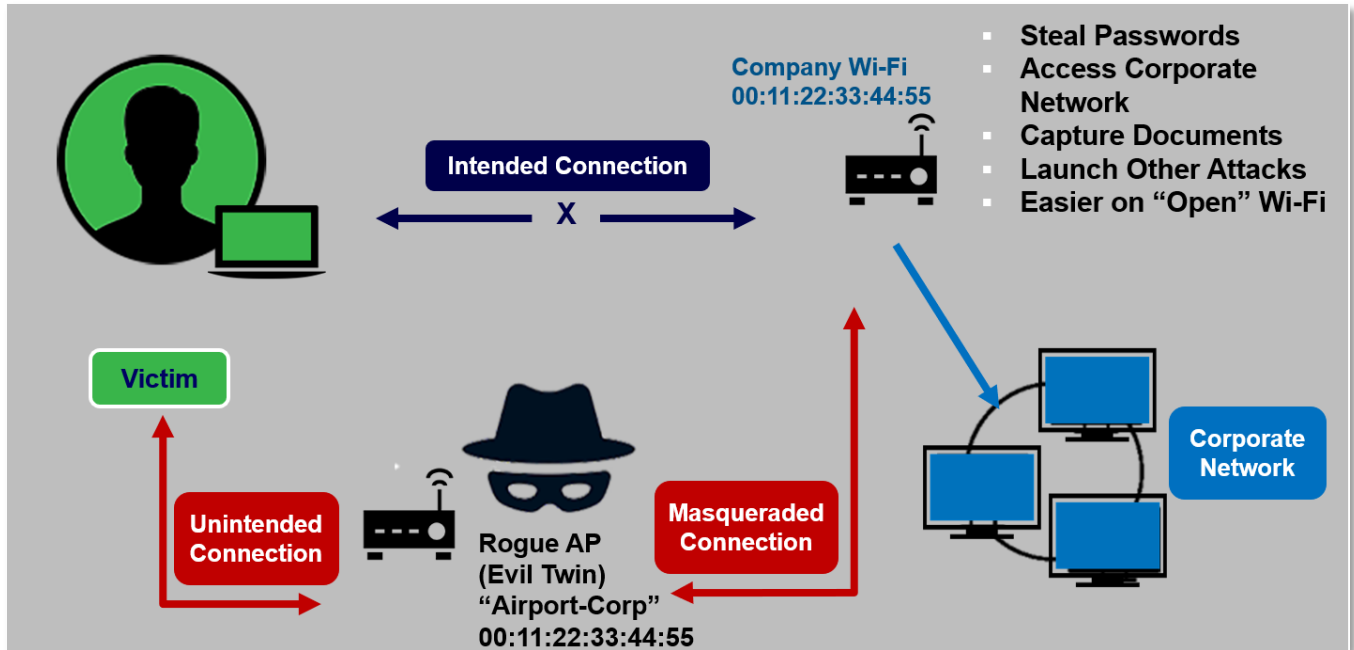


A simple Denial-of-Service (DoS) attack. The attacker broadcasts deauth packets to each Wi-Fi client trying to connect to the AP. The deauth packet forces the user to disconnect from the AP and to reauthenticate. The packet is a spoof that looks like it came from the AP but is in fact from the attacker. Since the packets are continuously broadcast, the users cannot maintain a connection to the AP. This would allow an attacker sole access to the AP.

Simple devices, such as the Raspberry Pi and ESP 8266, can be configured to spew deauth packets as the MAC address of each user is learned. The packets can also be broadcast to all clients by NOT specifying a specific address when using Aireplay-ng, making the attack even simpler and easy to execute. Problem is, the broadcasts deauth the attackers as well.

ICS Cybersecurity Evaluation (401 Virtual) Training

Evil Twin (Machine-in-the-Middle) Attack



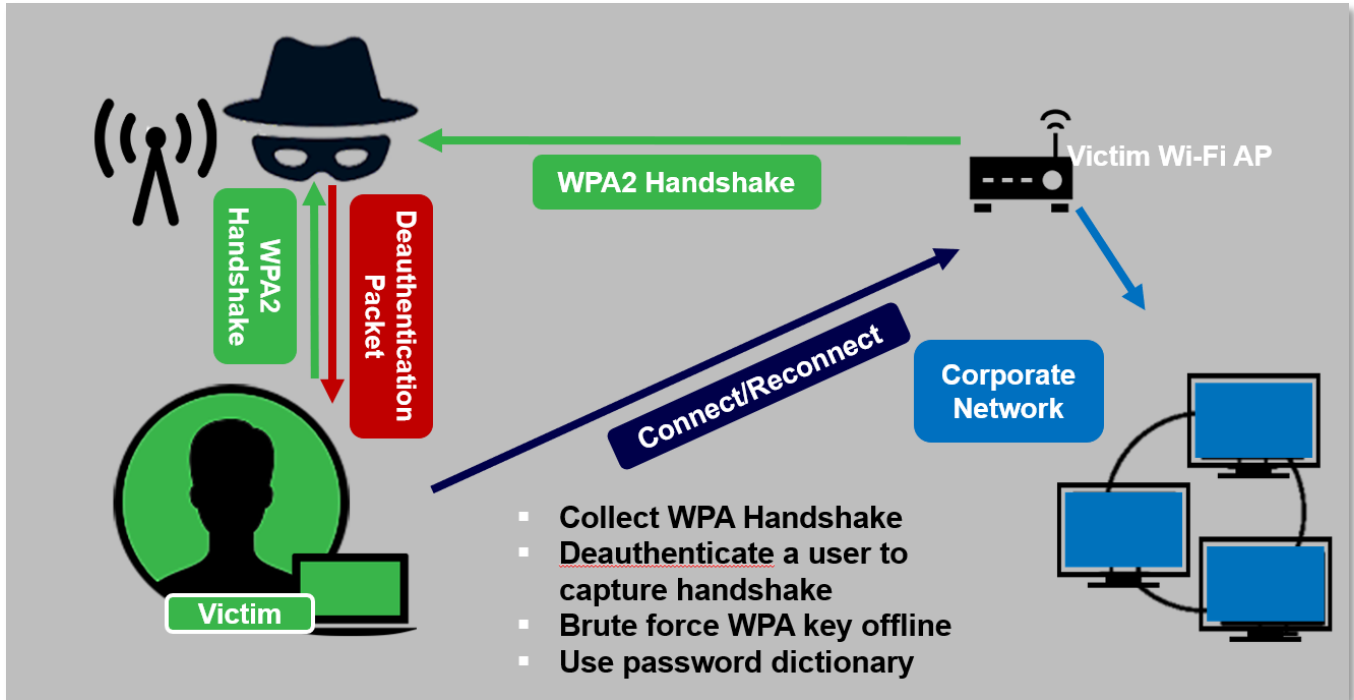
A Wi-Fi AP could be configured to look like others in the network. The MAC address could be duplicated to look like the real thing. The victim will attempt to connect to the access point to establish a connection. When the connection is attempted, the "Evil Twin" will take the victim's credentials and send them on to the intended access point and establish a connection for themselves, as well as a connection for the victim. The victim thinks they have a connection to the real network, but are connected to the Evil Twin, opening all connection elements for the attacker.

The list of things in the bottom-left allow the bad guy to steal passwords, access corporate networks, capture documents, launch other attacks, and a host of other things.

Another reason the victim will connect to the Evil Twin before it connects to the intended access point is due to the power level of the Evil Twin. The Evil Twin will be configured so it broadcasts at a higher power level, leading victims to choose the attacker's access point because the victim believes it is nearer with a better signal.

ICS Cybersecurity Evaluation (401 Virtual) Training

WPA/WPA2 Handshake Attack



The WPA or WPA2 attack is very straightforward and simple. All that is required is to collect the WPA handshake that occurs when a user connects to the Wi-Fi access point.

If the attacker cannot get the WPA handshake by just listening, the attacker can send a deauth packets to force the user to disconnect and then reconnect – a process that will expose the WPA handshake. Once the WPA handshake is captured, the attacker can go away and do some decryption on the WPA handshake at home or wherever there are computing resources.

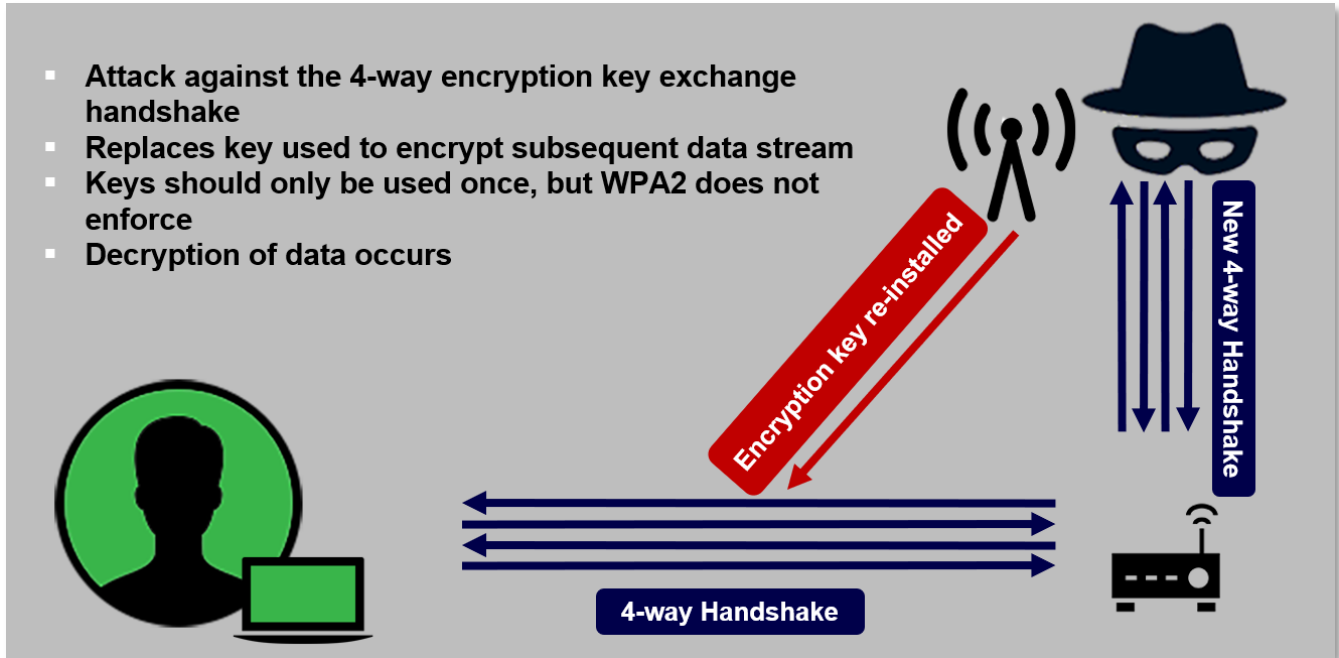
If the WPA password is very weak, then it will be a matter of seconds or minutes to crack the handshake – especially if the password is a dictionary word or a password found in a common password list. If the password is strong or long and complex, this attack becomes quite difficult and would require significant computing power.

Once the WPA password is cracked, it is just a matter of logging into the access point and accessing resources on that network.

ICS Cybersecurity Evaluation (401 Virtual) Training

WPA2 Key Reinstallation Attack (KRACK)

- Attack against the 4-way encryption key exchange handshake
- Replaces key used to encrypt subsequent data stream
- Keys should only be used once, but WPA2 does not enforce
- Decryption of data occurs



This attack came out in 2017 and was a big surprise to the Wi-Fi community. We thought our WPA2 configured Wi-Fi APs were very secure before this attack strategy. It is a simple and straightforward attack, and surprisingly it did not come out sooner. Again, it is an attack on the 4-way handshake, which exchanges the encryption key. Once the handshake is complete, the key can be replaced in a new session with a key the attacker prefers instead of the original key. So, it was just a matter of replacing the original key with a new key because the standard for WPA2 does not enforce using the key only once. Newly patched Wi-Fi APs will only allow use of the key once.

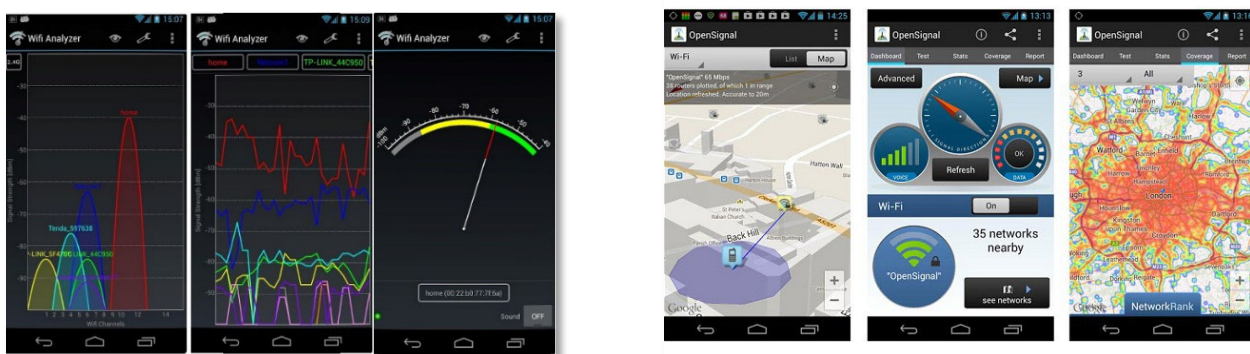
Some manufacturers have supplied patches to guard against this attack. This includes commercial grade APs and home APs. Not all WPA2 APs have a patch, and most APs have not been patched or do not have a patch. Mitigations must be in place to guard against attacks of this type, and an organization should measure its risk level and apply the appropriate protections.

ICS Cybersecurity Evaluation (401 Virtual) Training

Wi-Fi Analyzers for Android

There are several available applications for Android systems that can be used to evaluate nearby wireless signals. These tools offer a useful graphical representation of different signals and their corresponding strength from the perspective of the analyzer.

- **Wi-Fi Analyzer** – A widely used Wi-Fi analyzing application for Android
- **OpenSignal** – A Wi-Fi and phone signal analyzer that includes geographical maps with signals imposed
- **Wi-Fi Monitor** – Microsoft produced Wi-Fi analyzer



Wi-Fi Monitoring Hardware

Wi-Fi monitoring hardware is a small subset of all Wi-Fi hardware devices available. Most of the hardware built into laptops will not go into monitor mode, meaning an external dongle with a compatible chipset is required. There are open-source drivers available that have been modified to allow most Linux installations and a few Windows installations. The majority of installations are Linux on a wide variety of platforms, from Raspberry Pi to high-end laptops to portable units.

The most important thing to note is the chipset. There are a few compatible chipsets, including Atheros, Ralink, and Realtek.

This image shows compatible devices widely known to work. The TP-Link WN722N Version 1 is not the only version that works, but it works best and has a very low price point, although only in 2.4GHz. The manufacturer changed the chipset in Version 2 and later, and no longer works with Linux.



ICS Cybersecurity Evaluation (401 Virtual) Training

Some example Wi-Fi hardware:

- TP-Link WN722N V1 only
- Alfa AWUS036NH
- Panda Wireless PAU09

Source:

<https://www.wirelesshack.org/best-kali-linux-compatible-usb-adapter-dongles-2016.html>

IEEE 802.11[x] Support Tools

Tools will capture data for:

- IEEE 802.11[b,g,n] @ 2.4 GHz
- IEEE 802.11[a,n,ac] @ 5.8 GHz



NOTE: There is growing support for IEEE 802.11ac due to some hardware with the correct chipset.

Common Issues

- **No communication encryption** – Encryption is not used to protect information passed within to system.
- **Wireless access control** – There is no mechanism to verify or limit connections to company-owned devices.
- **Direct access to control system via Wi-Fi** – Wi-Fi connected devices have the ability to control and make changes to the ICS.

Cybersecurity Performance Goals (CPGs)

This is one of the CPGs associated with wireless. You will complete an evaluation using CSET® at the conclusion of this training.

1.A

ASSET INVENTORY			ID.AM-1, ID.AM-2, ID.AM-4, DE.CM-1, DE.CM-7
OUTCOME		RECOMMENDED ACTION	
Better identify known, unknown (shadow), and unmanaged assets, and more rapidly detect and respond to new vulnerabilities.		Maintain a regularly updated inventory of all organizational assets with an IP address (including IPv6), including OT. This inventory is updated on a recurring basis, no less than monthly for both IT and OT.	
TTP or RISK ADDRESSED	SCOPE		
- Hardware Additions (T1200) - Exploit Public-Facing Application (T0819, ICS T0819) - Internet Accessible Device (ICS T0883)	IT and OT assets		

MEDIUM-HIGH COST
HIGH IMPACT
HIGH COMPLEXITY

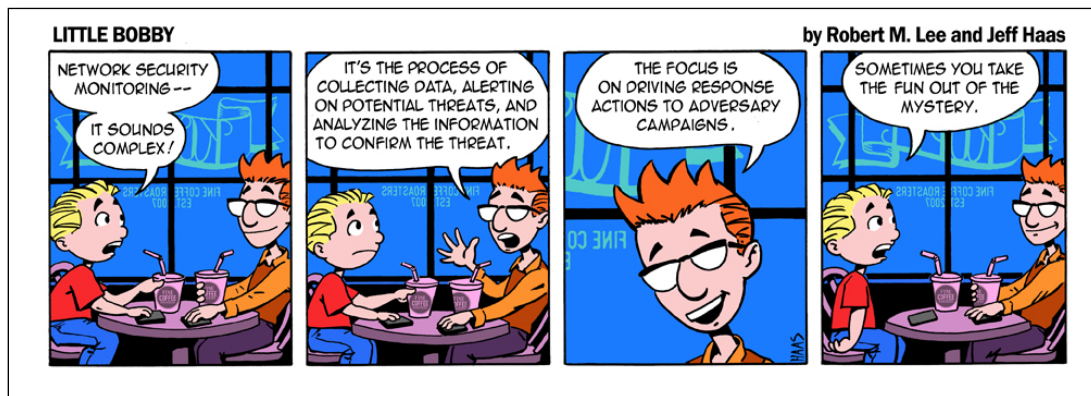
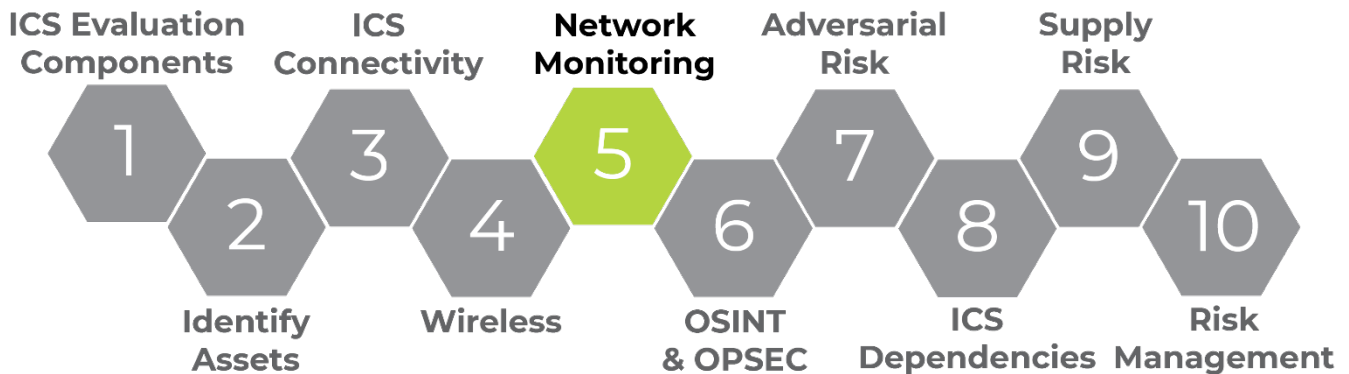
Wireless



ICS Cybersecurity Evaluation (401 Virtual) Training

LO5. Evaluate Network Monitoring in ICS Environments

Monitoring systems and networks for changes, anomalous behaviors, or attack signatures can be difficult in an ICS environment; however, monitoring and detection capabilities are essential to the protection of critical assets. In this objective, we reinforce the importance of network monitoring and how you can evaluate your network using these its capabilities.



“The collection, analysis, and escalation of indications and warnings to detect and respond to intrusions. NSM is a way to find intruders on your network and do something about them before they damage your enterprise.”

– The Practice of Network Security Monitoring

Having an electronic boundary around the ICS is not sufficient to protect critical assets from unauthorized access. This is true because for each protection put into place in a network environment, threat actors can find a method around it.

ICS environments provide a unique opportunity when considering protection mechanisms to place on the network. Despite considerable network traffic, that traffic is very predictable. For example, in a

Network
Monitoring



ICS Cybersecurity Evaluation (401 Virtual) Training

typical ICS environment, the PLC communicates in a standardized way with the HMI and the Historian; all applications and services on the process control system (PCS) network are known (or should be); and the protocols, web traffic, and proprietary traffic are known and predictable.

Asset owners can use an intrusion detection system (IDS) solution to easily monitor and create alarms for any traffic outside normal operations. An IDS is based on the passive monitoring of network traffic. Expected network traffic is deterministic, and deviations are used as triggers for alerting. Simple rules can be written to monitor for IP sources and destinations, protocols, lengths of packets, etc.

Philosophies

"Even the bravest cyber defense will experience defeat when weaknesses are neglected."
- Stephane Nappo

"As we've come to realize, the idea that security starts and ends with the purchase of a prepackaged firewall is simply misguided."
-Art Wittmann

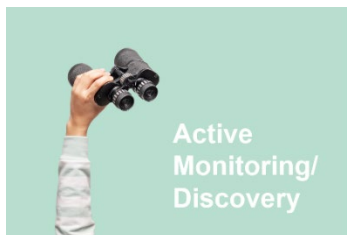
"If security were all that mattered, computers would never be turned on, let alone hooked into a network with literally millions of potential intruders."
-Dan Farmer

Network Monitoring Types



Passive monitoring / discovery silently analyzes network traffic through a span port or tap to identify endpoints and traffic patterns.

- NIDS/HIDS
- Full packet capture
- Centralized logging
- System Monitoring



Active monitoring / discovery works by sending test traffic into the network and polling endpoints that traffic contacts.

- Scanning – Nmap or Nessus
- PenTesting
- Policy Based – Allow-listing, GPO, Tripwire

Hybrid solutions - For an ICS to be successful, a hybrid monitoring solution is needed. OT environments require both passive and active monitoring to be effective.

- Security information and event monitoring (SIEM)

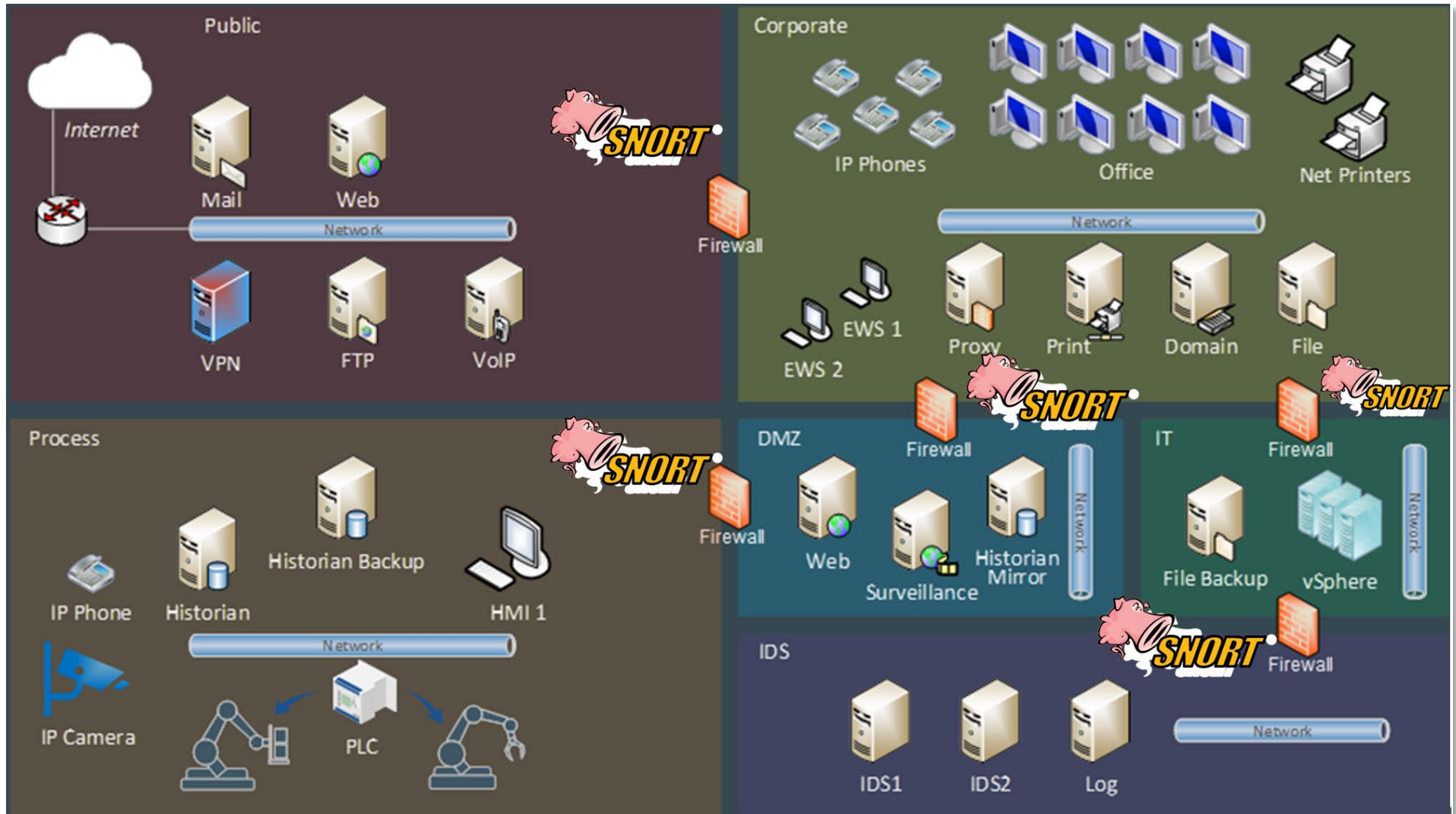
People!!

Network
Monitoring

5

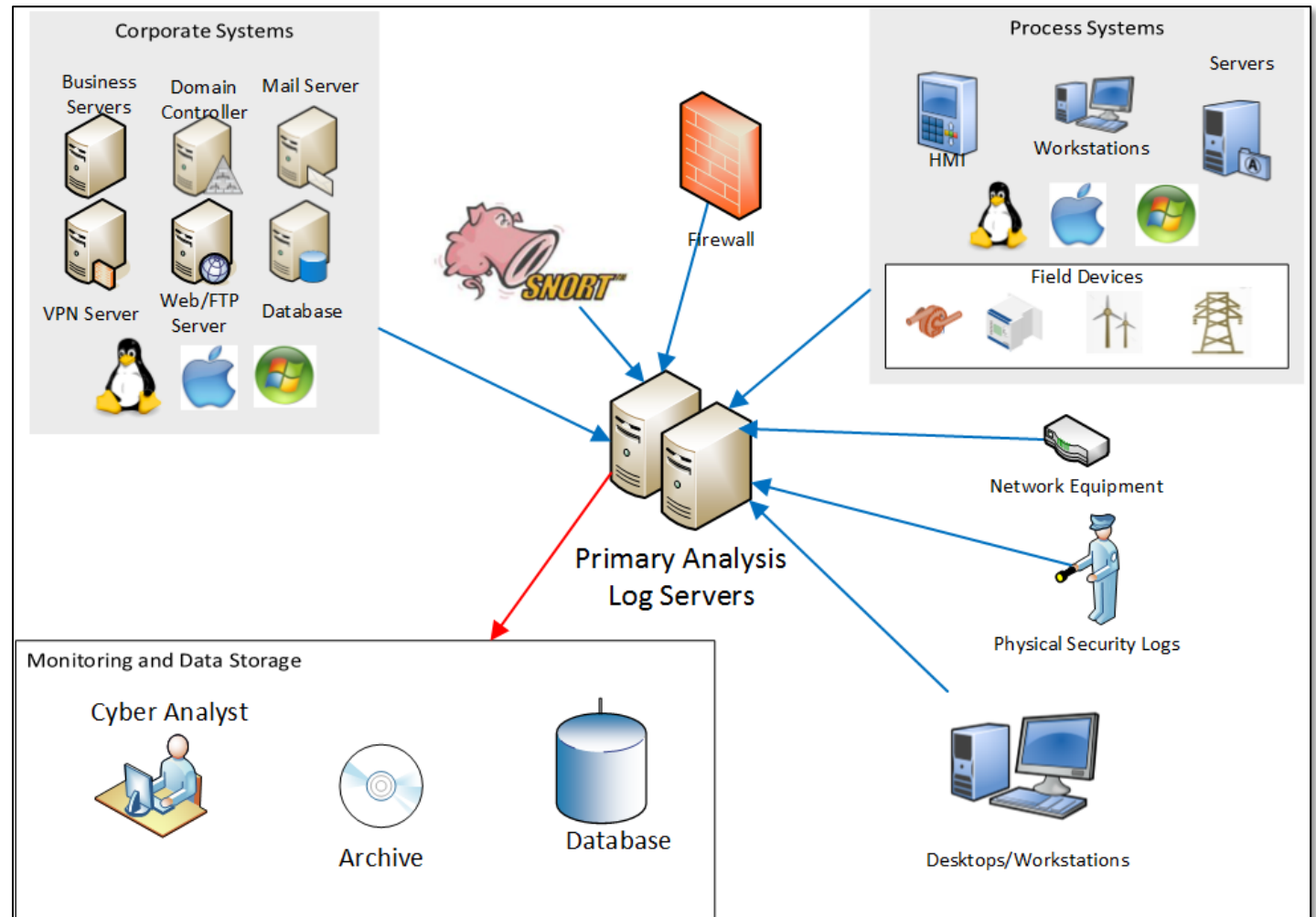
ICS Cybersecurity Evaluation (401 Virtual) Training

Logging Architecture



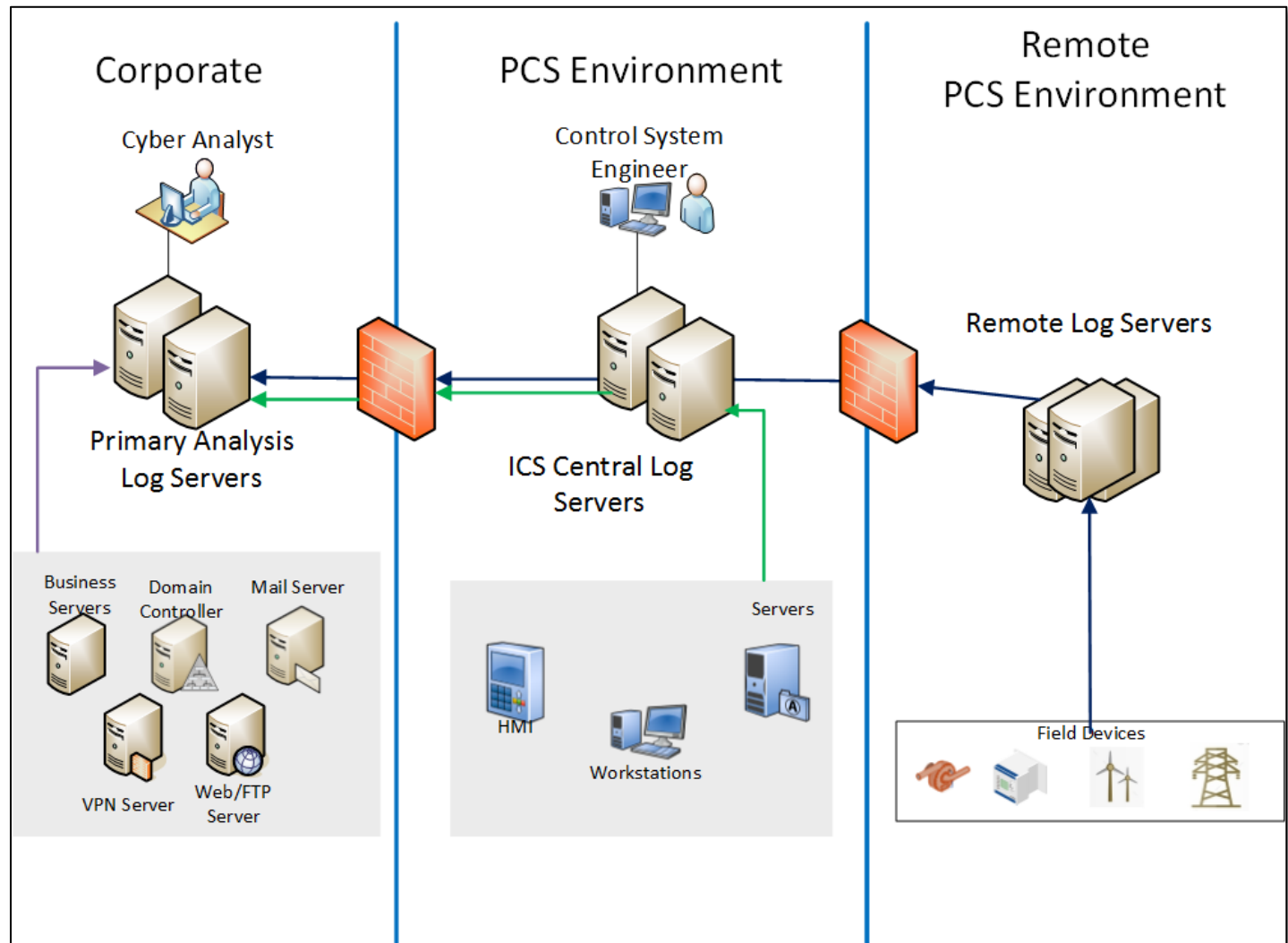
ICS Cybersecurity Evaluation (401 Virtual) Training

- A central log server can assist in threat identification or incident investigation by providing a chronological list of events – providing a more complete, bigger picture.
- Correlating with other logs can sometimes make the difference between recognizing an event for what it is (true or false) and then acting accordingly.
- Physical Security logs can help to identify an insider threat that has physically accessed the computer systems.



ICS Cybersecurity Evaluation (401 Virtual) Training

- In this example, we send our logs to the central control centers and field devices to an ICS Log Server.
- The ICS Log Server forwards data to the Centralized Log servers
- These Log servers should be placed in a high security area of the network.



ICS Cybersecurity Evaluation (401 Virtual) Training

Monitoring Control System

- Monitoring and management of control system
 - Devices, protocols, communications, user accounts, product / firmware versions, device settings
 - Host intrusion detection (HIDS)
 - Network intrusion detection (NIDS)
- Protection of control system
 - Boundary and security zone (Firewalls / Data Diodes)
 - Application and Media allow-listing
- Compliance audit and change management

Evaluating Network Monitoring

- NIST 800-53 Control - AU-6 - Audit Review, Analysis, and Reporting
 - Consistently part of CISA AES - Validated Architecture Design Review (VADR) findings.
- Control:
 - a. Reviews and analyzes information system audit **on at least on a weekly basis** for indications of **inappropriate or unusual activity**; and
 - b. Reports findings to **organization-defined personnel or roles**.
- Additional Guidance
 - a. *Process Integration*
 - b. *Correlate Audit Repositories*
 - c. *Integration of Scanning and Monitoring Capabilities*
 - d. *Correlation of Physical Monitoring*
- Policy needed to govern review of log data analysis

Network Monitoring Policy

- Log and Monitoring Policy should define:
 - Purpose of monitoring and logging
 - Who is responsible for audit logging and review
 - Frequency of log and audit review
 - Requirements for system owners
 - Activities to be logged (systems, applications)
 - Format of logs and storage
 - Protecting logs from risk
 - Administrative responsibilities

ICS Cybersecurity Evaluation (401 Virtual) Training

Data

There are many data types and collection tools. A few of which are listed in the table below:

Types	Description	Collection tools
Full content	unfiltered collection of packets	 Wireshark  
Extracted content	data streams, files, web pages, etc.	 NetworkMiner
Session	conversation between nodes	 Zeek
Transaction	requests and replies between nodes	 Zeek
Statistical	description of traffic, such as protocol and volume	 Wireshark  
Metadata	aspects of data (e.g., who owns this IP address)	
Alert/log	triggers from IDS tools, tracking user	   Kibana

Log Sources

Below are some commonly used logs, many of which are used in ICS environments. ICS vendors may be able to provide additional information on application-specific logs or third-party tools.

- Firewalls
- IDS Logs (Zeek and Snort)
- VPN Servers (may be part of Firewall logs)
- Operating Systems (e.g., Windows, *nix, Mac)
- Proxy Server
- Web Servers (e.g., IIS, Apache, Nginx)
- Databases (e.g., MS SQL, Oracle, MySQL)
- Other (e.g., PLCs, HMIs)

Snort IDS/IPS

Snort is an open-source deep packet inspection intrusion detection system (IDS) or intrusion prevention system (IPS). Snort is widely used and has become the standard for IPS/IDS. Learning to write Snort rules is useful because most IPS/IDS applications will either use the Snort rule format or provide a way to import Snort rules.

In an ICS environment, Snort is beneficial to ensure expected commands are being sent to your devices. Snort has ICS-specific preprocessors that enable you to easily identify functions from Modbus and DNP3 on your network. The following links provide more information about the Modbus and DNP3 preprocessors: <https://www.snort.org/faq/readme-modbus>, <https://www.snort.org/faq/readme-dnp3>

ICS Cybersecurity Evaluation (401 Virtual) Training

What to Monitor?

- Malware
- Failed Logins
- Specific Event Codes – OS / Network
- Unexpected Function Codes
- Unexpected IP Addresses
- Unexpected Protocols
- Anomalies
- Continuous Monitoring

Network Monitoring Concerns

False Positives - A legitimate network event alerted by the solution as a potential problem.

False negative - A malicious event that occurred but was not detected by the security architecture.

Unknown – Events detected by the solution requiring additional investigation.

How is Incident Response Supposed to Work?



Incident Response Plan

1. Overview, goals, and objectives
2. Response actions
3. Incident description
4. Communications
5. Incident detection
6. Forensics
7. Incident notification
8. Incident analysis
9. Additional sections – tabletops, playbooks, contact lists, etc.

“Developing an Industrial Control Systems Cybersecurity Incident Response Capability,”
– DHS, October 2009

ICS Cybersecurity Evaluation (401 Virtual) Training

Incident Response Questions

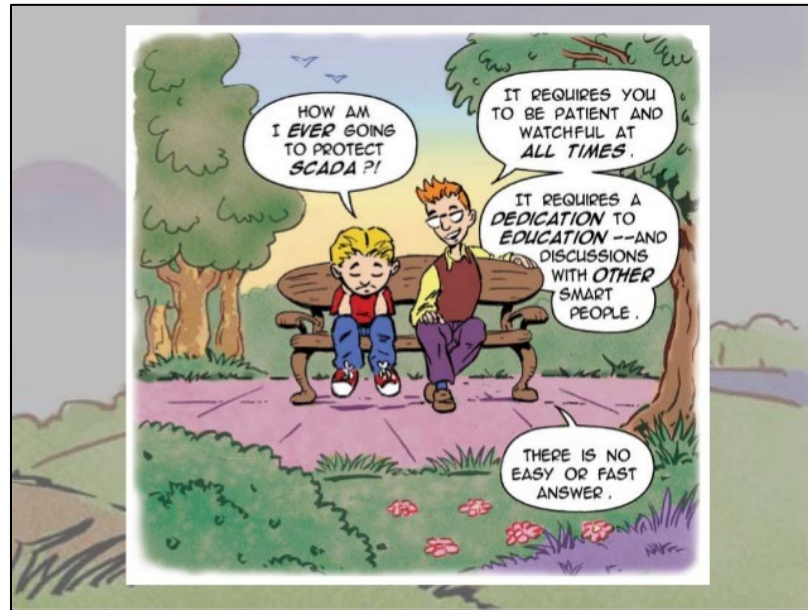
- ✓ Does the organization have written incident response procedures for the ICS Network that include a definition of personnel roles for handling incidents?
- ✓ Does the organization conduct table-top exercises yearly to evaluate responses to a designated threat scenario?
- ✓ Does the organization maintain third-party contact information to be used in security incident reporting?
- ✓ Does the organization ensure incident handling team personnel understand current threats and risks, as well as their responsibilities, by conducting periodic incident scenario sessions?
- ✓ Are auditable events adequate to support after-the-fact investigations of security incidents?

Review

Do	Do Not
✓ Know your network	✗ Assume you are in control of your own network
✓ Segment and segregate IT and OT	✗ Think you can outsmart your adversaries
✓ Place the sensors appropriately	✗ Think your network is of no interest to adversaries
✓ Centralize sys/event log collection – use a SIEM	✗ Think you'll ever be done with practicing good cybersecurity principles
✓ Perform full packet capture to the extent possible	✗ Assume that is not changing – many people touch your network in ICS
✓ Utilize the static nature of the OT environment	
✓ Have people who are curious and attentive	
✓ Remember defense-in-depth	

ICS Cybersecurity Evaluation (401 Virtual) Training

Little Bobby



Cybersecurity Performance Goals (CPGs)

This is one of the cybersecurity performance goals associated with network monitoring. You will complete an evaluation using CSET® at the conclusion of this training.

2.G-

DETECTION OF UNSUCCESSFUL (AUTOMATED) LOGIN ATTEMPTS			PR.AC-7
OUTCOME		RECOMMENDED ACTION	
Protect organizations from automated, credential-based attacks.		All unsuccessful logins are logged and sent to an organization's security team or relevant logging system. Security teams are notified (e.g., by an alert) after a specific number of consecutive, unsuccessful login attempts in a short period (e.g., five failed attempts in two minutes). This alert is logged and stored in the relevant security or ticketing system for retroactive analysis.	
TTP or RISK ADDRESSED	SCOPE	For IT assets, a system-enforced policy prevents future logins for the suspicious account. For example, this could be for some minimum time, or until the account is re-enabled by a privileged user. This configuration is enabled when available on an asset. For example, Windows 11 can automatically lock out accounts for 10-minutes after 10 incorrect logins over a 10-minute period.	
- Brute Force - Password Guessing (T1110.001) - Brute Force - Password Cracking (T1110.002) - Brute Force - Password Spraying (T1110.003) - Brute Force - Credential Stuffing (T1110.004)	Password-protected IT and OT assets, where safe and technically capable		

LOW COST
HIGH IMPACT
LOW COMPLEXITY

2.S-

INCIDENT RESPONSE (IR) PLANS			PR.IP-9, PR.IP-10
OUTCOME		RECOMMENDED ACTION	
Organizations maintain, practice, and update cybersecurity incident response plans for relevant threat scenarios.		Organizations have, maintain, update, and regularly drill IT and OT cybersecurity incident response plans for both common and organizationally-specific (e.g., by sector, locality) threat scenarios and TTPs. When conducted, tests or drills are as realistic as feasible. IR plans are drilled at least annually, and are updated within a risk-informed time frame following the lessons learned portion of any exercise or drill.	
TTP or RISK ADDRESSED	SCOPE		
Inability to quickly and effectively contain, mitigate, and communicate about cybersecurity incidents.	Organization-wide		

LOW COST
HIGH IMPACT
LOW COMPLEXITY

ICS Cybersecurity Evaluation (401 Virtual) Training

2.T

LOG COLLECTION			PR.PT-1
OUTCOME		RECOMMENDED ACTION	
Achieve better visibility to detect and effectively respond to cyberattacks.		Access- and security-focused logs (e.g., intrusion detection systems/intrusion prevention systems, firewall, data loss prevention, virtual private network) are collected and stored for use in both detection and incident response activities (e.g., forensics). Security teams are notified when a critical log source is disabled, such as Windows Event Logging.	
TTP or RISK ADDRESSED	SCOPE		
- Delayed, insufficient, or incomplete ability to detect and respond to potential cyber incidents - Impair Defenses (T1562)	IT and OT assets	OT: For OT assets where logs are non-standard or not available, network traffic and communications between those assets and other assets is collected.	

MEDIUM-LOW COST

HIGH IMPACT

**MEDIUM
COMPLEXITY**

2.U

SECURE LOG STORAGE			PR.PT-1
OUTCOME		RECOMMENDED ACTION	
Organizations' security logs are protected from unauthorized access and tampering.			
TTP or RISK ADDRESSED	SCOPE		
- Indicator Removal on Host - Clear Windows Event Logs (T1070.001) - Indicator Removal on Host - Clear Linux or Mac System Logs (T1070.002) - Indicator Removal on Host - File Deletion (T1070.004) - Indicator Removal on Host (ICS T0872)	IT and OT assets	Logs are stored in a central system, such as a security information and event management tool or central database, and can only be accessed or modified by authorized and authenticated users. Logs are stored for a duration informed by risk or pertinent regulatory guidelines.	

**MEDIUM-HIGH
COST**

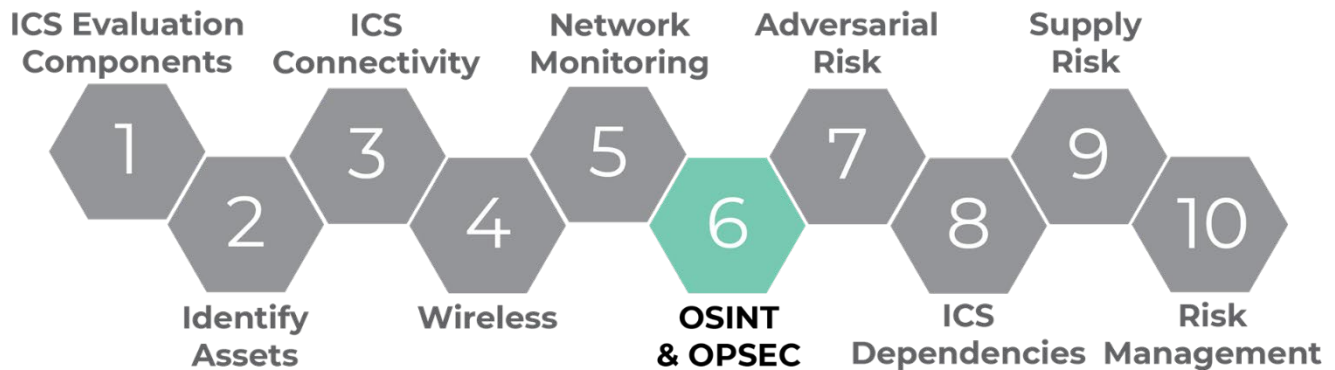
HIGH IMPACT

LOW COMPLEXITY

ICS Cybersecurity Evaluation (401 Virtual) Training

LO6: Identify Risk Using OPSEC and OSINT

In this objective we will apply OPSEC and OSINT methods to identify potentially exposed information.



Threats

- Adversaries leverage public information to develop attack paths and techniques targeting company information
- Successful attackers learn about their targeted organization's security posture through profiling and footprinting
- There is generally a TON of information that can be found
- Critical Infrastructure and control systems are increasingly popular targets



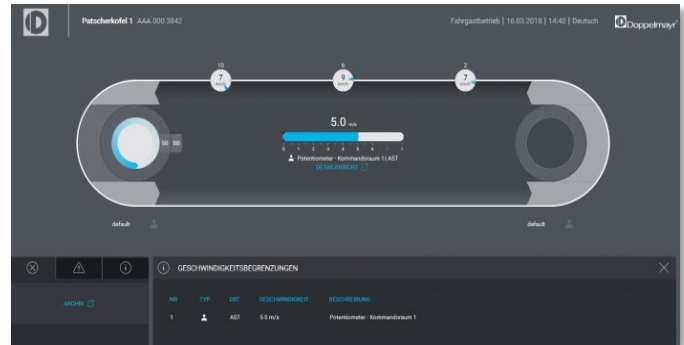
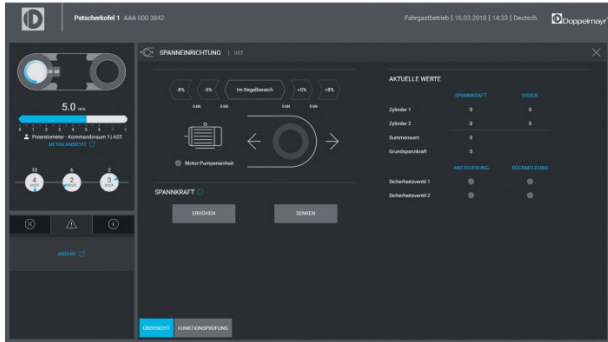
OSINT
& OPSEC

6

ICS Cybersecurity Evaluation (401 Virtual) Training

Threat Example

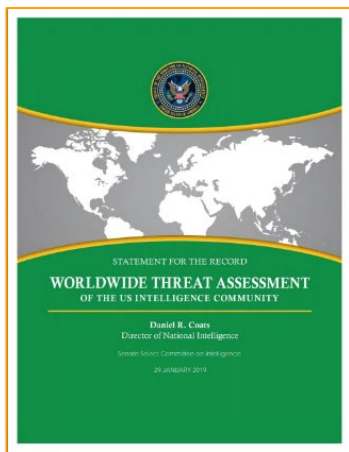
HMIs for a ski lift in Austria were left open on the Internet. If an attacker got a hold of these HMIs they can control the cable tension, distance between cable cars, speed, and direction of the lifts.



That same day as the Austrian ski resort shut down, a “malfunction” with the same HMI and controls vendor in Gudauri, Georgia happened. Coincidence?

ICS Incidents

In the January 2019 Worldwide Threat Assessment Report, the Director of National Intelligence calls out specific countries as actively mapping our Nation’s critical infrastructure for the purpose of causing substantial damage to our way of life.



“[Nation States are] mapping our critical infrastructure with the long-term goal of being able to cause substantial damage.”

— DNI

***They are not targeting my network.
But what if they already know it better than you?
What can they do?***

OSINT
& OPSEC

6

ICS Cybersecurity Evaluation (401 Virtual) Training

Examples

Norsk Hydro

A company that was cyberattacked and shared what they learned from experience with other companies.

The cyberattack rescue operation in Hydro Toulouse: <https://www.youtube.com/watch?v=o6eEN0mUakM>

Why Hydro chose to be transparent during cyberattack: <https://www.youtube.com/watch?v=C6MDz-AgQuE>

Bowman Avenue Dam

Purpose: Kept basements from flooding in a suburban neighborhood

Details: Began operation in 2013

- Sluice gate: 15 ft. wide x 2.5 ft. high
- SCADA system running a modern and complex array of sensors in the waterway used to automatically control the sluice gate, adjusting flow rate accordingly

Specifcits: Found by scanning the Internet for SCADA systems – connected via cellular modem. Attacked by Iran’s Revolutionary Guards Corps.

Operations Security (OPSEC)

- Military origins – “*Loose Lips Sink Ships*”
- It is a process, NOT a set of rules
 - Identify critical information
 - Analyze threats
 - Analyze vulnerabilities
 - Assess risks
 - Apply countermeasures
- Physical and cyber applications
- Should be part of your cybersecurity plan
- Should be integrated and synchronized throughout the organization

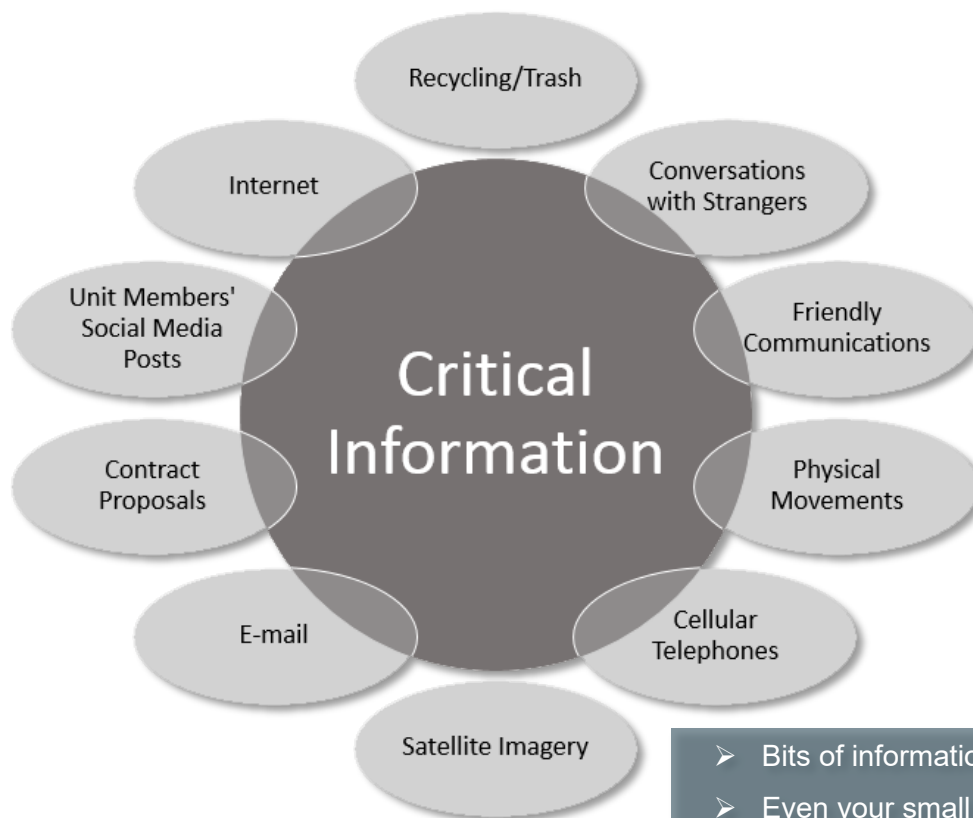
ICS Cybersecurity Evaluation (401 Virtual) Training

Identify Critical Information (CI)



“There’s a lot of information out there on my organization. So what? It’s just random bits of data that doesn’t mean anything ...”

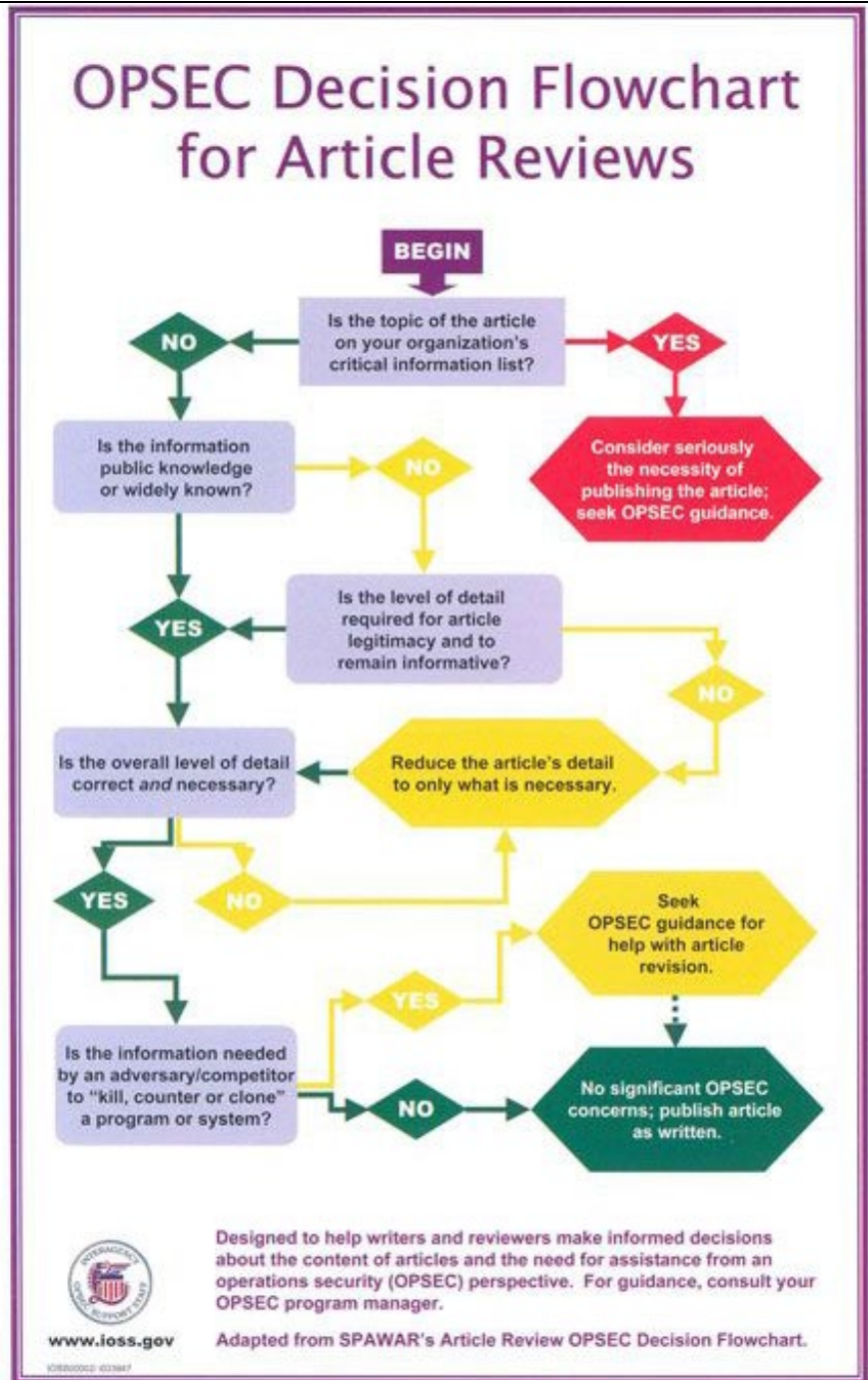
- It’s information about intentions, capabilities, and activities that allow an adversary to effectively plan to disrupt operations.
- Data are transformed into intelligence. The operational environment / business generates data. Patterns are identified in the data turning it into information. Context can be added to information to transform it into intelligence.
- Identifying CI can be difficult.



- Bits of information are puzzle pieces
- Even your small bits help complete the picture

ICS Cybersecurity Evaluation (401 Virtual) Training

- Determining what is critical for your organization requires a thorough understanding of how the organization operates.
- **Ask:** Would this bit of information be a risk to the success of the organization or the security of your customers?
- Check your information sources and destinations. Identify and document where CI is found within business processes.



ICS Cybersecurity Evaluation (401 Virtual) Training

Identify CI (Continued)

- A Critical Information List (CIL) can be created to prioritize data.
- Customer data, passwords, network information, data for analysis, etc., are examples of CI.
- The CIL should be fluid.
- Employees should be trained on how to secure the items on the CIL.

Example CIL	
• Work Schedules • Shipping requests or announcements • Meeting minutes or notes • Various reports (monthly, annual, etc.) • Scope-of-work orders • Staffing reports • Unusual occurrence reports • Purchasing requests • Travel requests/trip reports • Project units/blueprints • News releases • Progress reports • Published articles • Corporate newsletters • Emergency plans • Budget or financial documentation	• Employee suggestions • Standard Operating Procedures • Environmental Impact Statements • Position vacancy announcements • Operating manuals • Safety reports • Quality assurance notes • Information contained on home pages • Stereotyped activities (test schedules, range schedules, test preparations, range closures, etc.) • Increased levels of communications • Transportation arrangements

Open-Source Intelligence (OSINT)

OSINT is gathering information from publicly available sources to be used in an intelligence context.

There are many tools and techniques available for gathering and organizing information. We will introduce you to a few of the tools and techniques to highlight how and what types of information can be gathered about an organization.

- Tools and techniques:
 - Social media
 - Internet Archive
 - Builtwith
 - Robots.txt
 - Scans.io / Shodan
 - Google hacking
 - Maltego
 - Networking tools Nmap, nslookup, dig, etc.
- It is not just what you put out there, but what is publicly available about you (e.g., FCC, regulatory info, contracts)
 - Antennasearch – Strava

OSINT Historical Examples

Below are just a few categories and examples to learn from with regards to OSINT security.

OSINT
& OPSEC

6

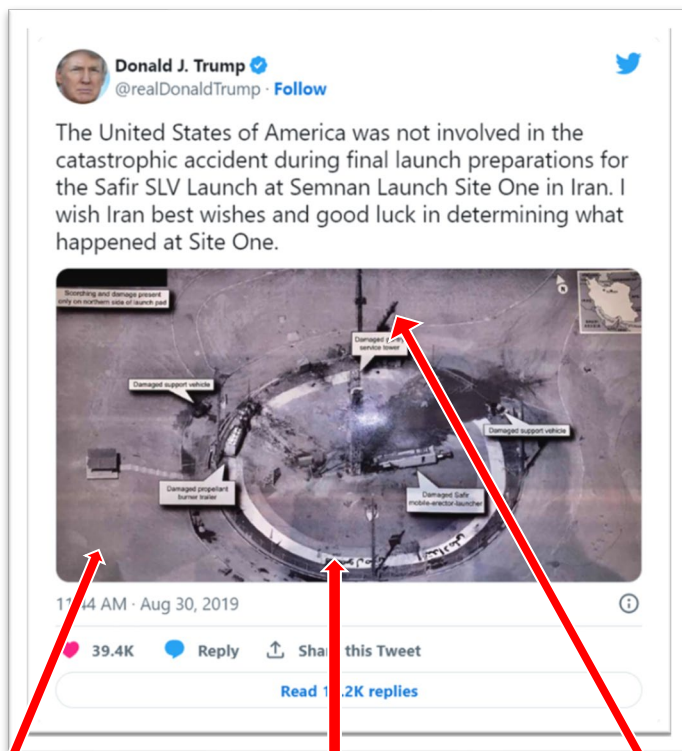
ICS Cybersecurity Evaluation (401 Virtual) Training

Social Media

Social media is an important piece in an organization's OPSEC plan. Social media users tend to be more open about their thoughts and can end up sharing sensitive company information. Take a few minutes to review Elliott Tessermick's Twitter (a.k.a. X) posts (CEO of ACME).

- Open the Internet browser
 - Go to the following URL: <https://twitter.com/acmechem>
 - Do you see anything that may have the potential negative impact to Elliott or ACME, Inc.?

Using a Twitter (a.k.a. X) post image, in less than 24 hours a group of individuals on the Internet managed to identify the exact satellite used to take the photo, revealing a secret satellite. What seemed a harmless post contained enough data points that, to the right individual or group, can find unintended information.



Hi-res
image

Elliptical shape
of circular object

Angle of
sun's
shadow



OSINT
& OPSEC

6

ICS Cybersecurity Evaluation (401 Virtual) Training

Internet Archive



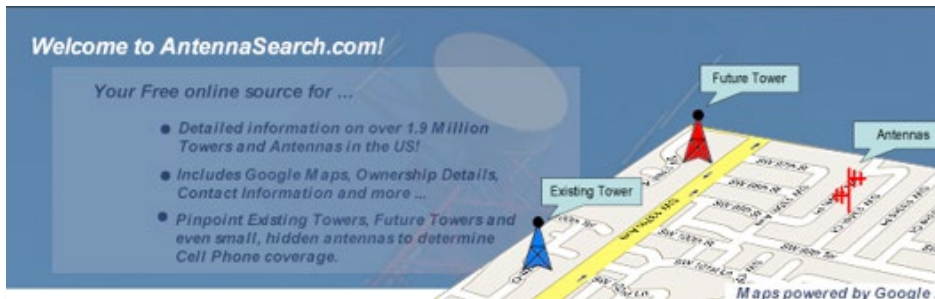
Even if information on the Internet is removed, there are various sources that archive old data, such as the Internet archive or “Way Back Machine.” If information is critical, extra steps may need to be taken to secure it.

Robots.txt

Sometimes useful information can be derived using other sources. Old websites or files thought inaccessible can still be found using the correct tools or resources.

Example: “I’m a MAC, I’m a PC” campaign website.

Antennasearch

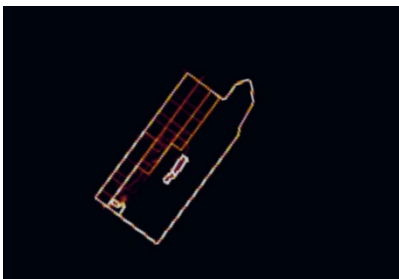


Some sources may be out of your control.

This is an example of antenna data that can search a prescribed area and report back information on the local antennas, including installation location, contact

information, and more. When using certain tools or resources, certain information may leave your control and it can be important to know what is publicly made available and be aware of it.

Mobile Phones Tracking (Strava)



This is an image of a health application creating a “heat map” using user tracking data.

If you knew an app tracked not only movement, but also when and how long a person was stationary, what detail can you infer from this heat map image?

Strava originally had an “opt-out” option that required participants to manually opt-out of being tracked. When soldiers installed it on their phones, heat maps of their movement were tracked and displayed

on Strava’s website. Several military installation locations were revealed for multiple countries.

ICS Cybersecurity Evaluation (401 Virtual) Training

OSINT Framework

OSINT framework is a collection of some of the most used OSINT gathering tools compiled into one handy website.

- www.osintframework.com
 - The Go To tool for OSINT searches
 - Collection of OSINT tools
 - Open-source on GitHub

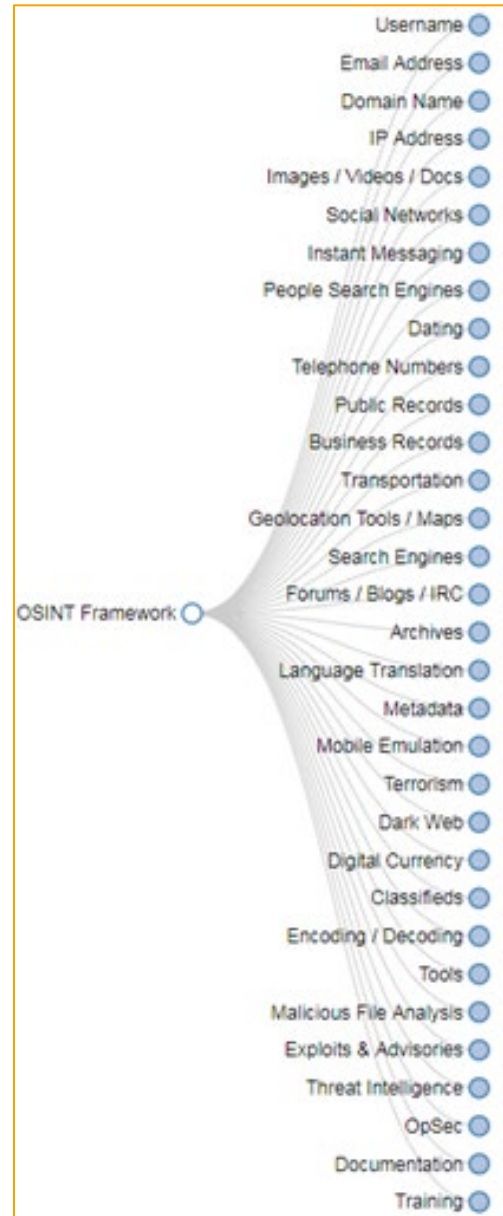
Google Hacking (Dorks)

Google has advanced search operators to help refine search results. Originally created for Search Engine Optimization (SEO) tasks, the advanced operators can return information that is not easily found through default searches on Google. There are approximately 30 advanced search operators available. The list changes as Google adds or deprecates operators.

The advanced operators enable people to find sensitive documents, code, and even vulnerable devices and services on the Internet. Security researcher Johnny Long brought the power of the advanced operators to light. He said they revealed “foolish” companies on the Internet, for which he coined the term “Google Dorks.” The term Google Dorks, or Dorking is now synonymous with Google Hacking.

The Google Hacking Database (GHDB) was created from Johnny Long’s project to index dorks who applied to finding devices and security vulnerabilities. The GHDB is currently hosted by exploit-db and is still heavily used and contributed to today. You can use these advanced operators to look for sensitive information about your organization that may be exposed.

An optional activity is available in Appendix B for Google Hacking.



ICS Cybersecurity Evaluation (401 Virtual) Training

Physical OPSEC

Most of us are probably familiar with the “ThreeGs” of physical security — gates, guards, and guns. Gates, guards, and guns are necessary in some places, but these physical deterrents do not do much good if proper attention is not given to them. OPSEC definitely applies to physical security as well, and should be considered by everyone in the organization.

Here are some tips on things to watch out for:

- Monitor who is entering your facilities; Check identification, and escort visitors.
- Report broken doors, windows, locks, etc.
- Inventory keys, badges, access cards, uniforms, vehicles, etc.
- Clear workspaces of PII (personally identifiable information) and other sensitive information that is no longer needed.
- Perform regular walkthroughs and inspections.



Hawaii Emergency Management Agency OPSEC Exercise



Identify as many OPSEC errors as you can from the image and record them.

Activity resources can be found on the CISA VLP.

ICS Cybersecurity Evaluation (401 Virtual) Training

Analyze Threats

Threats come from adversaries and consider intent, capability, and opportunity. The greater the combined intent and capability of an adversary, the greater the threat.

Understand how you fit in the picture (you may not be the main target, but a path to the desired target).

Keep up to date on the latest threats, hacks, and exploits, along with trends in cyber and physical security. Use information sources such as Threat Intelligence feeds, ISACs, US-CERT, Infraguard, DNI reports, etc., to learn about threats and associated indicators.

Revisit your CIL. What is defined as CI may depend to a degree on the threats you are facing. Change your context while reviewing the Critical Information List (CIL).

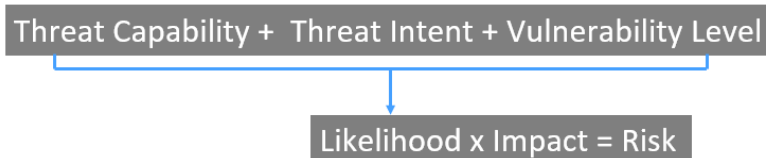


Analyze Vulnerabilities

In simple terms, **threat** can be thought of as the strength of the adversary, and **vulnerability** the weakness of an organization. Identify OPSEC indicators and compare them against the adversary's intelligence gathering capabilities. How would someone exploit the network, employees, or operations to get inside and do damage? IT and OT leaders should be sure they know the network in order to determine its potential flaws. Employees should be aware of potential social engineering attacks. Every machine should be audited regularly to ensure it is free of spyware and malware.

Assess Risk

Risk is based on the amount of harm a vulnerability may allow if exploited by an adversary, combined with the probability of the vulnerability being exploited.



The probability of compromise is greatest when the threat is very capable and dedicated, while friendly organizations are simultaneously exposed. Threats range from low to high. Once you know what kind of security threats you have and where your most vulnerable areas are, you can determine the risk and what needs to be done. Analyze vulnerabilities along with available countermeasures. You can outsource your operations, but you cannot outsource your risk!

Apply Countermeasures

OPSEC planning is useless without OPSEC application. Threats are different for different organizations, but every identified weakness or vulnerability deserves focused attention. Whether you are implementing policy improvements or buying a new security appliance, the costs of good security

ICS Cybersecurity Evaluation (401 Virtual) Training

are generally far less than the costs of a breach or production outage. Doing something is better than doing nothing.

Below are recommendations for an OPSEC plan — the format is organization-specific; however, plans should generally include:

- References
- General mission / program description
- Security responsibilities
- Critical information list (CIL)
- Indicators
- Threat
- Vulnerabilities
- Risk determination
- Countermeasures
- Management decision on which countermeasures to implement
- Public affairs
- Training
- Supporting units / associated programs
- Resources utilized

Common Issues

Common issues associated with OPSEC/OSINT include:

- ✓ Content published by the organization is not reviewed for security risks and sensitive information
- ✓ No password policy, potentially leaving default passwords on Internet-connected devices. Passwords on sticky notes
- ✓ Social media posts revealing sensitive company information
- ✓ No governance on system deployments resulting in unidentified assets potentially open externally
- ✓ Use of unsupported or unpatched software on external systems
- ✓ Flat network architecture and use of routable IP addresses exposing control systems externally
- ✓ Use of non-company-owned devices accessing information systems
- ✓ Staff are not trained on OPSEC and cybersecurity issues
- ✓ Laptops are not protected from loss outside of the facility; No full disk encryption
- ✓ Physical access is not monitored
- ✓ Computing equipment tossed in the trash without proper data destruction or sanitization

ICS Cybersecurity Evaluation (401 Virtual) Training

OPSEC Exercise – VLP

A 360° image that allows you to check a workspace for OPSEC security risks. Resources can be found on the CISA VLP.

Cybersecurity Performance Goals (CPGs)

This is one of the CPGs associated with OSINT and OPSEC. You will complete an evaluation using CSET® at the conclusion of this training.

1.E

MITIGATING KNOWN VULNERABILITIES		ID.RA-1, PR.IP-12, DE.CM-8, RS.MI-3, ID.RA-6, RS.AN-5
OUTCOME		RECOMMENDED ACTION
Reduce the likelihood of threat actors exploiting known vulnerabilities to breach organizational networks.		All known exploited vulnerabilities (listed in CISA's Known Exploited Vulnerabilities Catalog in internet-facing systems are patched or otherwise mitigated within a risk-informed span of time, prioritizing more critical assets first. OT: For assets where patching is either not possible or may substantially compromise availability or safety, compensating controls are applied (e.g., segmentation, monitoring) and recorded. Sufficient controls either make the asset inaccessible from the public internet or reduce the ability of threat actors to exploit the vulnerabilities in these assets.
TTP or RISK ADDRESSED	SCOPE	
- Active Scanning - Vulnerability Scanning (T1595.002) - Exploit Public-Facing Application (T1190, ICS T0819) - Exploitation of Remote Service (T1210, ICS T0866) - Supply Chain Compromise (T1195, ICS T0862) - External Remote Services (T1133, ICS T0822)	Internet-facing assets	

2.B

MINIMUM PASSWORD STRENGTH		PR.AC-1
OUTCOME		RECOMMENDED ACTION
Organizational passwords are harder for threat actors to guess or crack.		Organizations have a system-enforced policy that requires a minimum password length of 15* or more characters for all password-protected IT assets and all OT assets, when technically feasible.** Organizations should consider leveraging passphrases and password managers to make it easier for users to maintain sufficiently long passwords. In instances where minimum password lengths are not technically feasible, compensating controls are applied and recorded, and all login attempts to those assets are logged. Assets that cannot support passwords of sufficient strength length are prioritized for upgrade or replacement. This goal is particularly important for organizations that lack widespread implementation of MFA and capabilities to protect against brute-force attacks (such as web application firewalls and third-party content delivery networks) or are unable to adopt passwordless authentication methods. * Modern attacker tools can crack eight-character passwords quickly. Length is a more impactful and important factor in password strength than complexity or frequent password rotations. Long passwords are also easier for users to create and remember. ** OT assets that use a central authentication mechanism (such as Active Directory) are most important to address. Examples of low-risk OT assets that may not be technically feasible include those in remote locations, such as those on offshore rigs or wind turbines.
TTP or RISK ADDRESSED	SCOPE	
- Brute Force - Password Guessing (T1110.001) - Brute Force - Password Cracking (T1110.002) - Brute Force - Password Spraying (T1110.003) - Brute Force - Credential Stuffing (T1110.004)	Password-protected IT and Windows-based OT assets	

2.I

BASIC CYBERSECURITY TRAINING		PR.AT-1
OUTCOME		RECOMMENDED ACTION
Organizational users learn and perform more secure behaviors.		At least annual trainings for all organizational employees and contractors that cover basic security concepts, such as phishing, business email compromise, basic operational security, password security, etc., as well as foster an internal culture of security and cyber awareness. New employees receive initial cybersecurity training within 10 days of onboarding and recurring training on at least an annual basis.
TTP or RISK ADDRESSED	SCOPE	
User Training (M1017, ICS M0917)	All employees and contractors	

LOW COST

HIGH IMPACT

MEDIUM COMPLEXITY

LOW COST

HIGH IMPACT

LOW COMPLEXITY

LOW COST

HIGH IMPACT

LOW COMPLEXITY

OSINT
& OPSEC

6

ICS Cybersecurity Evaluation (401 Virtual) Training

2.W-

NO EXPLOITABLE SERVICES ON THE INTERNET			PR.AC-3
OUTCOME		RECOMMENDED ACTION	
Unauthorized users cannot gain an initial system foothold by exploiting known weaknesses in public-facing assets.		Assets on the public internet expose no exploitable services, such as remote desktop protocol. Where these services must be exposed, appropriate compensating controls are implemented to prevent common forms of abuse and exploitation. All unnecessary OS applications and network protocols are disabled on internet-facing assets.	
TTP or RISK ADDRESSED	SCOPE		
- Active Scanning - Vulnerability Scanning (T1595.002) - Exploit Public-Facing Application (T1190, ICS T0819) - Exploitation of Remote Service (T1210, ICS T0866) - External Remote Services (T1133, ICS T0822) - Remote Services - Remote Desktop Protocol (T1021.001)	IT and OT assets on the public internet		

LOW COST
HIGH IMPACT
LOW COMPLEXITY

2.X-

LIMIT OT CONNECTIONS TO PUBLIC INTERNET			PR.PT-4, PR.AC-5
OUTCOME		RECOMMENDED ACTION	
Reduce the risk of threat actors exploiting or interrupting OT assets connected to the public internet.		No OT assets are on the public internet, unless explicitly required for operation. Exceptions must be justified and documented, and excepted assets must have additional protections in place to prevent and detect exploitation attempts (such as logging, MFA, mandatory access via proxy or other intermediary, etc.).	
TTP or RISK ADDRESSED	SCOPE		
- Active Scanning - Vulnerability Scanning (T1595.002) - Exploit Public-Facing Application (T1190, ICS T0819) - Exploitation of Remote Service (T1210, ICS T0866) - External Remote Services (T1133, ICS T0822)	OT assets on the public internet		

MEDIUM-HIGH COST
MEDIUM IMPACT
MEDIUM COMPLEXITY

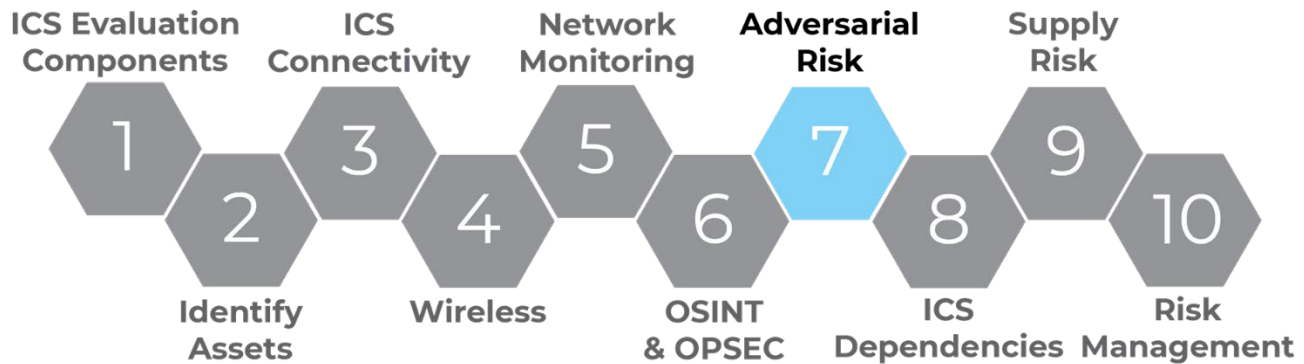
OSINT
& OPSEC

6

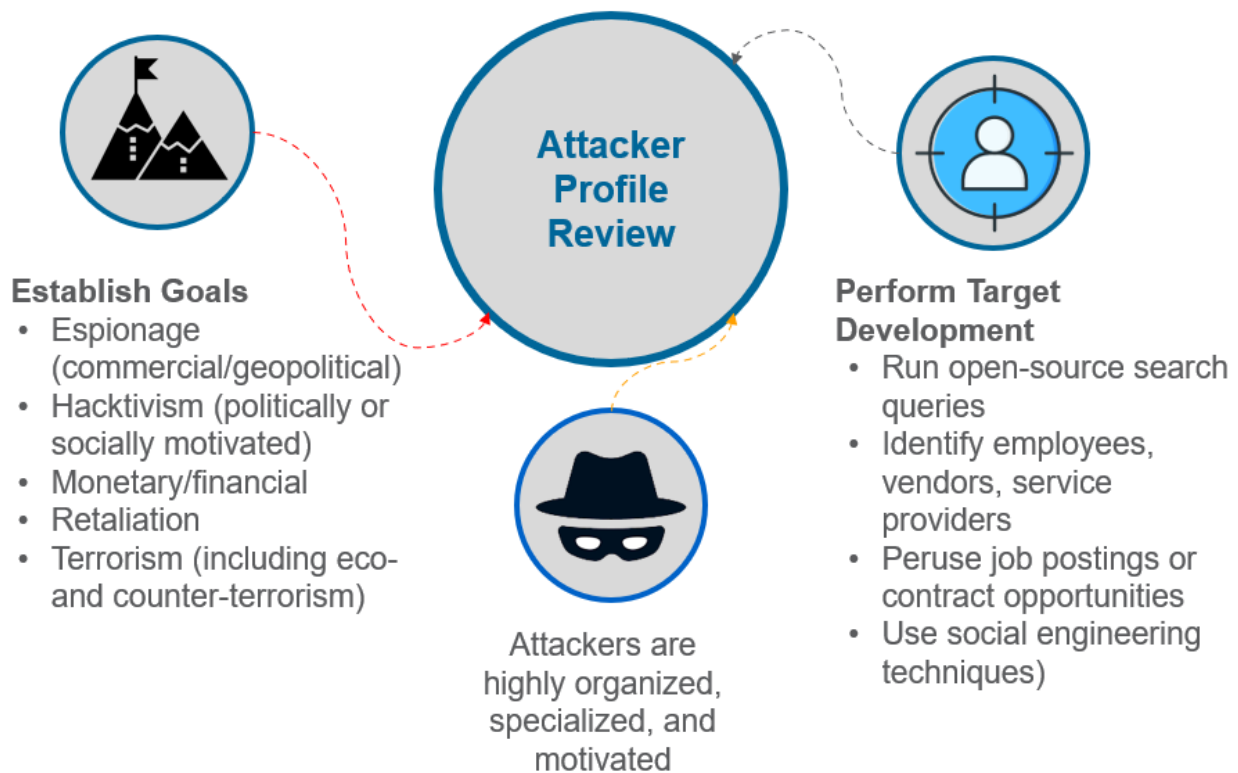
ICS Cybersecurity Evaluation (401 Virtual) Training

LO7. Evaluate Adversarial Risk to an ICS Environment

Continuing with assessing risk to the business, this section will discuss adversarial risk.



Normally, risk assessment is a determination of quantitative or qualitative risk related to a well-defined situation and a recognized threat based on magnitude of potential loss, and the probability loss will occur. However, in evaluating adversarial risk we will be looking at various ways an aggressor looks at and traverses a victim's network to identify potential attack targets and paths to achieve their goals. Armed with this aggressor perspective, it is easier to identify and apply appropriate mitigations to minimize adversarial risk.



ICS Cybersecurity

Evaluation (401 Virtual) Training

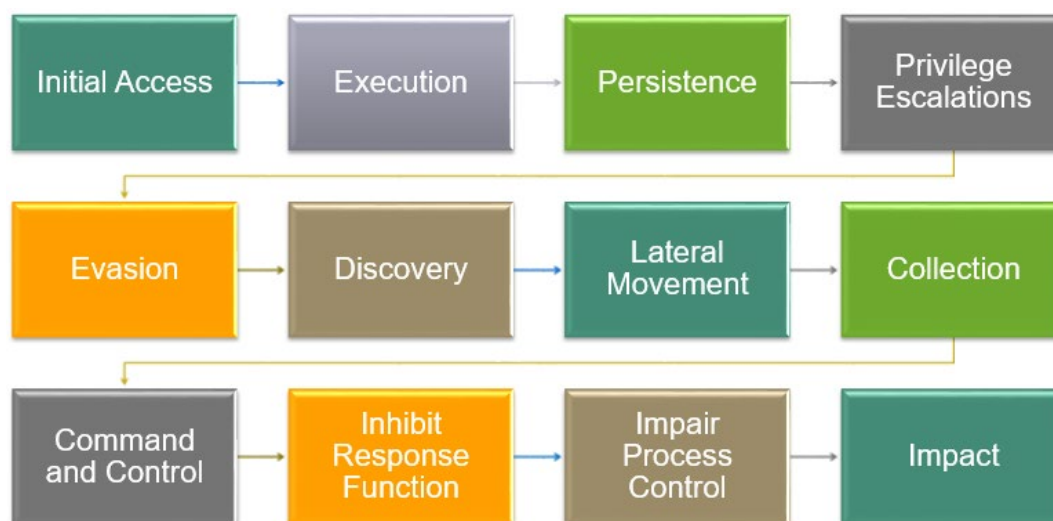


Phishing Exercise

You will learn about and craft a phishing email, as well as evaluate other sample phishing emails for how effective they may be. Activity resources can be found on the CISA VLP.

Adversarial Tactics and Techniques

Attackers use several tactics and techniques to initially access and then move through a network. The ICS Matrix is constantly being updated and improved to include new and different tactics and techniques and can be found at <https://attack.mitre.org/>. The following flowchart will walk you through several adversarial tactics and associated techniques used in those tactics.



Reference: © 2022 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation.

Initial Access



Drive-by Compromise – Adversaries may gain access to a system during a drive-by compromise, when a user visits a website as part of a regular browsing session. With this technique, the user's web browser is targeted and exploited simply by visiting the compromised website.

Exploit Public-Facing Application – Adversaries may leverage weaknesses to exploit Internet-facing software for initial access into an industrial network. Internet-facing

software may be user applications, underlying networking implementations, an assets operating system, weak defenses, etc.

Exploitation of Remote Services – Adversaries may exploit a software vulnerability to take advantage of a programming error in a program, service, or within the operating system software or kernel itself to enable remote service abuse.

ICS Cybersecurity

Evaluation (401 Virtual) Training

External Remote Services – Adversaries may leverage external remote services as a point of initial access into your network. These services allow users to connect to internal network resources from external locations. Examples are VPNs, Citrix, and other access mechanisms.

Internet Accessible Device – Adversaries may gain access into industrial environments through systems exposed directly to the Internet for remote access rather than through External Remote Services. Internet Accessible Devices are exposed to the Internet unintentionally or intentionally without adequate protections.

Remote Services – Adversaries may leverage remote services to move between assets and network segments. These services are often used to allow operators to interact with systems remotely within the network, some examples are RDP, SMB, SSH, and other similar mechanisms.

Replication Through Removable Media – Adversaries may move onto systems, such as those separated from the enterprise network, by copying malware to removable media that is then inserted into the control systems environment. The adversary may rely on unknowing trusted third parties, such as suppliers or contractors with access privileges, to introduce the removable media.

Rogue Master – Adversaries may set up a rogue master to leverage control server functions to communicate with outstations. A rogue master can be used to send legitimate control messages to other control system devices, affecting processes in unintended ways.

Spear Phishing Attachment – Adversaries may use a spear phishing attachment, a variant of spear phishing, as a form of a social engineering attack against specific targets. Spear phishing attachments are different from other forms of spear phishing in that they employ malware attached to an email.

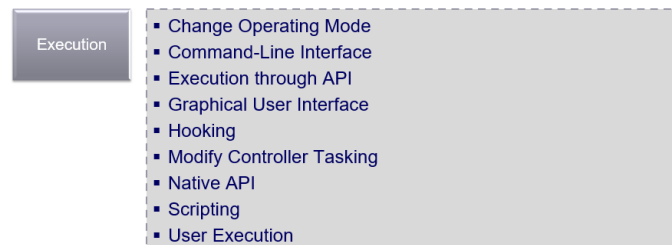
Supply Chain Compromise – Adversaries may perform supply chain compromise to gain control systems environment access by means of infected products, software, and workflows. Supply chain compromise is the manipulation of products, such as devices or software, or their delivery mechanisms before receipt by the end consumer.

Transient Cyber Asset – Adversaries may target devices that are transient across ICS networks and external networks. Normally, transient assets are brought into an environment by authorized personnel and do not remain in that environment on a permanent basis.

Wireless Compromise – Adversaries may perform wireless compromise as a method of gaining communications and unauthorized access to a wireless network. Access to a wireless network may be gained through the compromise of a wireless device.

As noted, there are many ways to get initial access to a system. Some require user interaction, some do not. By far the easiest way is through email phishing. A well written phishing email message is relatively easy to deliver but hard to defend against.

Execution



Change Operating Mode – Adversaries may change the operating mode of a controller to gain additional access to engineering functions such as Program Download. Programmable controllers typically have several modes of operation that control the state of the user program and control access to the controller's API.

ICS Cybersecurity

Evaluation (401 Virtual) Training

Command-Line Interface – Adversaries may utilize command-line interfaces (CLIs) to interact with systems and execute commands. CLIs provide a means of interacting with computer systems and are a common feature across many types of platforms and devices within control systems environments.

Execution through API – Adversaries may attempt to leverage Application Program Interfaces (APIs) used for communication between control software and the hardware. Specific functionality is often coded into APIs, which can be called by software to engage specific functions on a device or other software.

Graphical User Interface – Adversaries may attempt to gain access to a machine via a Graphical User Interface (GUI) to enhance execution capabilities. Access to a GUI allows a user to interact with a computer in a more visual manner than a CLI.

Hooking – Adversaries may hook into application programming interface (API) functions used by processes to redirect calls for execution and privilege escalation means. Windows API functions are typically stored in dynamic-link libraries (DLLs) as exported functions. One type of hooking seen in ICS involves redirecting calls to these functions via import address table (IAT) hooking. IAT hooking uses modifications to a process IAT, where pointers to imported API functions are stored.

Modify Controller Tasking – Adversaries may modify the tasking of a controller to allow for the execution of their own programs. This can allow an adversary to manipulate the execution flow and behavior of a controller.

Native API – Adversaries may directly interact with the native OS application programming interface (API) to access system functions. Native APIs provide a controlled means of calling low-level OS services within the kernel, such as those involving hardware / devices, memory, and processes.

Scripting – Adversaries may use scripting languages to execute arbitrary code in the form of a pre-written script or in the form of user-supplied code to an interpreter. Scripting languages are programming languages that differ from compiled languages, in that scripting languages use an interpreter, instead of a compiler.

User Execution – Adversaries may rely on a targeted organization's user interaction for the execution of malicious code. User interaction may consist of installing applications, opening email attachments, or granting higher permissions to documents. Adversaries may embed malicious code or visual basic code into files such as Microsoft Word and Excel documents or software installers.

Persistence

Persistence

- Modify Program
- Module Firmware
- Project File Infection
- System Firmware
- Valid Accounts

Modify Program – Adversaries may modify or add a program on a controller to affect how it interacts with the physical process, peripheral devices and other hosts on the network. Modification to controller

programs can be accomplished using a Program Download in addition to other types of program modification such as online edit and program append.

Module Firmware – Adversaries may install malicious or vulnerable firmware onto modular hardware devices. Control system devices often contain modular hardware devices. These devices may have their own set of firmware separate from the firmware of the main control system equipment.

Project File Infection – Adversaries may attempt to infect project files with malicious code. These project files may consist of objects, program organization units, variables such as tags, documentation, and other configurations needed for PLC programs to function.

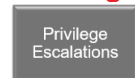
ICS Cybersecurity

Evaluation (401 Virtual) Training

System Firmware – System firmware on modern assets is often designed with an update feature. Older device firmware may be factory installed and require special reprogramming equipment. When available, the firmware update feature enables vendors to remotely patch bugs and perform upgrades.

Valid Accounts – Adversaries may rely on a targeted organization's user interaction for the execution of malicious code. User interaction may consist of installing applications, opening email attachments, or granting higher permissions to documents.

Privilege Escalations



- Exploitation for Privilege Escalation
- Hooking

Exploitation for Privilege Escalation –

Adversaries may exploit software vulnerabilities in an attempt to elevate privileges. Exploitation

of a software vulnerability occurs when an adversary takes advantage of a programming error in a program, service, or within the operating system software or kernel itself to execute adversary-controlled code.

Hooking – Adversaries may hook into application programming interface (API) functions used by processes to redirect calls for execution and privilege escalation means.

Evasion



- Change Operating Mode
- Exploitation for Evasion
- Indicator Removal on Host
- Masquerading
- Rootkit
- Spoof Reporting Message

Change Operating Mode – Operating modes can be physically selected using a key switch on the face of the controller but may also be selected with calls to the controller's API.

Exploitation for Evasion – Adversaries may exploit a software vulnerability to take advantage of a programming error in a program, service, or within the operating system software or kernel itself to evade detection. Vulnerabilities may exist in software that can be used to disable or circumvent security features

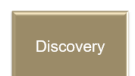
Indicator Removal on Host – Adversaries may attempt to remove indicators of their presence on a system in an effort to cover their tracks. In cases where an adversary may feel detection is imminent, they may try to overwrite, delete, or cover up changes they have made to the device.

Masquerading – Adversaries may use masquerading to disguise a malicious application or executable as another file, to avoid operator and engineer suspicion. Disguises for these masquerading files can include commonly found programs, expected vendor executables and configuration files, and other commonplace applications and naming conventions.

Rootkit – Adversaries may deploy rootkits to hide the presence of programs, files, network connections, services, drivers, and other system components. Rootkits are programs that hide the existence of malware by intercepting and modifying operating system API calls that supply system information.

Spoof Reporting Message – Adversaries may spoof reporting messages in control system environments for evasion and to impair process control. In control systems, reporting messages contain telemetry data (e.g., I/O values) pertaining to the current state of equipment and the industrial process.

Discovery



- Network Connection Enumeration
- Network Sniffing
- Remote System Discovery
- Remote System Information Discovery
- Wireless Sniffing

Network Connection Enumeration – Adversaries may perform network connection enumeration to discover information about device communication patterns. If an adversary can inspect the state of a network connection with tools, such as Netstat, in

ICS Cybersecurity

Evaluation (401 Virtual) Training

conjunction with System Firmware, then they can determine the role of certain devices on the network. The adversary can also use Network Sniffing to watch network traffic for details about the source, destination, protocol, and content.

Network Sniffing – Network sniffing is the practice of using a network interface on a computer system to monitor or capture information regardless of whether it is the specified destination for the information.

Remote System Discovery – Adversaries may attempt to get a listing of other systems by IP address, hostname, or other logical identifier on a network that may be used for subsequent Lateral Movement or Discovery techniques. Functionality could exist within adversary tools to enable this, but utilities available on the operating system or vendor software could also be used.

Remote System Information Discovery – An adversary may attempt to get detailed information about remote systems and their peripherals, such as make / model, role, and configuration. Adversaries may use information from Remote System Information Discovery to aid in targeting and shaping follow-on behaviors.

Wireless Sniffing – Adversaries may perform wireless compromise as a method of gaining communications and unauthorized access to a wireless network. Access to a wireless network may be gained through the compromise of a wireless device. Adversaries may also utilize radios and other wireless communication devices on the same frequency as the wireless network.

Lateral Movement

Lateral Movement	▪ Default Credentials ▪ Exploitation of Remote Services ▪ Lateral Tool Transfer ▪ Program Download ▪ Remote Services ▪ Valid Accounts	Default Credentials – Adversaries may leverage manufacturer or supplier default credentials on control system devices. These default credentials may have administrative permissions and may be necessary for initial configuration of the device.
-------------------------	---	---

Exploitation of Remote Services – Adversaries may exploit a software vulnerability to take advantage of a programming error in a program, service, or within the operating system software or kernel itself to enable remote service abuse. A common goal for post-compromise exploitation of remote services is for initial access into and lateral movement throughout the ICS environment to enable access to targeted systems.

Lateral Tool Transfer – Adversaries may transfer tools or other files from one system to another to stage adversary tools or other files over the course of an operation. Copying of files may also be performed laterally between internal victim systems to support Lateral Movement with remote Execution using inherent file sharing protocols such as file sharing over SMB to connected network shares.

Program Download – Adversaries may perform a program download to transfer a user program to a controller. Variations of program download, such as online edit and program append, allow a controller to continue running during the transfer and reconfiguration process without interruption to process control.

Remote Services – Adversaries may leverage remote services to move between assets and network segments. These services are often used to allow operators to interact with systems remotely within the network, some examples are RDP, SMB, SSH, and other similar mechanisms. Remote services could be used to support remote access, data transmission, authentication, name resolution, and other remote functions.

Valid Accounts – Adversaries may steal the credentials of a specific user or service account using credential access techniques. In some cases, default credentials for control system devices may be publicly available.

ICS Cybersecurity

Evaluation (401 Virtual) Training

Collection



Automated Collection – Adversaries may automate collection of industrial environment information using tools or scripts. This automated collection may leverage native control protocols and tools available in the control systems environment.

Data from Information Repositories – Adversaries may target and collect data from information repositories. This can include sensitive data such as

specifications, schematics, or diagrams of control system layouts, devices, and processes.

Detect Operating Mode – Adversaries may gather information about a PLC or controller's current operating mode. Operating modes dictate what change or maintenance functions can be manipulated and are often controlled by a key switch on the PLC (e.g., run, prog [program], and remote).

I/O Image – Adversaries may seek to capture process values related to the inputs and outputs of a PLC. During the scan cycle, a PLC reads the status of all inputs and stores them in an image table. The image table is the PLC's internal storage location where values of inputs / outputs for one scan are stored while it executes the user program.

Machine-in-the-Middle – Adversaries with privileged network access may seek to modify network traffic in real-time using machine-in-the-middle (MiTM) attacks. This type of attack allows the adversary to intercept traffic to and/or from a particular device on the network.

Monitor Process State – Adversaries may gather information about the physical process state. This information may be used to gain more information about the process itself or used as a trigger for malicious actions.

Point & Tag Identification – Adversaries may collect point and tag values to gain a more comprehensive understanding of the process environment. Points may be values such as inputs, memory locations, outputs, or other process specific variables. Tags are the identifiers given to points for operator convenience.

Program Upload – Adversaries may attempt to upload a program from a PLC to gather information about an industrial process. Uploading a program may allow them to acquire and study the underlying logic.

Screen Capture – Adversaries may attempt to perform screen capture of devices in the control system environment. Screenshots may be taken of workstations, HMIs, or other devices that display environment-relevant process, device, reporting, alarm, or related data. These device displays may reveal information regarding the ICS process, layout, control, and related schematics.

Wireless Sniffing – Adversaries may seek to capture radio frequency (RF) communication used for remote control and reporting in distributed environments. RF communication frequencies vary between 3 kHz to 300 GHz, although are commonly between 300 MHz to 6 GHz. The wavelength and frequency of the signal affect how the signal propagates through open air, obstacles (e.g. walls and trees) and the type of radio required to capture them.

Command and Control



Commonly Used Port – Adversaries may communicate over a commonly used port to bypass firewalls or network detection systems and to blend in with normal network activity,

ICS Cybersecurity

Evaluation (401 Virtual) Training

to avoid more detailed inspection. They may use the protocol associated with the port, or a completely different protocol.

Connection Proxy – Adversaries may use a connection proxy to direct network traffic between systems or act as an intermediary for network communications. The definition of a proxy can also be expanded to encompass trust relationships between networks in peer-to-peer, mesh, or trusted connections between networks consisting of hosts or systems that regularly communicate with each other.

Standard Application Layer Protocol – Adversaries may establish command and control capabilities over commonly used application layer protocols such as HTTP(S), OPC, RDP, Telnet, DNP3, and Modbus. These protocols may be used to disguise adversary actions as benign network traffic.

Inhibit Response Function

Inhibit
Response
Function

- Activate Firmware Update Mode
- Alarm Suppression
- Block Command Message
- Block Reporting Message
- Block Serial Communication
- Data Destruction
- Denial of Service
- Device Restart / Shutdown
- Manipulate I/O Image
- Modify Alarm Settings
- Rootkit
- Service Stop
- System Firmware

Activate Firmware Update Mode –

Adversaries may activate firmware update mode on devices to prevent expected response functions from engaging in reaction to an emergency or process malfunction.

Alarm Suppression – Adversaries may target protection function alarms to prevent them from notifying operators of critical conditions. Alarm messages may be a part of an overall reporting system and of particular interest to adversaries.

Block Command Message – Adversaries may block a command message from reaching its intended target to prevent command execution. In OT networks, command messages are sent to provide instructions to control system devices. A blocked command message can inhibit response functions from correcting a disruption or unsafe condition.

Block Reporting Message – Adversaries may block or prevent a reporting message from reaching its intended target. In control systems, reporting messages contain telemetry data (e.g., I/O values) pertaining to the current state of equipment and the industrial process. By blocking these reporting messages, an adversary can hide their actions from an operator.

Block Serial Communication – Adversaries may block access to serial communication ports (COM) to prevent instructions or configurations from reaching target devices. Serial COM allow communication with control system devices.

Data Destruction – Adversaries may perform data destruction over the course of an operation. The adversary may drop or create malware, tools, or other non-native files on a target system to accomplish this, potentially leaving behind traces of malicious activities.

Denial-of-Service – Adversaries may perform Denial-of-Service (DoS) attacks to disrupt expected device functionality. Examples of DoS attacks include overwhelming the target device with a high volume of requests in a short period and sending the target device a request it does not know how to handle.

Device Restart / Shutdown – Adversaries may forcibly restart or shutdown a device in an ICS environment to disrupt and negatively impact physical processes. Methods of device restart and shutdown exist in some devices as built-in, standard functionalities.

ICS Cybersecurity

Evaluation (401 Virtual) Training

Manipulate I/O Image – Adversaries may manipulate the I/O image of PLCs through various means to prevent them from functioning as expected. Methods of I/O image manipulation may include overriding the I/O table via direct memory manipulation or using the override function used for testing PLC programs.

Modify Alarm Settings – Adversaries may modify alarm settings to prevent alerts that may inform operators of their presence or to prevent responses to dangerous and unintended scenarios.

Rootkit – Adversaries may deploy rootkits to hide the presence of programs, files, network connections, services, drivers, and other system components. Rootkits are programs that hide the existence of malware by intercepting and modifying operating system API calls that supply system information.

Service Stop – Adversaries may stop or disable services on a system to render those services unavailable to legitimate users. Stopping critical services can inhibit or stop response to an incident or aid in the adversary's overall objectives to cause damage to the environment.

System Firmware – System firmware on modern assets is often designed with an update feature. Older device firmware may be factory installed and require special reprogramming equipment. When available, the firmware update feature enables vendors to remotely patch bugs and perform upgrades.

Impair Process Control

Impair Process Control

- Brute Force I/O
- Modify Parameter
- Module Firmware
- Spoof Reporting Message
- Unauthorized Command Message

Brute Force I/O – Adversaries may repetitively or successively change I/O point values to perform an action. Brute Force I/O may be achieved by changing either a range of I/O point values or a single point value

repeatedly to manipulate a process function.

Modify Parameter – Adversaries may modify parameters used to instruct industrial control system devices. These devices operate via programs that dictate how and when to perform actions based on such parameters.

Module Firmware – Adversaries may install malicious or vulnerable firmware onto modular hardware devices. Control system devices often contain modular hardware devices. These devices may have their own set of firmware separate from the firmware of the main control system equipment.

Spoof Reporting Message – Adversaries may spoof reporting messages in control system environments for evasion and to impair process control. In control systems, reporting messages contain telemetry data (e.g., I/O values) pertaining to the current state of equipment and the industrial process.

Unauthorized Command Message – Adversaries may send unauthorized command messages to instruct control system assets to perform actions outside their intended functionality, or without the logical preconditions to trigger their expected function.

ICS Cybersecurity Evaluation (401 Virtual) Training

Impact

Impact

- Damage to Property
- Denial of Control
- Denial of View
- Loss of Availability
- Loss of Control
- Loss of Productivity and Revenue
- Loss of Protection
- Loss of Safety
- Loss of View
- Manipulation of Control
- Manipulation of View
- Theft of Operational Information

Damage to Property – Adversaries may cause damage and destruction of property to infrastructure, equipment, and the surrounding environment when attacking control systems. This technique may result in device and operational equipment breakdown, or represent tangential damage from other techniques used in an attack.

Denial-of-Control – Adversaries may cause a denial-of-control to temporarily prevent

operators and engineers from interacting with process controls. An adversary may attempt to deny process control access to cause a temporary loss of communication with the control device or to prevent operator adjustment of process controls.

Denial-of-View – Adversaries may cause a denial-of-view in an attempt to disrupt and prevent operator oversight on the status of an ICS environment. This may manifest itself as a temporary communication failure between a device and its control source, where the interface recovers and becomes available once the interference ceases.

Loss of Availability – Adversaries may attempt to disrupt essential components or systems to prevent owners / operators from delivering products or services. Adversaries may leverage malware to delete or encrypt critical data on HMIs, workstations, or databases.

Loss of Control – Adversaries may seek to achieve a sustained loss of control or a runaway condition in which operators cannot issue any commands even if the malicious interference has subsided.

Loss of Productivity and Revenue – Adversaries may cause loss of productivity and revenue through disruption and even damage to the availability and integrity of control system operations, devices, and related processes. This technique may manifest as a direct effect of an ICS-targeting attack or tangentially, due to an IT-targeting attack against non-segregated environments.

Loss of Protection – Adversaries may compromise protective system functions designed to prevent the effects of faults and abnormal conditions. This can result in equipment damage, prolonged process disruptions and hazards to personnel. Many faults and abnormal conditions in process control happen too quickly for a human operator to react to.

Loss of Safety – Adversaries may compromise safety system functions designed to maintain safe operation of a process when unacceptable or dangerous conditions occur. Safety systems are often composed of the same elements as control systems but have the sole purpose of ensuring the process fails in a predetermined safe manner.

Loss of View – Adversaries may cause a sustained or permanent loss of view where the ICS equipment will require local, hands-on operator intervention; for instance, a restart or manual operation. By causing a sustained reporting or visibility loss, the adversary can effectively hide the present state of operations. This loss of view can occur without affecting the physical processes themselves.

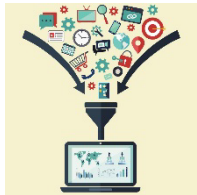
Manipulation of Control – Adversaries may manipulate physical process control within the industrial environment. Methods of manipulating control can include changes to set point values, tags, or other parameters. Adversaries may manipulate control systems devices or leverage their own, to communicate with and command physical control processes.

ICS Cybersecurity Evaluation (401 Virtual) Training

Manipulation of View – Adversaries may attempt to manipulate the information reported back to operators or controllers. This manipulation may be short term or sustained. During this time the process itself could be in a much different state than what is reported. Operators may be fooled into doing something harmful to the system in a loss of view situation.

Theft of Operational Information – Adversaries may steal operational information on a production environment as a direct mission outcome for personal gain or to inform future operations. This information may include design documents, schedules, rotational data, or similar artifacts that provide insight on operations.

Additional Resources



MITRE ATT&CK® Knowledge Base

Pre-Att&ck Matrix – <https://attack.mitre.org/matrices/enterprise/pre/>

Enterprise Matrix – <https://attack.mitre.org/>

Industrial Control System Matrix – <https://attack.mitre.org/matrices/ics/>

Common Issues

- ✓ No general cybersecurity awareness training – staff are not receiving cybersecurity awareness training
- ✓ Multi-use systems – Particular host is used to perform multiple tasks that increase risk because of the multiple resources they access
- ✓ Systems diagrams and documentation is missing / incomplete

Cybersecurity Performance Goals (CPGs)

These are several of the cybersecurity performance goals associated with adversarial risk. You will complete an evaluation using CSET® at the conclusion of this training.

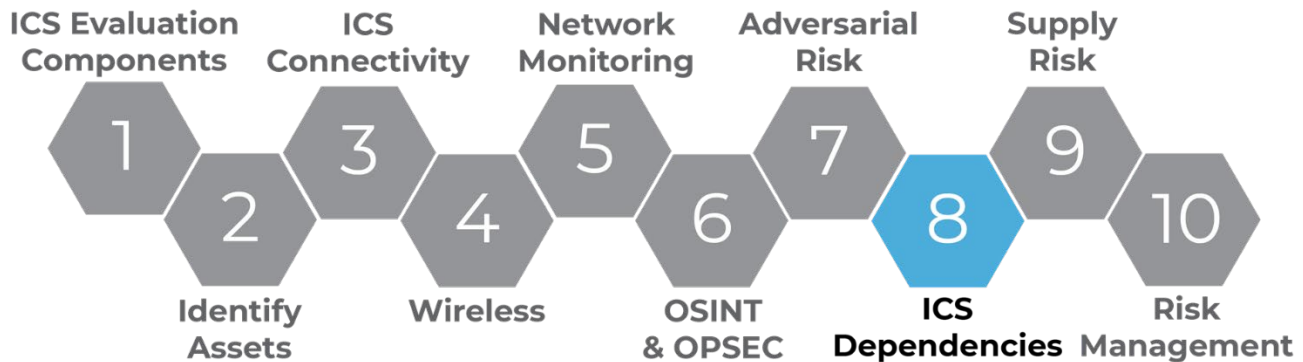
2.1-	BASIC CYBERSECURITY TRAINING		PR.AT-1	Low Cost HIGH IMPACT LOW COMPLEXITY
	OUTCOME		RECOMMENDED ACTION	
	Organizational users learn and perform more secure behaviors.		At least annual trainings for all organizational employees and contractors that cover basic security concepts, such as phishing, business email compromise, basic operational security, password security, etc., as well as foster an internal culture of security and cyber awareness.	
	TTP or RISK ADDRESSED	SCOPE		
	User Training (M1017, ICS M0917)	All employees and contractors	New employees receive initial cybersecurity training within 10 days of onboarding and recurring training on at least an annual basis.	
3.A-	DETECTING RELEVANT THREATS AND TTPs		ID.RA-2, ID.RA-3, DE.CM-1	MEDIUM-HIGH COST MEDIUM IMPACT HIGH COMPLEXITY
	OUTCOME		RECOMMENDED ACTION	
	Organizations are aware of and able to detect relevant threats and TTPs.		Organizations document a list of threats and cyber actor TTPs relevant to their organization (e.g., based on industry, sectors), and maintain the ability (such as via rules, alerting, or commercial prevention and detection systems) to detect instances of those key threats.	
	TTP or RISK ADDRESSED	SCOPE		
	Without the knowledge of relevant threats and ability to detect them, organizations risk that threat actors may exist undetected in their networks for long periods.	N/A		

ICS Cybersecurity Evaluation (401 Virtual) Training

ICS Cybersecurity Evaluation (401 Virtual) Training

LO8. Determine ICS Dependencies

In this objective we will delve into infrastructure dependencies, both internal and external to ICS systems. This brings us to determining ICS dependencies.



Infrastructure and Dependencies

Infrastructure: Engineered systems and facilities that enable and enhance a community's ability to meet societal demands by facilitating the production, transport (transmission), and consumption of goods and services.

Dependency: A relationship between two infrastructures through which the state of the providing infrastructure influences the other.



Critical Infrastructure Sectors and Lifeline Sectors

Of the 16, four are essential to the operation of the other critical infrastructure sectors. These are called "Lifeline" sectors:

- Water / Wastewater Systems
- Energy
- Communications
- Transportation

Every critical infrastructure sector relies on one or more of the lifeline sectors (Water, Energy, Communications, and Transportation) to maintain functionality. But this reliance upon those sectors is

also true of each of the lifeline sectors themselves. For example, the Energy and Communications sectors have a foundational role in the operations of other sectors' systems. But both Energy and

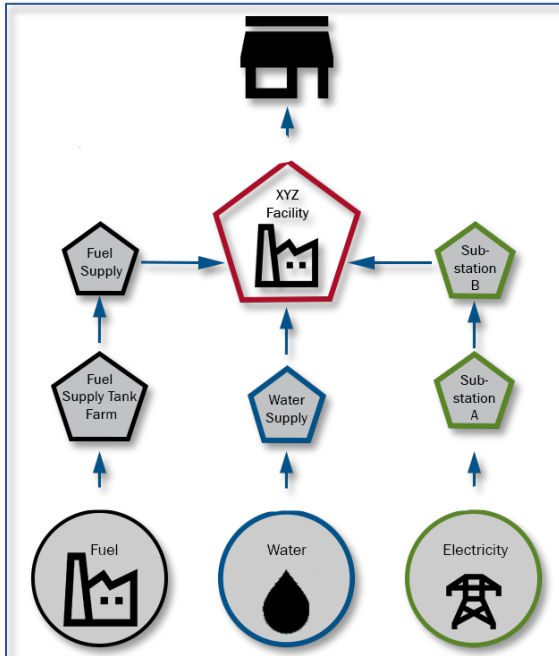
ICS
Dependencies

8

ICS Cybersecurity Evaluation (401 Virtual) Training

Communications services are also reliant on each other to maintain that baseline functionality – in the case of the Energy Sector, Industrial Control System and vulnerability management is dependent on reliable network service; for the Communications Sector, electricity underpins the ability for those and other network capabilities. In addition, the Energy Sector is reliant upon both the Water and Transportation sectors, for cooling and the transit of precursor materials, respectively.

Dependency and Dependency Types



Example of dependency flow from source to distributor to consumer.

What is your company dependent on from the outside?

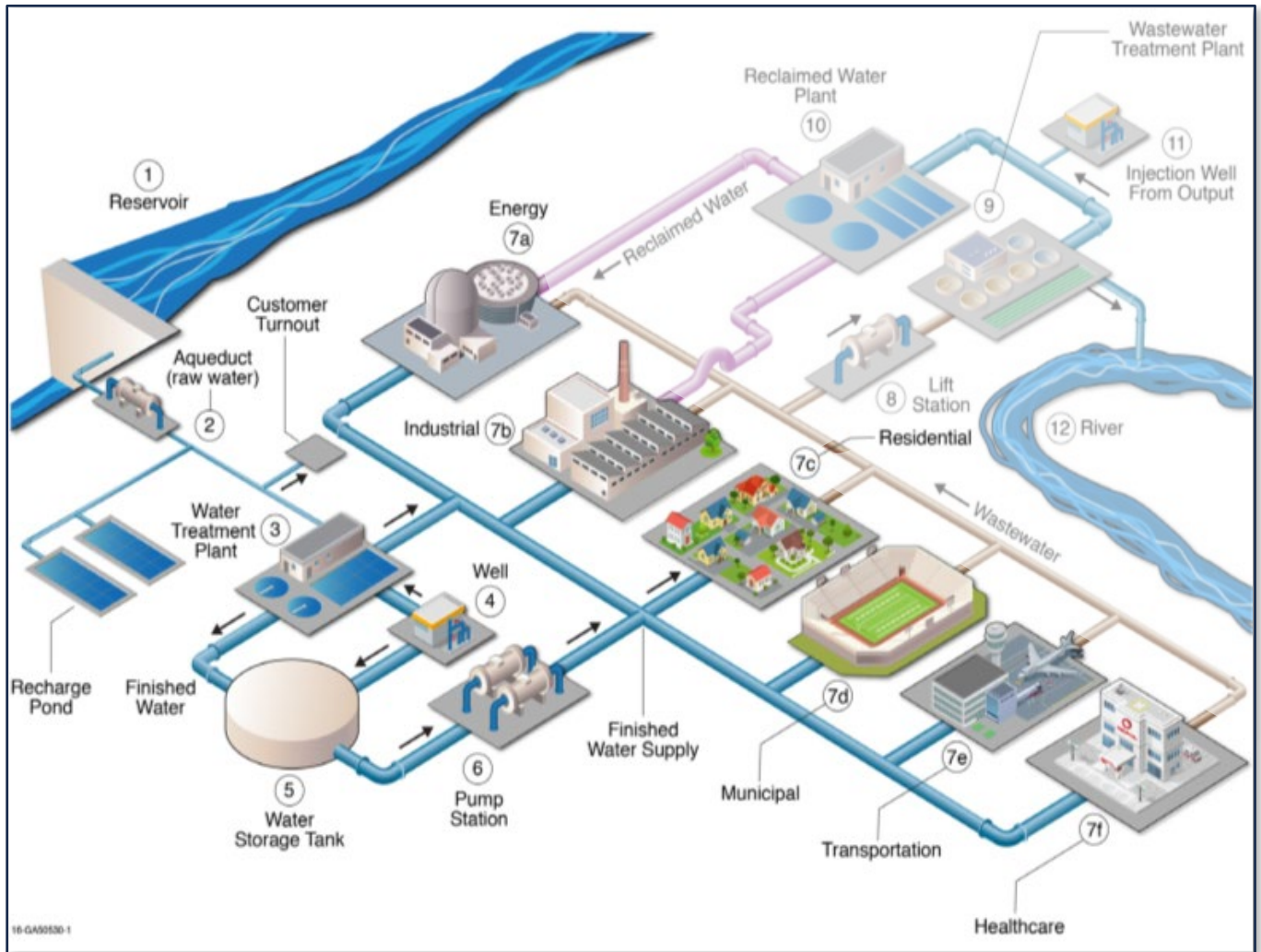
Cross-Sector Dependency: A dependency between infrastructure from different sectors (e.g., water and energy).

Interdependency: The products or services provided to one infrastructure by another external infrastructure that are necessary to support its operations and functions.

Intradependency: The interactions among internal operations, functions, and missions of the infrastructure. Internal dependencies are the internal links among the assets constituting a critical infrastructure (e.g., an electric generating plant that depends on cooling water from its own onsite water well).

ICS Cybersecurity Evaluation (401 Virtual) Training

Connected Networks: Connectivity Links



Interdependencies

Looking at the example image above, find where the flow of water starts and map it to the various destinations. At what points does the water move from one infrastructure to another?

Intradependency

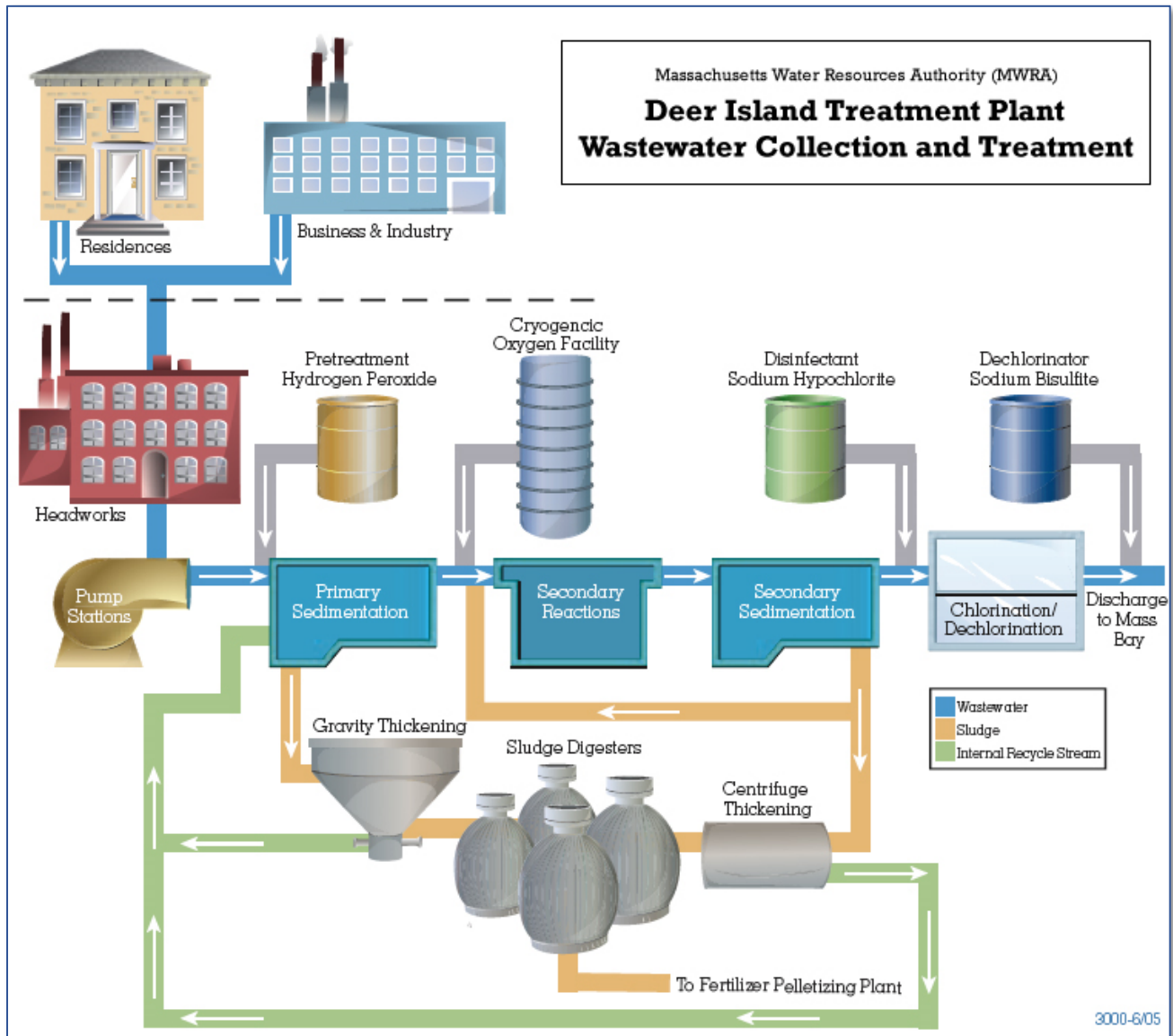
Looking at the example image again, identify the potential internal links within an infrastructure. Which ones do you notice?

ICS
Dependencies



ICS Cybersecurity Evaluation (401 Virtual) Training

Deer Island Treatment Plant Wastewater Collection and Treatment



Where Does All the Sewage Come From?

From people using water in kitchens and bathrooms in their homes and from commercial and industrial use. Nearly half the state's population, over 2 million people in 43 communities, send sewage to MWRA's treatment plants on the shores of Boston Harbor. Over 5,500 businesses and industries contribute wastewater as well. In addition, nearly half of the total flow in MWRA sewers is from rainy-weather street runoff and from below-ground cracks and faulty connections that allow groundwater into the system.

ICS
Dependencies

8

ICS Cybersecurity Evaluation (401 Virtual) Training

How Does Sewage Get to the Treatment Plants?

Sewage travels through three different sets of pipes. Water used in a home or industry is flushed through a building's pipes until it reaches local sewers owned and operated by city and town sewer departments. These 5,100 miles of local sewers transport the wastewater into 227 miles of MWRA interceptor sewers. The interceptor sewers, ranging from 8 inches to 11 feet in diameter, carry the region's wastewater to two MWRA treatment plants. Though most of the wastewater flows by gravity some low-lying areas require pumping.

How Does Sewage Treatment Work?

MWRA provides preliminary primary and secondary treatment to its wastewater flows at the [Deer Island Treatment Plant](#). The first phase of secondary treatment began operating in July 1997. The treatment process is as follows:

➤ Collection and Pumping

Sewage is piped from communities to several headworks where bricks, logs and other large objects are screened out. Pumps draw the sewage through deep-rock tunnels under the harbor to Deer Island.

➤ Preliminary Treatment

Mud and sand settle in a tank called a grit chamber. Later, this material, known as grit and screenings, is taken to a landfill for environmentally safe disposal.

➤ Primary Treatment

The sewage then flows to primary settling tanks where up to 60% of the solids in the waste stream settle out as a mixture of sludge and water. This primary treatment removes very few toxic chemicals.

➤ Secondary Treatment

In the secondary treatment plant oxygen is added to the wastewater to speed up the growth of micro-organisms. These microbes then consume the waste and settle to the bottom of the secondary settling tanks. After secondary treatment, 80-90% of human waste and other solids have been removed. A significant proportion of toxic chemicals are also removed by this process.

Where Does all the Treated Wastewater and Sludge Go?

The remaining wastewater is disinfected before it is discharged to the receiving waters (Massachusetts Bay). This stream of treated wastewater, known as effluent, travels through a 9.5-mile [Outfall Tunnel](#) bored through solid rock more than 250 feet below the ocean floor. The tunnel's final 1¼ mile include 55 separate release points known as "diffusers." By extending to an area with water depths up to 120 feet, this outfall provides a much higher rate of mixing and/or dilution than is possible with present discharges into the shallow waters of Boston Harbor.

Sludge from primary and secondary treatment is processed further in sludge digesters, where it is mixed and heated to reduce its volume and kill disease-causing bacteria. It is then transported through the Inter-Island Tunnel to the [pelletizing plant](#) in Quincy, where it is dewatered, heat-dried and converted to a pellet [fertilizer](#) for use in agriculture, forestry and land reclamation.

ICS
Dependencies



ICS Cybersecurity Evaluation (401 Virtual) Training

Define Business Process Functions

- How do you define Business Process Functions?
 - Functions that are directly part of the ICS Network.
 - Will depend on your site.
 - Parts of the site process that control in the ICS and monitor.
- Some examples Deer Island could have:
 - PLC
 - RTU
 - DCS computers
 - Network switches
 - Firewalls
 - Network traffic flow

Define Auxiliary Functions: What Other Factors Are Around the Process?

- How do you define Auxiliary Functions?
 - Functions that are not directly part of the ICS network.
 - Depends on your site.
 - May include items attached to the Business Process Function but on separate networks.
- Some examples Deer Island could have.
 - Map out what they have.
 - Talk to Site Security Specialist.
 - Talk to Site engineers.

Understand Criticality and Risk

Criticality: The quality, state, or degree of being of the highest importance

Risk: A situation involving exposure to danger

- Focus on Risk and Criticality inside your Asset (Functions).
- Evaluate the Risk and Criticality on both an Interdependency and Intradependency level. The main purpose is to focus on anything that falls into a high category, depending on your site.

ICS Cybersecurity Evaluation (401 Virtual) Training

LITTLE BOBBY



by Robert M. Lee and Jeff Haas



Interdependencies Exercise

Complete the Interdependencies exercise found on the CISA VLP.

Common Issues

- Network – Connections to systems
- Physical Access – Enforcement
- Configuration – Change Management
- Network – Wireless and Radio

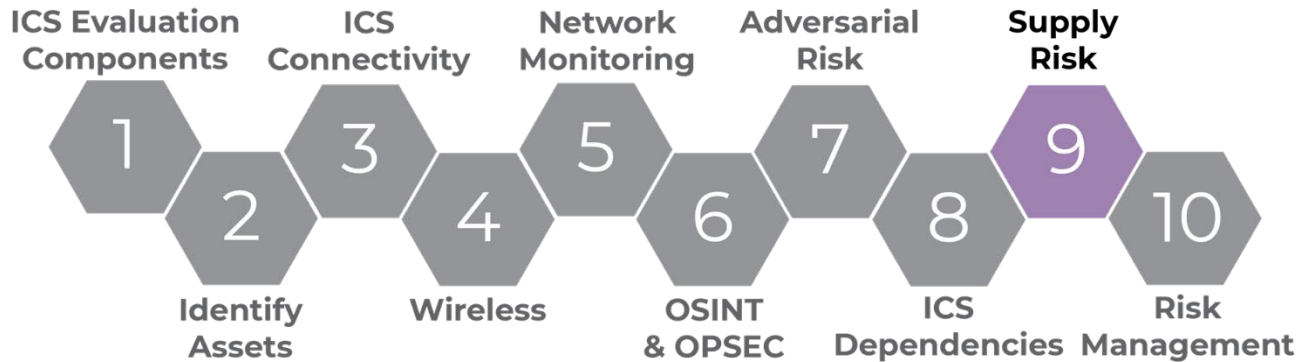
ICS
Dependencies

8

ICS Cybersecurity Evaluation (401 Virtual) Training

LO9. Analyze Supply Chain Risk

Continuing on with assessing risk to the business, this section will assess risk to supply chain.

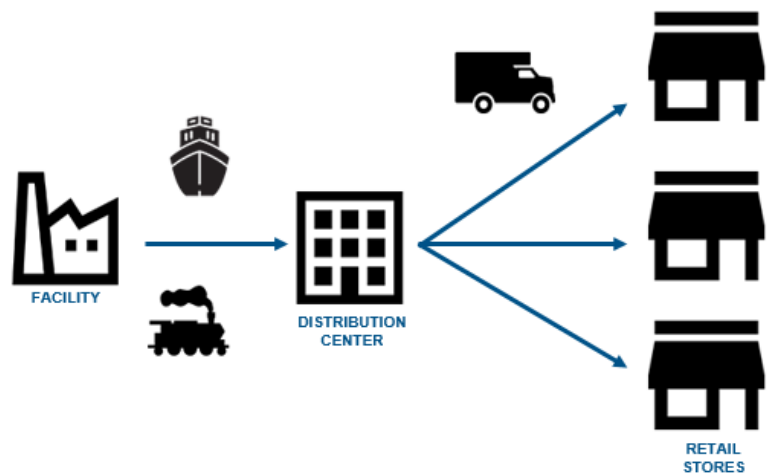


Why Attack the Supply Chain?

Why pay attention to supply chain risks? Attacks on a supply chain can compromise an organization's operations unnoticed. Supply chain attacks can be done without a vendor's knowledge, especially in today's environment because vendors do not make the physical equipment anymore – it is typically outsourced.

Types of Attacks:

- Shipment intercept
- Hardware or hardware manipulation
- Manufacturing
- Misconfiguration (intentional / unintentional)



Supply Risk

9

ICS Cybersecurity Evaluation (401 Virtual) Training

Vulnerabilities

There are multiple risks in supply chains. Listed here are some aspects of the supply chain.

- **Design** – Vulnerabilities introduced during Design are often unintentional and can affect all users of the components. Malicious actors could build vulnerabilities into components, which could then be installed in millions of pieces of equipment.
- **Development and Production** – Vulnerabilities introduced during this phase are often inadvertent and can be costly to fix if not identified during prototype testing. Well-designed products may still have malicious components introduced during manufacturing and assembly in a way that could be difficult to identify.
- **Distribution** – Components transported between production facilities and customers often do not fall under the purview of the personnel responsible for design or production. Vulnerabilities introduced during Distribution are likely to be malicious and affect a limited number of components and customers, as compared to earlier phases.
- **Acquisition and Deployment** – Malicious insiders may insert vulnerabilities or replace equipment with vulnerable components during acquisition or installation. Vulnerabilities introduced during this phase likely affect a limited number of customers.
- **Maintenance** – ICT components receiving Maintenance are susceptible to vulnerabilities introduced through physical or network access, and from exploitation of previously unknown or unpatched vulnerabilities. Vulnerabilities introduced during Maintenance might be targeted against specific entities but can affect many customers in the case of software updates.
- **Disposal** – ICT components that are improperly disposed of can contain sensitive company or customer data. Malicious actors can also attempt to refurbish components and try to resell them as new. Used parts may be less reliable and prone to failure, or have malware installed.

Supply Chain Considerations

Map your supply network:

- Identify your Tier 1 supplier
- Identify the upstream Tier 2, 3, 4 ... suppliers to the Tier 1

Potential questions:

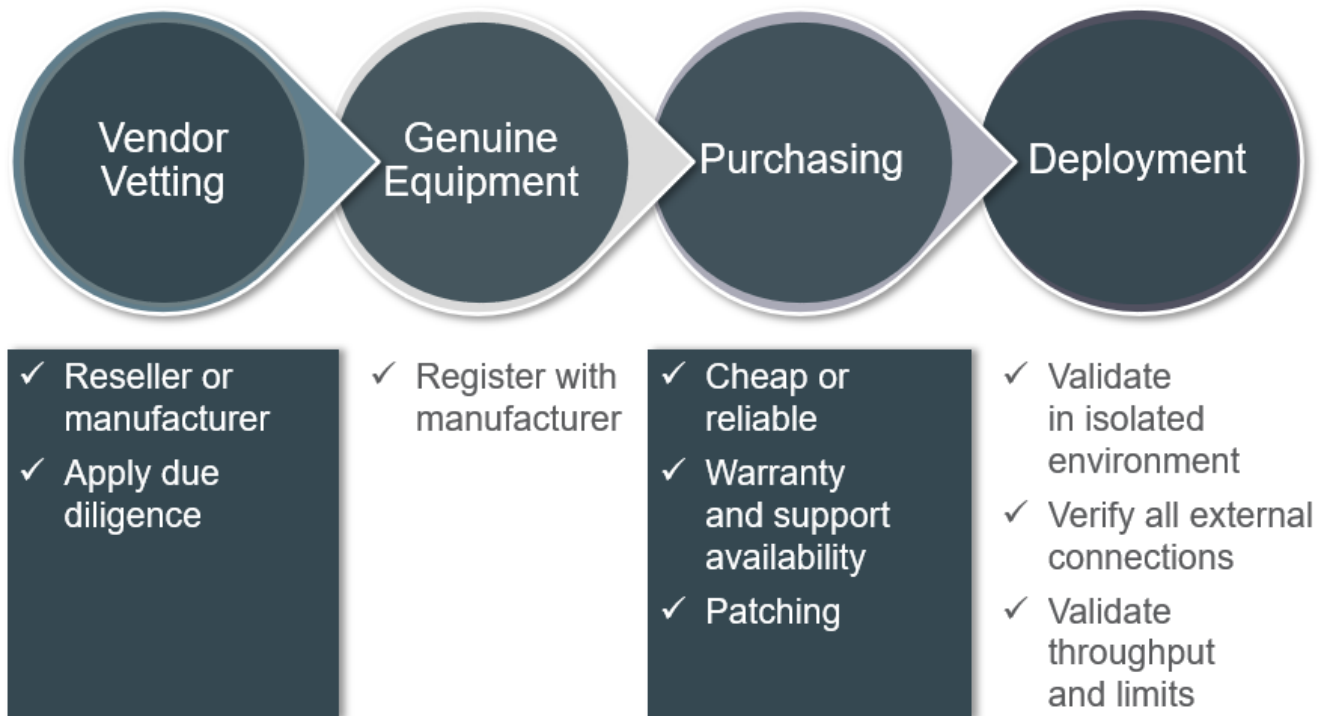
- What is the health of these companies?
- Have they had a cyber incident of which you are not aware?
- Does their location have potential for geographic, political, or weather-related risks?

Ensure you identify where your supplies are coming from. What are the upstream vendors?

Look into the risk of your supply chain. What is their history, normal business and cyber? How long have you used them? How hard is it to get the correct part you need consistently?



ICS Cybersecurity Evaluation (401 Virtual) Training



Use Cases

- In 2012, a third-party factory that produced switches designed by a U.S. company installed infected compact flash cards during production. The U.S. company warned that using an infected component could compromise the system and spread the malware within the network. Source: <https://www.esecurityplanet.com/malware/hp-warns-of-procurve-switches-with-malware-laden-flash-cards.html>
- In 2015, a U.S. citizen imported thousands of counterfeit integrated circuits from China and Hong Kong. He resold them to U.S. customers, including to Defense contractors supplying them to the U.S. Navy for use in nuclear submarines. Source: <https://medium.com/homeland-security/americas-military-breached-by-counterfeit-electronics-12dc207f257c>

Supply
Risk

9

ICS Cybersecurity Evaluation (401 Virtual) Training



Supply Chain Exercise

Find the resources for this activity on the CISA VLP.

Third-Party Access Considerations

Third-party access is an important aspect for ICS or OT systems. Third-party access is defined as a vendor or contractor that needs access to a local site or remote site ICS system. This access may be for maintenance, upgrades, administration, etc.

First, we need to look at considerations for access – that is, why does the contractor or vendor need access to the ICS network? Most of this revolves around who maintains the systems for your organization.

- So, we need to ask: Why is access needed?
 - First, we need to verify the purpose of third-party access.
 - Is it the vendor or a contractor working on the equipment?
- How does your company do a proper vetting of the contractor / vendor?
- Have you done a background check?
- What is the safety record of the contractor / vendor? It is important third parties are safe when they come onsite, and some sites require they have a good safety record. Make sure you know what is required before contractors / vendors are scheduled for access.



Training. Training when coming onsite is also important. What is needed for access? Contractors / vendors will need to understand your network layout and what they will have access to. Make sure you understand the Management of Change (MOC) process.

What in your **site network segmentation** is important for these third parties to understand? How do you protect other systems both logically and physically?

How will third parties be **monitored**? What do you have in place to keep an eye on their activities? Always insist on knowing precisely what they are working on and how changes could affect systems.

Onsite Access

It is also important to inform third parties of policies that affect access to the systems. Be very careful with any outside hardware that needs to be attached to your system. Be sure to properly vet outside hardware, and ensure it is secure (up-to-date audio / visual (AV), no dual-homing, up-to-date patching, and scanned before attaching to the network or device). Never connect an outside laptop to your network unless it is secured.

Supply
Risk



ICS Cybersecurity Evaluation (401 Virtual) Training

Only allow what is needed. Do not give full network or physical access to third parties if they do not need it. Only allow a limited user account for system access.

Third parties need to be overseen by ICS staff onsite. If they need to work during off hours, allowances can be made and signed for by management. This should all be well documented and allow for no changes without ICS management staff onsite. Third parties should be escorted onsite unless they are properly trained for a site emergency.

Remote Access

Third-party remote access did not used to be a big issue. Now we need to plan for remote access to everything. Remote access is a risk that should not be taken lightly. For a contractor / vendor to need remote access to an ICS system, there needs to be significant security in place.

The best practice is to avoid remote access whenever possible. When considering third-party remote access, start by asking why the third-party needs network access, and if there is a reasonable alternative. If remote access is required, always ensure there are strong security policies in place to protect your organization's interests, and that those policies are enforced.

Network access:

- What is needed to get the work done?
- How is access granted?
- Who is in control of the access?
- Authentication – multifactor?
- Jump box in the DMZ
- Hours allowed to access the system
- How are you going to monitor the connection (logging, IDS)?
- VPN / connection policy
 - Remote computer security policy verification
 - What does the connection have access to on the network (only necessary access)?

Third-Party Access Use Case - Trisis

What: An oil and gas plant in Saudi Arabia

Event: In late August 2017, Trisis malware infected ICS computers

Impact: Complete shutdown of the entire facility

Specifics: trilogy.exe program along with Library.zip were download to the affected computers. Can cause problems with an SIS system. Could have been spread by USB or email.

Lessons learned:

- SIS systems need to be isolated
- This could have been much worse, but the actor made a mistake in the code
- Could easily be installed at the vendor level before installation at the site
- Scan all computers



ICS Cybersecurity Evaluation (401 Virtual) Training



Self-Reflection Scenario

The ACME Company has an oil refinery in the United States. A vendor has installed some new equipment to load material from one refinery unit to another. They would like to set up remote support for this equipment to maintain and check problems while the equipment is in operation.

1. Who is responsible for handling this request?
2. What questions would you ask of the vendor before considering this request?
3. What mitigation would you put in place if remote access is required to have support from this vendor?

Supply
Risk



ICS Cybersecurity Evaluation (401 Virtual) Training

Common Issues

- ✓ System has multiple remote access options
- ✓ No process governing the implementation of remote access
- ✓ NAC/NAP
- ✓ Direct VPN Access to SCADA

Cybersecurity Performance Goals (CPGs)

This is one of the cybersecurity performance goals associated with supply chain and supply risk. You will complete an evaluation using CSET® at the conclusion of this training.

1.G	<table> <tr> <th colspan="2">SUPPLY CHAIN INCIDENT REPORTING</th><th>ID.SC-1, ID.SC-3</th></tr> <tr> <th colspan="2">OUTCOME</th><th>RECOMMENDED ACTION</th></tr> <tr> <td colspan="2">Organizations more rapidly learn about and respond to known incidents or breaches across vendors and service providers.</td><td rowspan="3">Procurement documents and contracts, such as service-level agreements (SLAs), stipulate that vendors and/or service providers notify the procuring customer of security incidents within a risk-informed time frame as determined by the organization.</td></tr> <tr> <th>TTP or RISK ADDRESSED</th><th>SCOPE</th></tr> <tr> <td>Supply Chain Compromise (T1195, ICS T0862)</td><td>Suppliers of IT and OT assets and services</td></tr> </table>	SUPPLY CHAIN INCIDENT REPORTING		ID.SC-1, ID.SC-3	OUTCOME		RECOMMENDED ACTION	Organizations more rapidly learn about and respond to known incidents or breaches across vendors and service providers.		Procurement documents and contracts, such as service-level agreements (SLAs), stipulate that vendors and/or service providers notify the procuring customer of security incidents within a risk-informed time frame as determined by the organization.	TTP or RISK ADDRESSED	SCOPE	Supply Chain Compromise (T1195, ICS T0862)	Suppliers of IT and OT assets and services	LOW COST HIGH IMPACT LOW COMPLEXITY
SUPPLY CHAIN INCIDENT REPORTING		ID.SC-1, ID.SC-3													
OUTCOME		RECOMMENDED ACTION													
Organizations more rapidly learn about and respond to known incidents or breaches across vendors and service providers.		Procurement documents and contracts, such as service-level agreements (SLAs), stipulate that vendors and/or service providers notify the procuring customer of security incidents within a risk-informed time frame as determined by the organization.													
TTP or RISK ADDRESSED	SCOPE														
Supply Chain Compromise (T1195, ICS T0862)	Suppliers of IT and OT assets and services														
1.H	<table> <tr> <th colspan="2">SUPPLY CHAIN VULNERABILITY DISCLOSURE</th><th>ID.SC-1, ID.SC-3</th></tr> <tr> <th colspan="2">OUTCOME</th><th>RECOMMENDED ACTION</th></tr> <tr> <td colspan="2">Organizations more rapidly learn about and respond to vulnerabilities in assets provided by vendors and service providers.</td><td rowspan="3">Procurement documents and contracts, such as SLAs, stipulate that vendors and/or service providers notify the procuring customer of confirmed security vulnerabilities in their assets within a risk-informed time frame as determined by the organization.</td></tr> <tr> <th>TTP or RISK ADDRESSED</th><th>SCOPE</th></tr> <tr> <td>Supply Chain Compromise (T1195, ICS T0862)</td><td>Suppliers of IT and OT assets and services</td></tr> </table>	SUPPLY CHAIN VULNERABILITY DISCLOSURE		ID.SC-1, ID.SC-3	OUTCOME		RECOMMENDED ACTION	Organizations more rapidly learn about and respond to vulnerabilities in assets provided by vendors and service providers.		Procurement documents and contracts, such as SLAs, stipulate that vendors and/or service providers notify the procuring customer of confirmed security vulnerabilities in their assets within a risk-informed time frame as determined by the organization.	TTP or RISK ADDRESSED	SCOPE	Supply Chain Compromise (T1195, ICS T0862)	Suppliers of IT and OT assets and services	LOW COST HIGH IMPACT LOW COMPLEXITY
SUPPLY CHAIN VULNERABILITY DISCLOSURE		ID.SC-1, ID.SC-3													
OUTCOME		RECOMMENDED ACTION													
Organizations more rapidly learn about and respond to vulnerabilities in assets provided by vendors and service providers.		Procurement documents and contracts, such as SLAs, stipulate that vendors and/or service providers notify the procuring customer of confirmed security vulnerabilities in their assets within a risk-informed time frame as determined by the organization.													
TTP or RISK ADDRESSED	SCOPE														
Supply Chain Compromise (T1195, ICS T0862)	Suppliers of IT and OT assets and services														
1.I	<table> <tr> <th colspan="2">VENDOR/SUPPLIER CYBERSECURITY REQUIREMENTS</th><th>ID.SC-3</th></tr> <tr> <th colspan="2">OUTCOME</th><th>RECOMMENDED ACTION</th></tr> <tr> <td colspan="2">Reduce risk by buying more secure products and services from more secure suppliers.</td><td rowspan="3">Organizations' procurement documents include cybersecurity requirements and questions, which are evaluated in vendor selection such that, given two offerings of roughly similar cost and function, the more secure offering and/or supplier is preferred.</td></tr> <tr> <th>TTP or RISK ADDRESSED</th><th>SCOPE</th></tr> <tr> <td>Supply Chain Compromise (T1195, ICS T0862)</td><td>Suppliers of IT and OT assets and services</td></tr> </table>	VENDOR/SUPPLIER CYBERSECURITY REQUIREMENTS		ID.SC-3	OUTCOME		RECOMMENDED ACTION	Reduce risk by buying more secure products and services from more secure suppliers.		Organizations' procurement documents include cybersecurity requirements and questions, which are evaluated in vendor selection such that, given two offerings of roughly similar cost and function, the more secure offering and/or supplier is preferred.	TTP or RISK ADDRESSED	SCOPE	Supply Chain Compromise (T1195, ICS T0862)	Suppliers of IT and OT assets and services	LOW COST HIGH IMPACT LOW COMPLEXITY
VENDOR/SUPPLIER CYBERSECURITY REQUIREMENTS		ID.SC-3													
OUTCOME		RECOMMENDED ACTION													
Reduce risk by buying more secure products and services from more secure suppliers.		Organizations' procurement documents include cybersecurity requirements and questions, which are evaluated in vendor selection such that, given two offerings of roughly similar cost and function, the more secure offering and/or supplier is preferred.													
TTP or RISK ADDRESSED	SCOPE														
Supply Chain Compromise (T1195, ICS T0862)	Suppliers of IT and OT assets and services														

Supply
Risk



ICS Cybersecurity Evaluation (401 Virtual) Training

2.C-

UNIQUE CREDENTIALS

PR.AC-1

OUTCOME

Attackers are unable to reuse compromised credentials to move laterally across the organization, particularly between IT and OT networks.

RECOMMENDED ACTION

Organizations provision unique and separate credentials for similar services and asset access on IT and OT networks. Users do not (or cannot) reuse passwords for accounts, applications, services, etc. Service accounts/machine accounts have passwords that are unique from all member user accounts.

TTP or RISK ADDRESSED

- Valid Accounts (T1078, ICS T0859)
- Brute Force - Password Guessing (T1110.001)

SCOPE

IT and OT assets

LOW COST
HIGH IMPACT
LOW COMPLEXITY

Supply
Risk

9

ICS Cybersecurity Evaluation (401 Virtual) Training

LO10. Provide Risk Management and Mitigation Methods



Our purpose here is to produce recommendations from the issues collected throughout the evaluation process. It is very important to understand that, as evaluators, we are not doing the work but recommending solutions that can/should be deployed.

Manage Risk

$$\text{Risk} = \text{Threats} \times \text{Vulnerabilities} \times \text{Consequences}$$

When wanting to reduce risk, you need to consider the variables that combine to create risk.

- Threats
- Vulnerabilities
- Consequences

Threats



A threat only exists if the right conditions are met. A threat must be **capable**, have an **opportunity**, and possess **hostile intent**. The level of each variable can vary depending on the other two.

For example, a person without great technical knowledge about a system can still cause significant harm if they are in an area with sensitive equipment. A slightly disgruntled person may think nothing of a flipped switch, but the widespread effect it could have can be exponential.

Threat Sources

Sources of a threat can vary from individuals on their home computer to large, organized crime groups, up to large nation states. The focus of these different categories of threat groups may vary.

Risk
Management



ICS Cybersecurity Evaluation (401 Virtual) Training

Trusted Sources with Malicious Intent

- Individuals or organizations with which the system owner shares some level of trust, but wishes to deliberately cause harm to the control system.
- Examples could include:
 - disgruntled systems administrator or user,
 - criminal elements within a partner organization such as a business peer, or
 - a subcontractor unhappy about the impending termination of their contract.

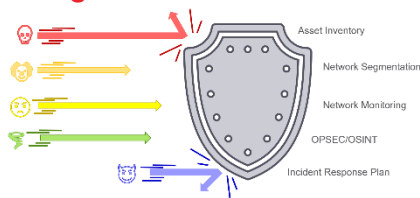
External Sources with Malicious Intent

- These sources are typically individuals or organizations with a desire to threaten the control system, but do not share an implicit trust relationship with the control system owner
- Examples could include:
 - Industrial spies
 - Hackers
 - Activist groups
 - Criminal elements
 - Foreign government agencies

Environmental Sources

- Such sources are usually disruptive natural events, or significant human-caused accidents such as an aircraft crash, or oil refinery explosion
- Examples could include:
 - fire
 - flood
 - storm

Strategies to Deter Threats



A proactive approach is a strong deterrent to threats.

Asset inventory, network segmentation, network monitoring, OPSEC/OSINT, an incident response plan – these measures can help solidify a system's defense and mitigate the influence of a threat within the system.

Vulnerabilities

Vulnerabilities are the various ways your resources and assets are exposed to an attack. Poor firewall rules, improper network segmentation, poor or non-existent policies directing vendor or company access are just a few vulnerabilities to keep in mind.

With all vulnerabilities, humans can be the greatest vulnerability or the greatest defense of a system. Training, awareness, and practice across all levels of a company can help avoid a simple phishing

**Risk
Management**



ICS Cybersecurity Evaluation (401 Virtual) Training

email click from toppling larger corporations such as Maersk and causing significant financial and physical harm.

Consequences

Consequences can be minor or major. Proper preparation can see a ransomware attack successfully walled off in an area where it cannot harm physical components. Alternatively, we can see results that lead to a loss of money and trust, and harm to physical components and personnel.

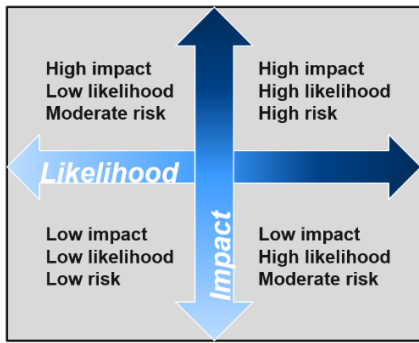
What are the risks within your company?

Consider your own company. Do you have proper physical security? Cybersecurity?

What are natural disasters that could occur in your region?

How resilient are your systems against a power outage?

Prioritize: Basic Risk Outlined

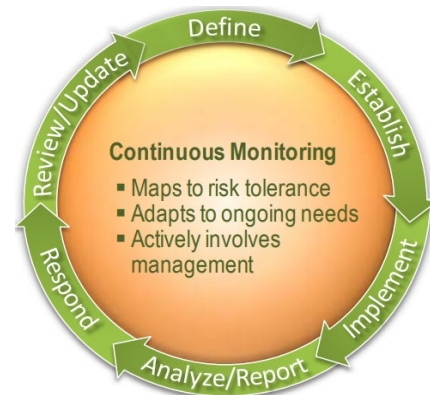


As you work to better protect your systems, it is important to prioritize where to focus first.

List your risks based on the likelihood and the impact they would have on your organization. This can give you a starting point to prioritizing your efforts.

Continuous Monitoring

- ✓ Defined system by understanding (Complete)
 - Assets and business impacts
 - Security / threat / vulnerability and risk
- ✓ Established metrics / evaluation frequency (Done)
 - Process for evaluation
 - Evaluation architecture
- ✓ Implement and Analyze - Report (Accomplished)
 - Collected data with initial analysis
 - Provided report outlining critical risk and mitigations



Management Respond

- ✓ Respond (to issues)
 - Handle Risk – What decision will be made for each risk?
 - Accept Risk
 - Avoid Risk
 - Share Risk

Risk
Management



ICS Cybersecurity Evaluation (401 Virtual) Training

- Transfer Risk
- Mitigate Risk
- ✓ Review / Update
 - Review evaluation processes
 - Establish change / configuration management process

Responding to 'Risk'

- ✓ Accept – within risk tolerance so (COA): 'Accept' the risk completely without action
- ✓ Avoid – exceeds risk tolerance (COA): 'Avoid' the risk completely by taking specific actions
- ✓ Share – shifts a portion of risk responsibility (liability) to other organizations
- ✓ Transfer – shifts the entire risk to another entity; generally, insurance companies
- ✓ Mitigate – 'risk reduction'
 - When a 'portion' of the risk cannot be accepted, avoided, shared, or transferred.
 - For example, deploying multifactor authentication mitigates risk against compromised passwords.

Recommend Points of Contact

Find the people in your organization to reach out to for potential issues. When an issue comes up, you want to know who to call instead of trying to figure out who to call.

Report Recommendations / Document Actions

Document your findings and recommendations. Evaluation tools such as CSET® can provide records to use to help track progress and stay on task.

ICS Cybersecurity Evaluation (401 Virtual) Training

Review / Update

- ✓ Establish a Change Management Process
 - Assign a Change Management Supervisory Role
 - Convene a Change Management Board with all appropriate stakeholders
 - Identify, Implement, and Monitor Changes



Request for Records

*If your completion certificate gets lost or misplaced,
you can obtain a copy from:*

Infrastructure Assurance & Analysis
nhs-training@inl.gov

Provide the following information in your request:

- *Completion date of training*
- *Course title*
- *Name (first and last) of the requestor*
- *Preferred method of delivery (email, mail).*
If mail, provide complete address information.

Risk
Management





CSET® Guide Introduction

The Cyber Security Evaluation Tool (CSET®) is a Department of Homeland Security (DHS) product that assists organizations in protecting their key national cyber assets. It was developed under the direction of the DHS National Cyber Security Division (NCSD) by cybersecurity experts, and with assistance from the National Institute of Standards and Technology (NIST). This tool provides users with a systematic and repeatable approach for assessing the security posture of their cyber systems and networks. It includes both high-level and detailed questions related to all industrial control and IT systems.

This training will provide trainees with the knowledge and skills needed to evaluate the security posture of their organization using CSET®.

Disclaimer

This presentation is intended for informational and discussion purposes only.

Training personnel do not discriminate on the basis of race, color, religion, national origin, sexual orientation, physical or mental disability, or gender expression/identity. Nor do they possess proprietary interest in any product, instrument, device, service or material discussed in this course.

Learning Objectives

Upon completion of this training, trainees will be able to:

1. Discuss the purpose and benefits of CSET®.
2. Describe the steps to conduct a CSET® assessment.

CSET[®]

CYBER SECURITY EVALUATION TOOL

1. Discuss the purpose and benefits of CSET[®]



The Cyber Security Evaluation Tool (CSET[®]) is a DHS product that assists organizations in protecting their key national cyber assets. The tool provides users with a systematic, disciplined, and repeatable approach for evaluating an organization's security posture. It does not require connection to the Internet or to any control system or corporate network. CSET[®] does not transmit information to DHS or any government or commercial entity, and does not report information to anyone except the person using the tool.

CSET[®] assists users in performing a self-assessment of their cybersecurity posture to establish a security baseline as a starting point for continuous improvement. It guides asset owners and operators through a step-by-step process to evaluate ICS and IT network security practices. When a user selects one or more of the standards, CSET[®] opens a set of questions to be answered. The answers to these questions are compared against a selected security assurance level, and a detailed report is generated showing areas for cybersecurity improvement.

DHS offers CSET[®] at no cost to end users.

It is available for download at: <https://cset-download.inl.gov/download>

CSET[®]

CYBER SECURITY EVALUATION TOOL

Your Organization's Cybersecurity Posture

Are you confident in the cybersecurity posture of your organization? Have you asked yourself where do you stand now? Where do you start? What are your priorities? CSET[®] can help you answer these questions.

The Department of Homeland Security is developing methods to assess the security posture of the control systems at critical infrastructure facilities, and CSET[®] is the cornerstone of building this capability. CSET[®] is a self-contained software tool that runs on a desktop or laptop computer. It does not transmit information to DHS or any government or commercial entity and does not report information to anyone except the person using the tool.

It provides a systematic, disciplined, and repeatable approach for evaluating an organization's security posture. CSET[®] guides asset owners and operators through a step-by-step process to evaluate ICS and IT network security practices. DHS developed the CSET[®] application and offers it at no cost to end users.



CSET[®]

CYBER SECURITY EVALUATION TOOL

CSET[®] Capabilities



What CSET[®] CAN do:

- Provide a consistent means of evaluating a control system network as part of a comprehensive cybersecurity assessment
- Specify cybersecurity recommendations
- Report using standards-based information analysis
- Provide a baseline cybersecurity standard



What CSET[®] CAN'T do:

- Validate accuracy of user inputs
- Ensure compliance with organizational or regulatory cybersecurity policies and procedures
- Ensure implementation of cybersecurity enhancements or mitigation techniques
- Identify all known cybersecurity vulnerabilities.

CSET[®] is designed to assist you in evaluating your control system network. It can provide solutions, recommendations, and best practices. It can also provide focused solution assistance. For example, as part of its solution library, CSET[®] contains firewall configuration whitepapers. A baseline of security posture provides for a comparison between assessments performed on a periodic basis.

CSET[®] cannot scan a network and provide a detailed topology analysis. Nor will it identify every cybersecurity vulnerability in the system. The tool is only as good as the responses you provide it. Furthermore, CSET[®] cannot actually implement controls or mitigate vulnerabilities, but it does help you establish a prioritized list to help focus your cybersecurity efforts.

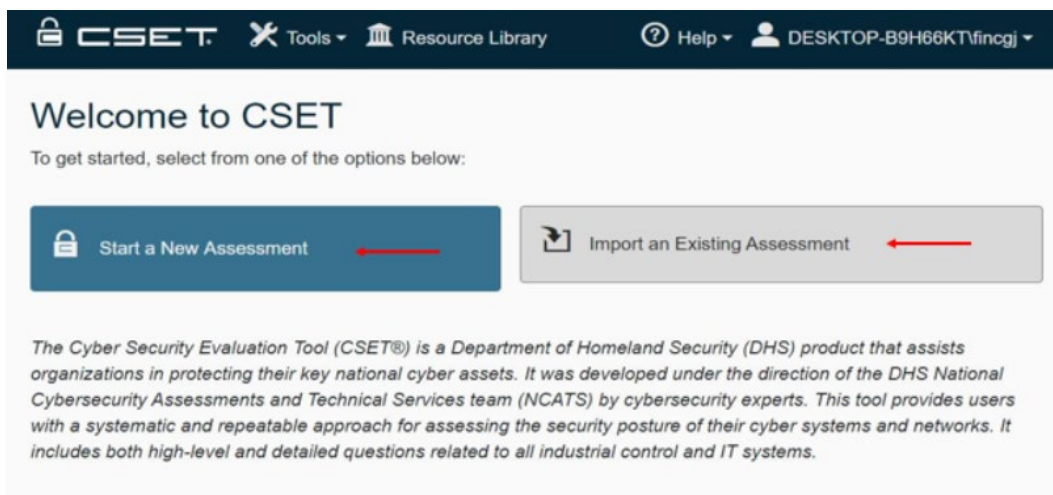
2. Describe the steps to conduct a CSET[®] evaluation.

ICS Evaluation Components

- Establish an ICS evaluation methodology
- Determine evaluation entry qualifiers
- Establish role(s)/team to perform evaluation
- Establish expected outcomes and products
- Final reporting mechanism

The above slide may look familiar, it was presented earlier this week. You have been using this information for performing an evaluation. This slide will be referred to throughout this presentation to show where CSET[®] can assist with the performance of an evaluation.

The above slide may look familiar; it was presented earlier this week. You have been using this information for performing an evaluation. This slide will be referred to throughout this presentation to show where CSET[®] can assist with the performance of an evaluation.

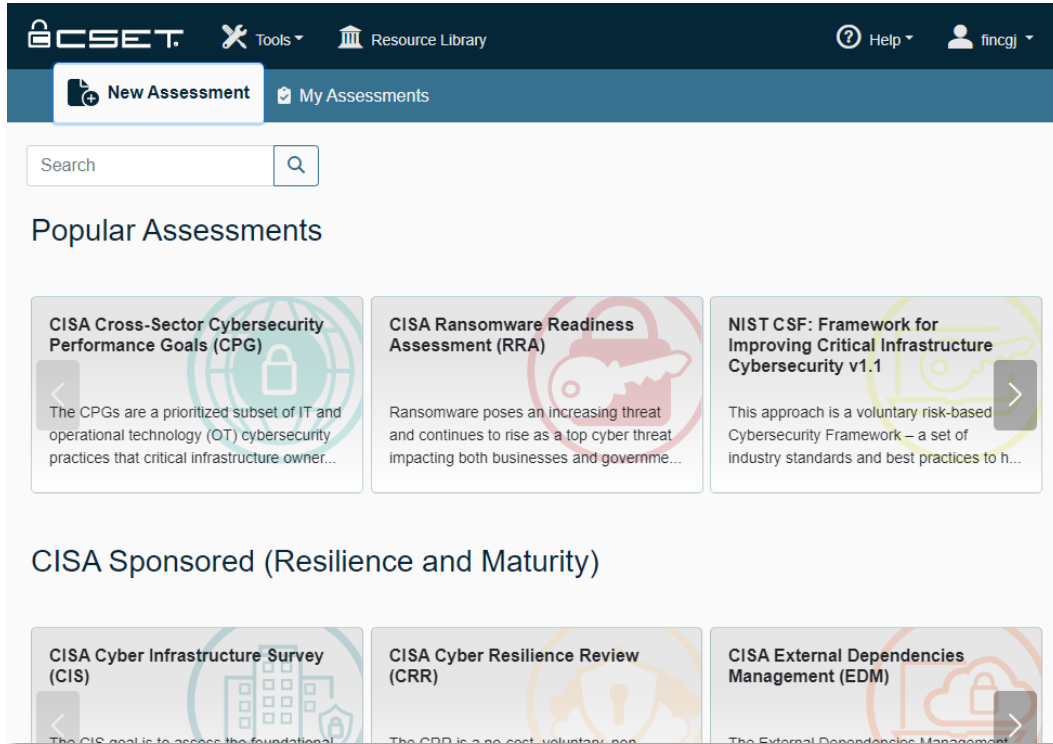


By selecting “My Assessments” you will navigate to this page. Here if you select “Start a New Assessment” you will move to the previous page, or you can select “Import an Existing Assessment” to import an assessment.

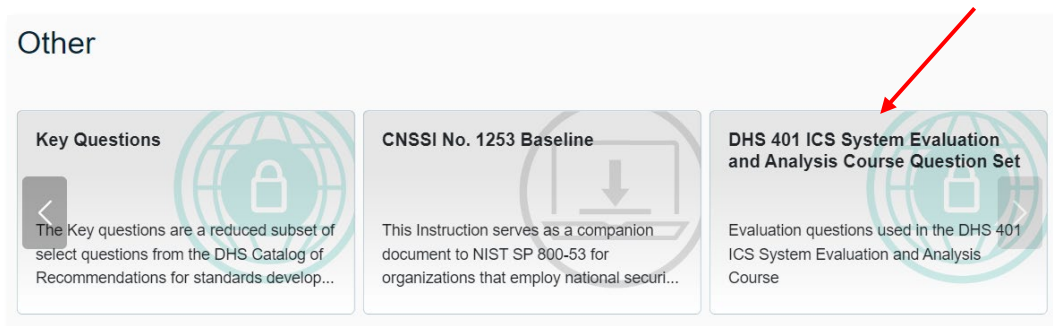
CSET®

CYBER SECURITY EVALUATION TOOL

Start the CSET® Assessment



This is the opening page the first time you start CSET®. From here you can start a new assessment based on specific standards or guidelines or select “My Assessments” to see existing assessments. For this presentation I have selected “My Assessments” to use an existing assessment.

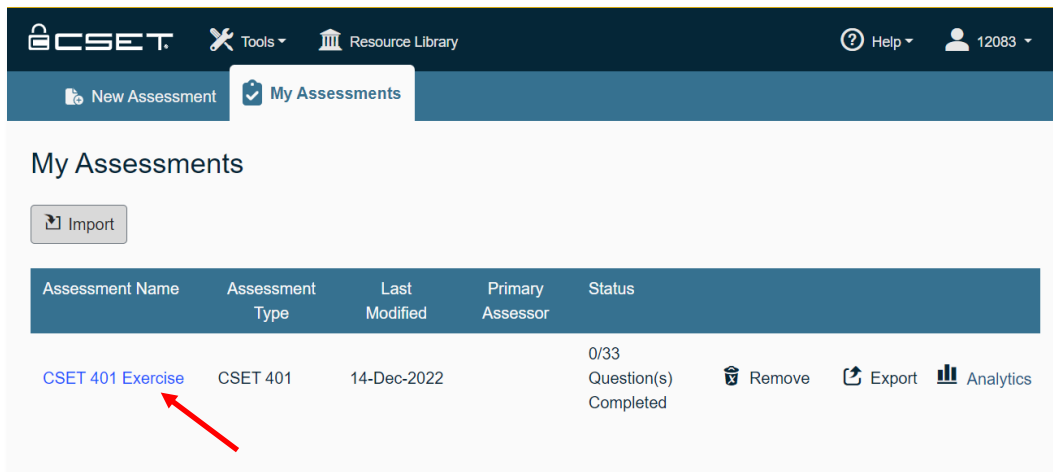


For the exercises you will select “DHS401 ICS System Evaluation and Analysis Course Question Set” under the assessment group “Other.”

ICS Evaluation Components

- Establish an ICS evaluation methodology
- Determine evaluation entry qualifiers
- Establish role(s)/team to perform evaluation
- Establish expected outcomes and products
- Final reporting mechanism

This is one component that does not map directly to part of the process in CSET[®]. The next step in CSET[®] is to detail the evaluation information about the organization.



Once you have started / created an assessment you can double-click the assessment name to enter the tool.

Navigation Approach

CSET[®] is designed to focus user time in the areas most effective for conducting an assessment. The high-level navigation is divided into three main areas:

The **Preparation** portion is necessary for each assessment but is accessed very little once the selection process and network diagramming activities are completed.

- Assessment Configuration
- Assessment Information
- Security Assurance Level (SAL)

The **Assessment** portion is where users spend most of the time answering assessment questions.

- Standard Questions

The **Results** portion has two sections: Analysis and Reports. The Analysis section can be used repeatedly to judge the completeness of the assessment.

- Standard Results
- High-Level Assessment Description, Executive Summary & Comments
- Reports
- Feedback



▼ Prepare

Assessment Configuration

Assessment Information

Security Assurance Level (SAL)

▼ Assessment

Standard Questions

▼ Results

➤ Standard Results

High-Level Assessment

Description Executive Summary &
Comments

Reports

Feedback

CSET®

CYBER SECURITY EVALUATION TOOL

Assessment Configuration

Organization Details

Assessment Name: CSET 401 Exercise

Assessment Date: 12/14/2022

Facility Name: CSAC

City Or Site Name: Idaho Falls

State/Province/Region: ID

Assessment Type

CSET 401

This set is used in 401 training for CSET

Begin the evaluation by filling out information about the assessment. This includes the assessment name and date, facility name, City or Site name, State / Province / Region, and Assessment type. This assessment has a specific 401 CSET® question set.

Demographics

Sector: Chemical Sector (Not Oil and Gas)

Industry: Specialty Products

What is the gross value of the asset you are trying to protect?: > \$10,000,000

What is the relative expected effort for this assessment?: Small (1-2 hour) assessment

Name of Organization: Acme Chemical Inc

Business Unit/Agency: Business Unit/Agency

CSET[®]

CYBER SECURITY EVALUATION TOOL

The screenshot shows the 'Organization Type' section of the CSET tool. A red rounded rectangle highlights the following elements:

- Organization Type** section header.
- Industry** dropdown menu with a red arrow pointing to it.
- Facilitator** dropdown menu with 'Jill Moshino' selected and a red arrow pointing to it.
- Critical Service** dropdown menu with 'Critical Service' selected and a red arrow pointing to it.
- Critical Service Point of Contact** dropdown menu with 'Eric Cartman' selected and a red arrow pointing to it.
- Back** button at the bottom left.
- Next** button at the bottom right, with a red arrow pointing to it from the left.

The Sector Demographics page is used to indicate which of the critical sectors this assessment pertains to. The gross value of the facility, length of the assessment, organization name and type, Facilitator and Point of Contact.

ICS Evaluation Components

- Establish an ICS evaluation methodology
- Determine evaluation entry qualifiers
- Establish role(s)/team to perform evaluation
- Establish expected outcomes and products
- Final reporting mechanism

Now we need to establish the evaluation team. CSET[®] allows you to capture the team members' information.

Evaluation Team – Required Interviews / Participants

CSET[®] assessments are most effective when completed by a cross-functional team. A cross-functional team consisting of representatives from operational, maintenance, information technology, business, and security areas is essential because no one individual typically has the span of responsibility or knowledge to effectively answer all the questions. The representatives must be subject matter experts (SMEs) with significant expertise in their respective areas.

Type of Participant	Knowledge
Control Systems Engineer	Control systems
Configuration Manager	Systems management
Operations Manager	Business operations
IT Network Specialist	IT infrastructure
IT Security Officer	Policies & procedures
Risk Analyst or Insurance Specialist	Risk
Human Resource Specialist	Work-related issues

A cross-functional team consisting of representatives from operational, maintenance, information technology, business, and security areas is essential because no one individual has the span of responsibility or knowledge to effectively answer all the questions. When the appropriate people are brought together, they are often able to recognize areas of weakness and improvement that can bring about significant changes to the organization.

CSET[®]

CYBER SECURITY EVALUATION TOOL

CSET[®]

Tools

Resource Library

Help

12083

Prepare

Assessment

Results

Home

Prepare

- Assessment Configuration
- Assessment Information
- Security Assurance Level (SAL)

Assessment

- Standard Questions

Results

- Standard Results
 - Analysis Dashboard
 - Control Priorities
 - Standards Summary
 - Ranked Categories
 - Results By Category
- High-Level Assessment
- Description Executive Summary & Comments
- Reports
- Feedback

Anthony Cowan
Process Control and IT
Applications Engineer
Acme Chemical Inc.
CSAC

anthony.cowan@acme.com
Office Phone: 208 555-1629
Cell Phone: 208 555-8004

Participated
in Site Visit

Change Remove

Kevin McFarlane
IT System Engineer
Acme Chemical Inc.
CSAC

kevin.mcfarlane@acme.com
Office Phone: 208 555-3316
Cell Phone: 208 555-3317

Participated
in Site Visit

Change Remove

Nicole Baumgardener
IT Cybersecurity Analyst
Acme Chemical Inc.
CSAC

nicole.baumgardener@acme.com
Office Phone: 208 555-5467
Cell Phone: 208 555-3641

Participated
in Site Visit

Change Remove

Klein Holts
Control Technician
Acme Chemical Inc.
CSAC

klein.holts@acme.com
Office Phone: 208 555-3244
Cell Phone: 208 555-3234

Participated
in Site Visit

Change Remove

Andrew Nguyen
Control System and OT
Network Engineer
Acme Chemical Inc.
CSAC

andrew.nguyen@acme.com
Office Phone: 208 555-4345
Cell Phone: 208 555-4243

Participated
in Site Visit

Change Remove



CYBER SECURITY EVALUATION TOOL

Jill Moshino

(Administrator)
VP Plant Operations
Acme Chemical Inc.
CSAC

jill.moshino@acme.com
Office Phone: 208 555-3536
Cell Phone: 208 555-1749

Participated
in Site Visit

**Eric Cartman**

Plant Manager
Acme Chemical Inc.
CSAC

eric.cartman@acme.com
Office Phone: 208 555-4689
Cell Phone: 208 555-4678

Participated
in Site Visit

Primary
Point of Contact

**Robert Feltern**

Director Physical Security
Acme Chemical Inc.
CSAC

robert.feltern@acme.com
Office Phone: 208 555-4772
Cell Phone: 208 555-0011

Participated
in Site Visit



+ Add Contact

Add team member information here.

ICS Evaluation Components

- Establish an ICS evaluation methodology
- Determine evaluation entry qualifiers
- Establish role(s)/team to perform evaluation
- Establish expected outcomes and products
- Final reporting mechanism

This bullet item is not part of the CSET® process. But CSET® can be executed, and 6 to 12 months later can be executed again. The results can be compared to determine the progress being made.

CSET®

CYBER SECURITY EVALUATION TOOL

Security Assurance Level (SAL)

Security Assurance Level (SAL)

The Security Assurance Level or SAL determines the number of questions you will need to answer and level of rigor of the assessment. For example, a typical high SAL will contain 350-1000 questions where a low SAL will typically contain 30-350 questions, depending on the selected standard.

Current Security Assurance Level

Overall	Confidentiality	Integrity	Availability
Low	Low	Low	Low

Choose one of the three SAL methodologies below to determine the correct level for your assessment.

Simple General Risk Based NIST-60 / FIPS-199

Overall SAL

Low Moderate High Very High

Confidentiality

This value relates to the importance of protecting information from unauthorized access. The more important it is that unauthorized users do not have access to the information the higher your SAL level.

Low Moderate High Very High

Integrity

This value relates to the importance of the accuracy of information. The more important it is that information is kept consistent, accurate, and only changed by those authorized the higher your SAL level.

Low Moderate High Very High

Availability

This value relates to the importance of information being readily available. The more important it is to have your information available for use the higher your SAL level.

The Security Assurance Level (SAL) directly correlates to the number of questions asked during the evaluation. For the first evaluation, I suggest selecting “Low” across the board. This will allow your team to get their feet wet and then adjust the SAL as required.

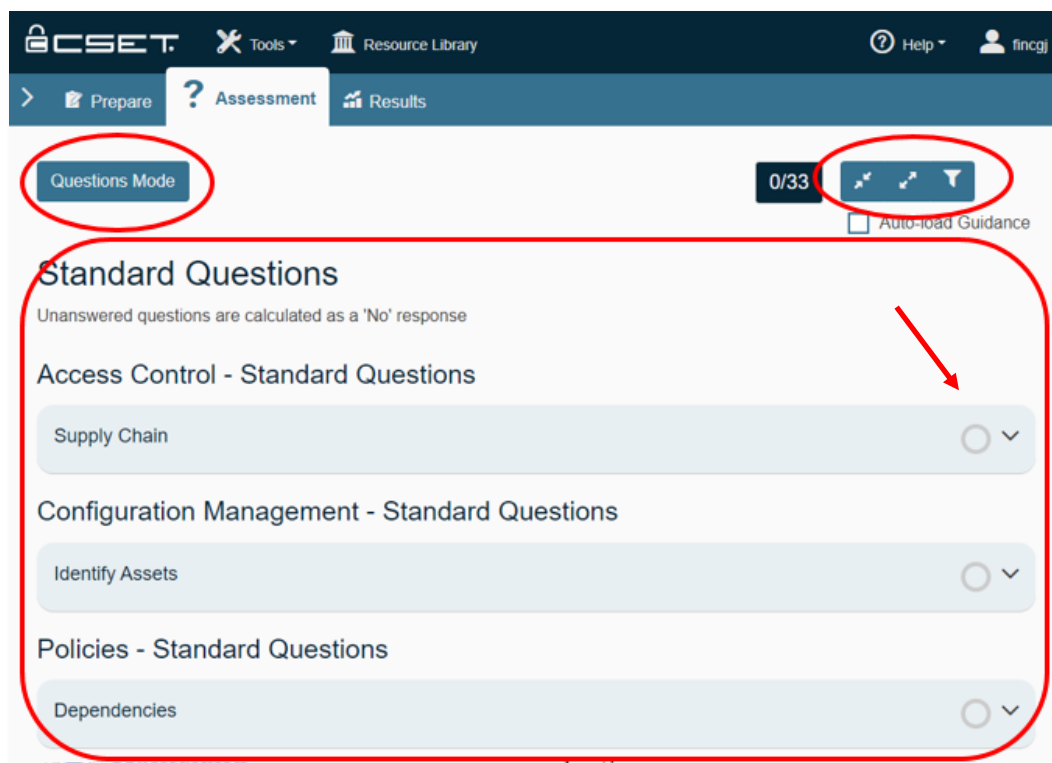
The expected outcome would be to understand the cybersecurity posture of your environment based on standards and/or requirements for your industrial sector.

CSET®

CYBER SECURITY EVALUATION TOOL

CSET® Basis

Evaluation Section – Questions Mode



Once the security assurance level (SAL) has been selected, select “Next” to move to the Questions Mode screen. All questions will be answered as either Yes, No, Not Applicable (N/A), or through an Alternate method (ALT).

The process of answering questions is straightforward. You can select the “down arrow” to expand individual questions or select <- -> to expand all the questions.

CSET[®]

CYBER SECURITY EVALUATION TOOL

CSET[®] Tools Resource Library Help fincj

> Prepare ? Assessment Results

Questions Mode 2/33 Auto-load Guidance

Standard Questions

Unanswered questions are calculated as a 'No' response

Access Control - Standard Questions

Supply Chain Requires Review ✓

1 Are vendors allowed remote access into the OT environment?

2 Are vendors given more than one account to ensure accounts are not shared?

Yes No N/A Alt

Yes No N/A Alt

Description, explanation and/or justification for alternate answer

Reviewed

The process of answering questions is straightforward. You can select the “down arrow” to expand the question or select “Expand All” to have all the questions expanded.

As a team, start with Question 1 and continue through each subject area or category until all questions have been discussed and answered.

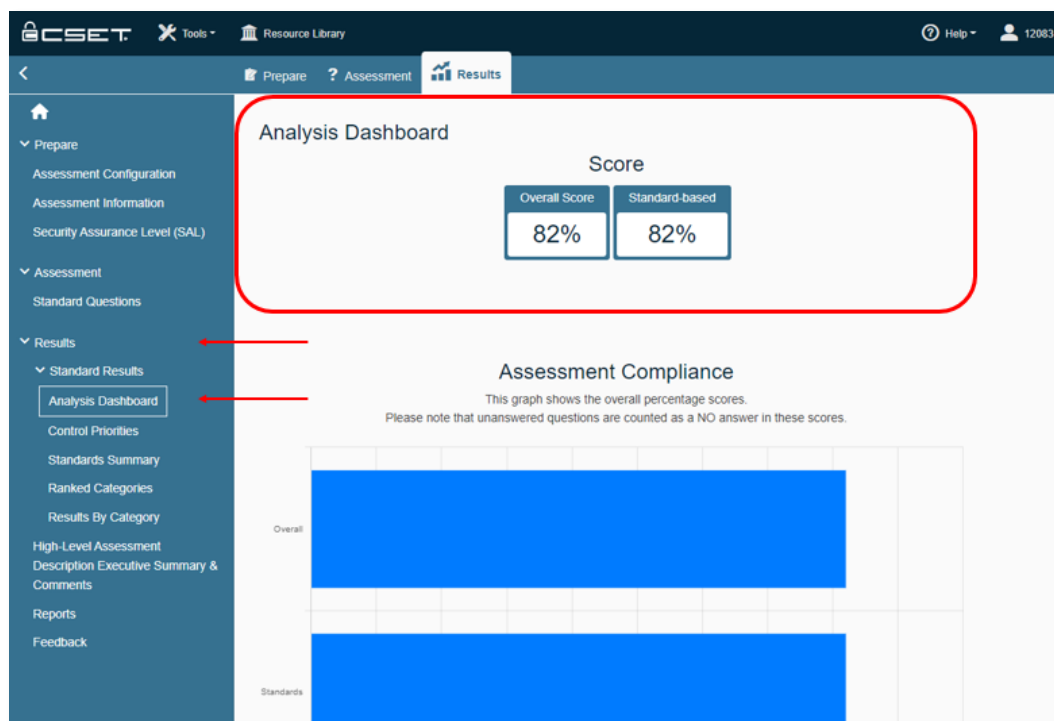
You can select any icon to get or create more information for the question. Icons are: Details / Standard, Supplemental, Comments, Documents, References, Observations and Feedback. You can also indicate the question has been reviewed if you have a review process in place.

ICS Evaluation Components

- Establish an ICS evaluation methodology
- Determine evaluation entry qualifiers
- Establish role(s)/team to perform evaluation
- Establish expected outcomes and products
- Final reporting mechanism

This bullet item can be related to the Analysis section or Dashboard.

Results Section – Analysis Dashboard



The Results Overview screen shows the results of the evaluation in clear to understand charts and graphics.

It shows the overall positive score based on “Yes” or “Alt” versus total number of questions.

CSET[®]

CYBER SECURITY EVALUATION TOOL

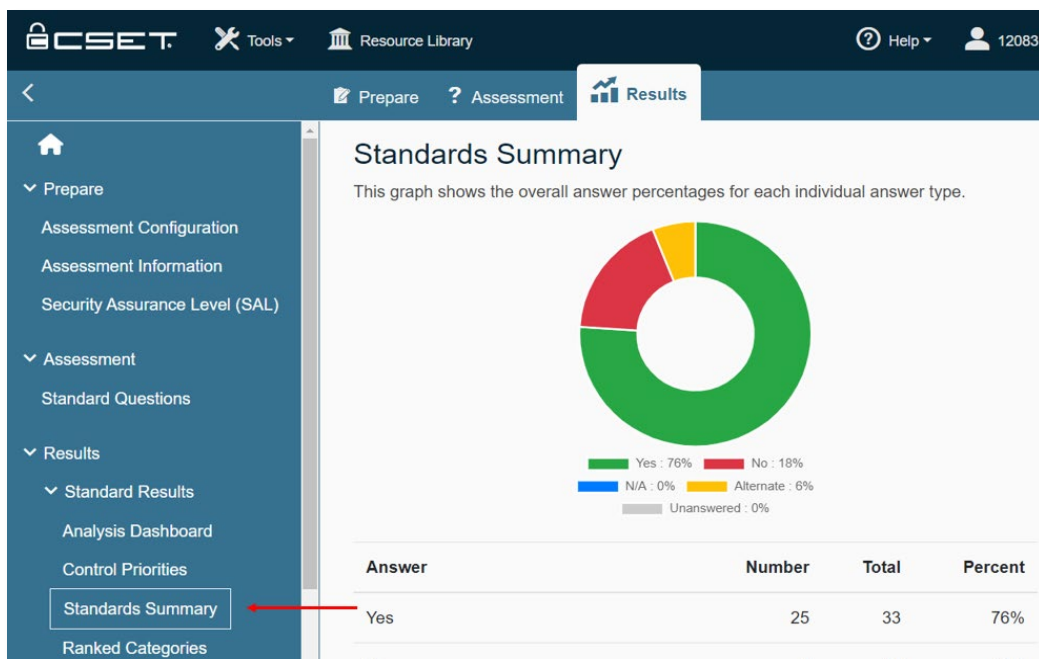
Control Priorities

Control Priorities
Information on ranking can be found in the [User Guide](#).

Standard	Category	Answer	Rank	Question	Reference #
CSET 401	Configuration Management	No	1	Are software platforms and applications within the company inventoried?	2
CSET 401	System and Communications Protection	No	2	Is access to OT restricted through the use of a VPN?	8
CSET 401	System and Communications Protection	No	3	Does the company collect logs for all system types (IT/OT)?	2

The Control Priority page is the mitigation hit list of “No” or “Unanswered” questions. They are ranked based on cost and time to mitigate along with the severity of the deficiency.

Standards Summary



CSET®

CYBER SECURITY EVALUATION TOOL

Executive Summary, Overview and Comments Section

The screenshot shows the CSET web interface. The left sidebar contains a menu with the following items: Analysis Dashboard, Control Priorities, Standards Summary, Ranked Categories, Results by Category, Components Summary, Ranked Categories, Results by Category, Component Types, Network Warnings, Executive Summary, Overview, & Comments (highlighted with a red arrow), Reports, and Feedback. The main content area is titled 'Executive Summary' and contains three sections: 'Executive Summary' (a text box with a description of the tool's purpose), 'Overview' (a text box with instructions for providing a high-level assessment description), and 'Comments' (a text box with instructions for providing general comments). A red arrow points to the 'Executive Summary, Overview, & Comments' menu item.

This section is available to the team for summarizing highlights, issues and follow-up needs for executives. High-level evaluation description of the process and work performed. And any additional general comments to include in the final reports.

The final bullet is producing a Final Report. CSET® has a reporting capability to create reports for different levels of the organization.

Results Section – Reports

The screenshot shows the CSET web interface. The left sidebar contains a menu with the following items: Analysis Dashboard, Control Priorities, Standards Summary, Ranked Categories, Results by Category, Components Summary, Ranked Categories, Results by Category, Component Types, Network Warnings, Executive Summary, Overview, & Comments, Reports (highlighted with a red arrow), and Feedback. The main content area is titled 'Reports' and contains a text box with instructions for creating final reports. Below the text box is a list of report types: Executive Summary (highlighted with a red arrow), Site Summary Report, Site Cybersecurity Plan, Site Detail Report, and Observations Tear-Out Sheets. A red arrow points to the 'Reports' menu item.

The intent of the reporting functionality is to provide the user with a way to print evaluation information, including summary charts and lists. It also provides a hardcopy of the results to be used in meetings, for communications to management, and to assign tasks to technical staff. Combined with the online analysis, these reports can help the user clearly understand where weaknesses are and where improvements should be made.



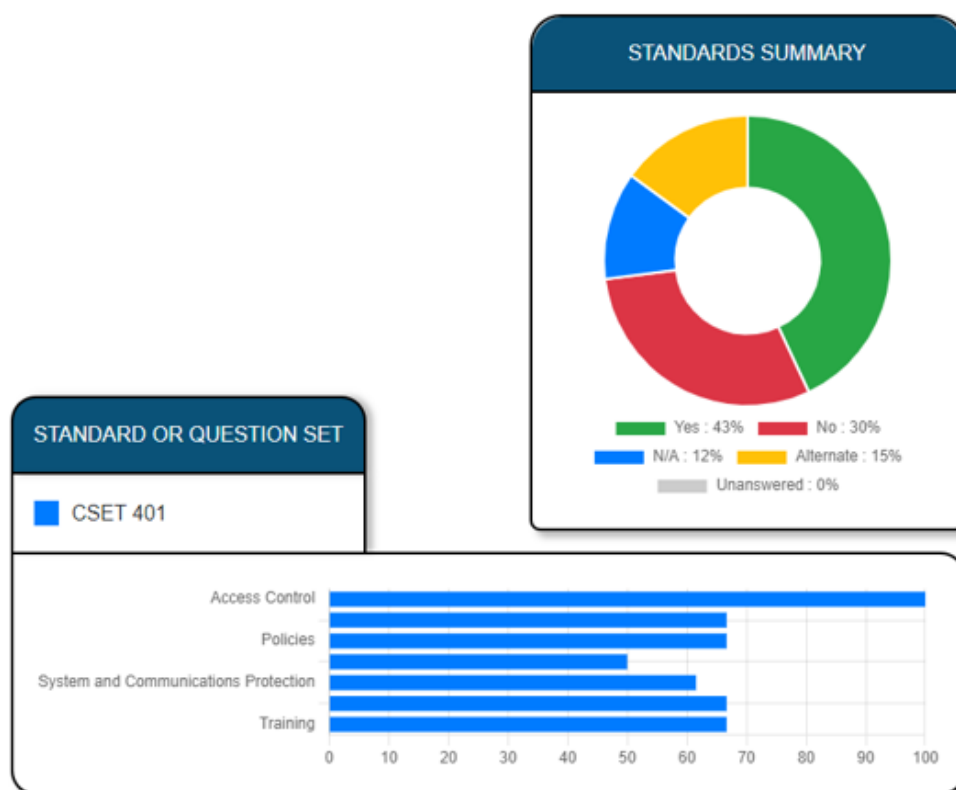
CYBER SECURITY EVALUATION TOOL

Executive Summary Report

From the executive to the site summary and the site detail reports, each report provides increased levels of detail. Finally, the security plan report provides a template for documenting the required cybersecurity controls and the degree to which they are met.

E X E C U T I V E S U M M A R Y

Evaluation Against Selected Standards and Question Sets



The printable reports contain charts, lists, and detailed information found on the analysis screen.

Areas of Concern Top Subjects and Questions

The top subject areas and questions identify those areas where attention will either provide the most immediate impact or protect against the greatest vulnerabilities.

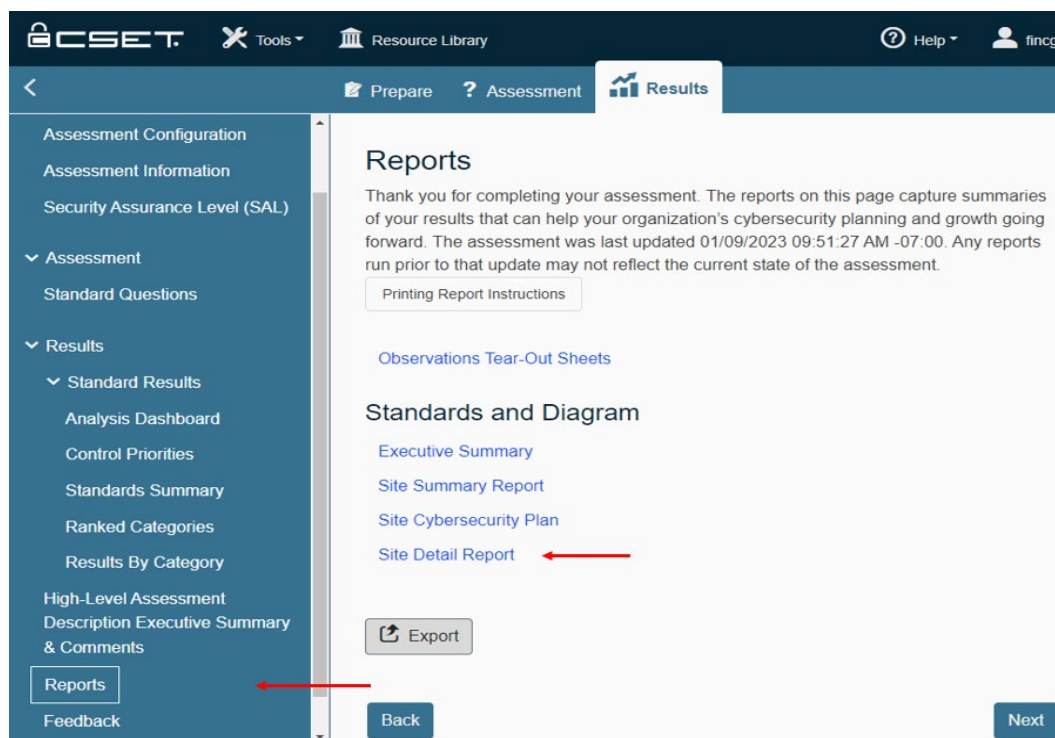
Top Categories of Concern

- 1 Access Control
- 2 Configuration Management
- 3 Policies
- 4 Portable/Mobile/Wireless
- 5 System and Communications Protection

Top Questions of Concern

- 1 Are software platforms and applications within the company inventoried?
- 2 Is access to OT restricted through the use of a VPN?
- 3 Does the company collect logs for all system types (IT/OT)?
- 4 Is the ICS incident response plan tested on a regular basis?
- 5 Does the company validate (through site surveys and configuration review) that only authorized wireless access points are broadcasting?

Returning to the reports page, you can select the “Site Detail Report”.





CYBER SECURITY EVALUATION TOOL

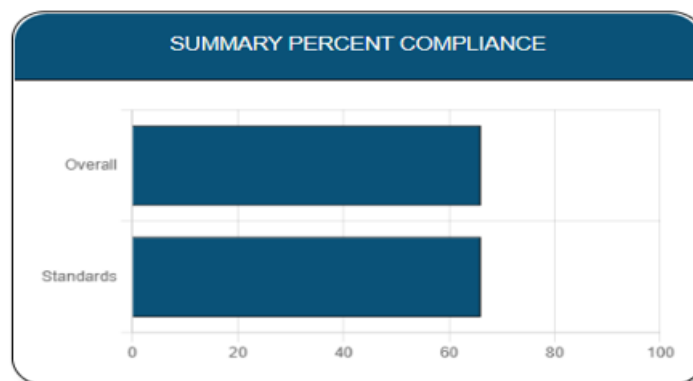
Site Detail Report

Here are examples of charts and lists from the Site Detail Report.

S I T E D E T A I L R E P O R T

Site Information

Assessment Name:	CSET 401 Exercise
Assessment Date:	14-Dec-2022
Facility Name:	CSAC
City or Site Name:	Idaho Falls
State, Province or Region:	ID
Principal Assessor Name:	fincgj
Additional Notes and Comments:	
Contact(s):	12083 Eric Cartman Sal Gentrell Jill Moshino Enoch Weng Robert Feltern Phil Garcia





CYBER SECURITY EVALUATION TOOL

Summary Of Ranked Questions

Each question that did not meet the required Security Assurance Level (SAL) is shown in ranking order below. The displayed levels are the SALs applicable to that question. They are: Low (L), Moderate (M), High (H), and Very High (VH). CNSSI levels are for Confidentiality (C), Integrity (I), and Availability (A). DoD Instruction 8500.2 levels are for Confidentiality (Conf) and Mission Assurance Category (MAC). They are: Classified (C), Sensitive (S), and Public (P) for Confidentiality; MAC I, II, and III for Mission Assurance Category.

Rank: 1	Configuration Management #2	Level: Low
Are software platforms and applications within the company inventoried?		No
Rank: 2	System and Communications Protection #8	Level: Low
Is access to OT restricted through the use of a VPN?		No

Question Comments

There are no questions with comments to display.

Alternate Justification Comments

Access Control #2		
Question:	Are vendors given more than one account to ensure accounts are not shared?	Alternate
Alternate Justification:		

Data and reports generated by the tool should be managed securely and marked, stored, and distributed in a manner appropriate to their sensitivity.



CYBER SECURITY EVALUATION TOOL

Free Download

For the latest web application:

<https://cset-download.inl.gov/download>

Download the latest CSET® tool from the link above or here <https://cset-download.inl.gov/download>.

NOTE: This course uses CSET® v11.5.0.0 for the Final Exercise and can be downloaded through the online VLP.

Acronyms

AS	Automation System
CSET®	Cyber Security Evaluation Tool
DCS	Distributed Control System
DHS	Department of Homeland Security
DMZ	Demilitarized Zone
ICS	Industrial Control System
HMI	Human Machine Interface
I/O	Input/Output
ICS	Industrial Control Systems
IED	Intelligent Electronic Device
IT	Information Technology
NCSD	National Cyber Security Division
NIST	National Institute of Standards and Technology
OPSEC	Operational Security
OSINT	Open-source Intelligence
OT	Operational Technology
PCS	Process Control System
PLC	Programmable Logic Controller
RTU	Remote Terminal Unit
SAL	Security Assurance Level
SCADA	Supervisory Control and Data Acquisition
SIEM	Security Information and Event Management
SIS	Safety Instrumented System
VPN	Virtual Private Network

ICS Cybersecurity Evaluation (401 Virtual) Training

CSET® Report

Using the following information about your company, ACME, fill out your CSET® report using the 401 question set. As you complete the information, you will notice some information is missing, preventing you from completing your report. As with a normal evaluation, you will have to find the missing information later during the Final Exercise. For now, download CSET® from the VLP and the corresponding question sets and complete your report as far as you can *before* beginning the Final Exercise.

NOTE: There are no evaluation questions for LO1 or LO10.



LO2 Evaluation Questions

Open the CSET® tool. Using the information provided below, answer the following questions to the best of your ability. Some questions may have more information than others.

ACME has an inventory of networked connected devices. However, you do not know if a software inventory exists. They also lack visibility into their remote field devices. They do patching during maintenance downtimes every 3 months according to their ICS patching policy. Operating systems range from Windows XP to Windows 7. They have an agreement with Microsoft for support to include outdated versions.

Questions

- ✓ Are physical devices and systems within the organization inventoried?
 - Configuration Management, Identify Assets (aligns with **CPG 1.A**)
- ✓ Are software platforms and applications within the organizations inventoried?
 - Configuration Management, Identify Assets (aligns with **CPG 1.A**)
- ✓ Is the system updated or patched to the most current version?
 - Configuration Management, Identify Assets
- ✓ Does the company have support for outdated versions of software?
 - Configuration Management, Identify Assets

ICS Cybersecurity Evaluation (401 Virtual) Training



LO3 Evaluation Questions

Open the CSET® tool. Using the information provided below, answer the following questions to the best of your ability. Some questions may have more information than others.

ACME has a list of known protocols it uses in the production, supply, and distribution of its chemicals. These protocols include S7comm, Modbus, dnp3, CIP and ENIP. IT and OT are segmented with firewalls from each other with an ICS DMZ. All users must use a VPN to access the OT.

Questions

- ✓ Are OT and IT segmented from each other with the use of firewalls?
 - System and Communication Protection, Network Segmentation (aligns with **CPG 2.F**)
- ✓ Is access to OT restricted through the use of a VPN?
 - System and Communication Protection, Network Segmentation (aligns with **CPG 2.F**)
- ✓ Does an ICS DMZ exist to allow for the transfer of information between OT and business functions?
 - System and Communication Protection, Network Segmentation (aligns with **CPG 2.F**)



LO4 Evaluation Questions

Open the CSET® tool. Using the information provided below, answer the following questions to the best of your ability. Some questions may have more information than others.

Wireless access is fairly new to ACME OT. Vendors install the wireless systems and provide an inventory of wireless APs installed. The wireless APs that are known / inventoried are authorized to be on the network. Devices connected to the wireless system were installed by the vendor. To future-proof deployments, omni-directional antenna are utilized to provide broad coverage. Physical connectivity is preferred. Devices not utilizing wireless are installed with wireless capabilities turned off.

Questions

- ✓ Does the organization maintain an inventory of authorized wireless APs connected to the OT wired network?
 - Portable / Mobile / Wireless, Wireless
- ✓ Does the company validate (through site surveys and configuration review) that only authorized wireless APs are broadcasting?
 - Portable / Mobile / Wireless, Wireless (aligns with **CPG 1.A**)
- ✓ Is each device connected to the wireless system authorized?
 - Portable / Mobile / Wireless, Wireless

ICS Cybersecurity Evaluation (401 Virtual) Training



LO5 Evaluation Questions

Open the CSET® tool. Using the information provided below, answer the following questions to the best of your ability. Some questions may have more information than others.

ACME has 2 IDS sensors. One IDS monitors the ICS/OT network and ICS DMZ. The second IDS monitors the Corporate/IT network and Corporate DMZ. The sensors are running Snort / Security Onion and have appx 3,000 attack signatures. ACME has log monitoring capabilities for the windows systems only. All logs are collected in the IDS area in a log server using Graylog. Logs are monitored throughout the day. Any findings are reported to the cybersecurity lead daily. If ACME has an ICS incident response plan is unknown.

Questions

- ✓ Does the organization deploy network-based IDS sensors?
 - System and Communications Protection, Network Monitoring
- ✓ Does the organization collect logs for all system types (IT/OT)?
 - System and Communications Protection, Network Monitoring (aligns with **CPG 2.T**)
- ✓ Does the organization deploy SIEM or log analytic tools for log aggregation?
 - System and Communications Protection, Network Monitoring (aligns with **CPG 2.U**)
- ✓ Are logs reviewed and analyzed on a defined frequency, and are findings reported to designated officials?
 - System and Communications Protection, Network Monitoring
- ✓ Does an ICS incident response plan exist?
 - Systems and Communications Protection, Network Monitoring (aligns with **CPG 2.S**)
- ✓ Is the ICS incident response plan tested on a regular basis?
 - Systems and Communications Protection, Network Monitoring (aligns with **CPG 2.S**)

ICS Cybersecurity Evaluation (401 Virtual) Training



LO6 Evaluation Questions

Open the CSET® tool. Using the information provided below, answer the following questions to the best of your ability. Some questions may have more information than others.

ACME scans all systems, internally and externally, for vulnerabilities on a weekly basis. Findings are reported to the Operations Team for resolution. Shodan is also checked weekly to ensure no new externally available systems have been put into place without the knowledge of IT or OT. Passwords on the Corporate side are enforced through Group Policy. All passwords on the OT side are local passwords and are not changed regularly. Passwords on PLCs cannot meet corporate password requirements and are managed locally. Facility walkdowns are performed monthly by management. Any discrepancies are noted and fixed, if possible, prior to the next walkdown. All employees, including OT personnel, go through yearly security awareness training that includes OPSEC procedures. Each department maintains their own critical information lists.

Questions

- ✓ Are externally facing machines regularly scanned for vulnerabilities?
– System and Communications Protection, OSINT OPSEC (aligns with **CPG 1.E**)
- ✓ Is an ICS password policy enforced?
– System and Communications Protection, OSINT OPSEC (aligns with **CPG 2.B**)
- ✓ Are facility walkdowns performed?
– System and Communications Protection, OSINT OPSEC
- ✓ Is a company defined critical information list in place and updated periodically?
– System and Communications Protection, OSINT
- ✓ Are employees trained on OPSEC practices?
– Training, OSINT OPSEC (aligns with **CPG 2.I**)
- ✓ Does the company regularly check a product, such as Shodan, for externally available systems?
– System and Communications Protection, OSINT OPSEC (aligns with **CPG 2.W**)



LO7 Evaluation Questions

Open the CSET® tool. Using the information provided below, answer the following questions to the best of your ability. Some questions may have more information than others.

ACME employees receive phishing email training quarterly through the cybersecurity awareness program. Statistics show the training is working and the number of incidents from phishing emails is down. OT personnel receive additional cybersecurity training specific to the OT environment. You just completed your 401 course and are aware of adversarial tactics.

Questions

- ✓ Are employees trained on phishing emails on an annual or more frequent basis?
– Training, Adversarial Risk (aligns with **CPG 2.I**)
- ✓ Are managers aware of adversarial tactics and techniques?
– Training, Adversarial Risk (aligns with **CPG 3.A**)

ICS Cybersecurity Evaluation (401 Virtual) Training



LO8 Evaluation Questions

Open the CSET® tool. Using the information provided below, answer the following questions to the best of your ability. Some questions may have more information than others.

ACME Power and Light provides power for all ACME divisions including ACME Specialty Chemical, ACME Supply and ACME Distribution. ACME Supply provides all necessary chemicals for ACME Specialty Chemical. The output of ACME Specialty Chemical is sent to ACME Distribution for distribution to vendors. Management is aware of the external and internal dependencies for the manufacturing process. You do not know where the data flow diagrams exist.

Questions

- ✓ Does management know what external dependencies exist?
 - Policies, Dependencies
- ✓ Does management know what intradependencies exist?
 - Policies, Dependencies
- ✓ Does documentation of information / data / management flows exist?
 - Policies, Dependencies

ICS Cybersecurity Evaluation (401 Virtual) Training



LO9 Evaluation Questions

Open the CSET® tool. Using the information provided below, answer the following questions to the best of your ability. Some questions may have more information than others.

ACME has a supply chain policy in the document management system and verifies vendors and purchases. All vendors are vetted and ensured they follow all cybersecurity procedures when onsite and when accessing the network remotely. Vendors are required to report security incidents to us if the incidents affect our information, equipment, or VPN access. As part of the vetting process, vendors are required to supply a third-party evaluation of security controls as well as certification that all materials and equipment provided are genuine and not altered. Vendors can access the ACME OT network remotely using a dedicated VPN connection. Each vendor is issued enough user accounts and passwords for their application experts to support system requirements. If vendors come onsite, they must use an ACME provided laptop for access to the systems.

Questions

- ✓ Is there a supply chain policy to verify vendors and purchases?
 - Policies, Supply Chain
- ✓ Are vendors allowed remote access into the OT environment?
 - Access Control, Supply Chain
- ✓ Are vendors given more than one account to ensure accounts are not shared?
 - Access Control, Supply Chain (aligns with **CPG 2.C**)
- ✓ Do vendors supply a third-party evaluation (audit / assessment) of security controls?
 - System and Services Acquisition, Supply Chain (aligns with **CPG 1.I**)
- ✓ Are vendors required to report a security incident to our company?
 - System and Services Acquisition, Supply Chain (aligns with **CPG 1.G**)
- ✓ Can resellers validate materials are genuine and not altered?
 - System and Services Acquisition, Supply Chain

ICS Cybersecurity Evaluation (401 Virtual) Training

Final Exercise

During the training course, you compiled a report using the CSET® tool. However, you did not have all the information you needed to complete the report and some questions were left unanswered. This is pretty normal when compiling a report. You just do not have all the information at first. As a manager at ACME, you will need to get to know and contact members of your team and try to fill in the gaps.

Team Members



Name: Anthony Cowan

Age: 49

Roles: Process Control Engineer (5 years); OT Application Admin (10 years); Database Engineer (10 years)

Time with company: 11 years

Bio: Enjoys fishing, skiing, and camping. Expert in collecting brass antiques.

Background: Knowledgeable of OT software in use.

Schedule: **Busy, Anthony only has time for two interviews after which he will be unavailable** (You will only be able to ask him two questions, so choose wisely).



Name: Kevin McFarlane

Age: 55

Roles: IT Systems Engineer (15 years)

Time with company: 15 years

Bio: Was tragically born without a personality. Watches football and follows the Denver Broncos. Divorced with two kids. Amateur radio hobbyist.

Background: Knowledgeable of IT processes.

Schedule: **Available anytime.**

ICS Cybersecurity Evaluation (401 Virtual) Training



Name: Amy Nguyen

Age: 59

Roles: System Engineer (6 years); OT Network Admin (7 years)

Time with company: 7 years

Bio: Life accomplishment: "I once went an entire day without blinking."

Married with two children. Life goal is to be able to raise a good family.

Background: Knowledgeable of OT network operations

Schedule: **Available anytime.**



Name: Klein Holts

Age: 42

Roles: Control Technician (3 years)

Time with company: 3 years

Bio: Hates drinking hot beverages from a mug. Cosplays Star Wars at Comic-con. Has two dogs, Trooper and Storm. Enjoys hiking.

Background: Knowledgeable of OT hardware in use

Schedule: **Available anytime.**



Name: Nicole Baumgardener

Age: 34

Roles: IT Cybersecurity Analyst (8 years)

Time with company: 2 years

Bio: Enjoys March Madness. Competes in professional rose growing competitions. Leads a company book club. Enjoys painting with watercolors.

Background: Knowledgeable of Cybersecurity processes and procedures

Schedule: **Available most of the time, planning some personal leave on Day 3 so she will be unavailable to answer questions then** (During third round of questions).

ICS Cybersecurity Evaluation (401 Virtual) Training

Notes:

ICS Cybersecurity Evaluation (401 Virtual) Training

Notes:

ICS Cybersecurity Evaluation (401 Virtual) Training

Appendix A. Content References

LO1: Discuss Components of an ICS Evaluation

- Gary Miller, “60% of small companies that suffer a cyberattack are out of business within six months,” The Denver Post, Oct. 24, 2016 – quoting study by the National Cyber Security Alliance
- Steve Morgan, “Cyber Crime Costs Projected to Reach \$2 Trillion by 2019,” Forbes Jan. 17, 2016
- Verizon, 2016 Data Breach Investigations Report, p. 8-9
- Limor Kesseem, “2016 Cybercrime Reloaded: Our Predictions for the Year Ahead,” Jan. 15, 2016
- FireEye, Inc, Mandiant M-Trends 2016, p. 4
- Patricia Harman, “50% of small businesses have been target of a cyber-attack,” PropertyCasualty360.com, Oct. 7, 2015
- Mark Smith, “Huger rise in hack attacks as cyber-criminals target small business,” The Guardian, Feb. 8, 2016
- Thor Olavsrud, “Companies complacent about data breach preparedness,” CIO, Oct. 28, 2016
- Jeff Goldman, “48 Percent of Companies don’t inspect the Cloud for Malware,” eSecurity Planet (blog), Oct. 12, 2016
- Chris Brook, Kaspersky Lab, 91 Percent of Public-Facing ICS Components Are Remotely Exploitable, July 11, 2016
- Mandiant M-Trends, p. 7 2016 Data Breach Investigation Report, p. 11

ICS Cybersecurity Evaluation (401 Virtual) Training

Appendix B: OSINT Framework and Google Hacking Exercise

Optional Activity

The goal of this lab is to use Google and Shodan to practice finding and gathering as much open-source information as possible about Internet-accessible ICS devices.



NOTE: *This lab will involve searching the Internet for real-world devices accessible from the Internet. The goal of this lab is **passive** reconnaissance of those devices. Any attempt to connect to or manipulate these devices could have legal ramifications. For the purposes of this lab, perform only **passive** reconnaissance.*

You will use the Kali Linux VM (instructions below) on the laptop to perform the Google and Shodan elements of this lab.

1. Click the “VMware Player” shortcut on the desktop
2. Open and run the Kali Linux 2019.3 VM
3. The Kali Linux VM should automatically login, but you may use the following credentials in case it does not or if the screen locks:
 - a. Username: **root**
 - b. Password: **toor**

Searching for Vulnerabilities Using Google

1. Open the Firefox web browser
2. Navigate to <https://www.osintframework.com/> take a few minutes and glance at the available menu options
3. Click Search Engines > General Search > Google
4. Perform searches for vulnerabilities in ICS equipment using the following search terms:
5. “Allen Bradley Vulnerability”
6. “ControlLogix Vulnerability”
7. “ControlLogix 5570 Vulnerability”
8. “ControlLogix 1756-ENBT Vulnerability”

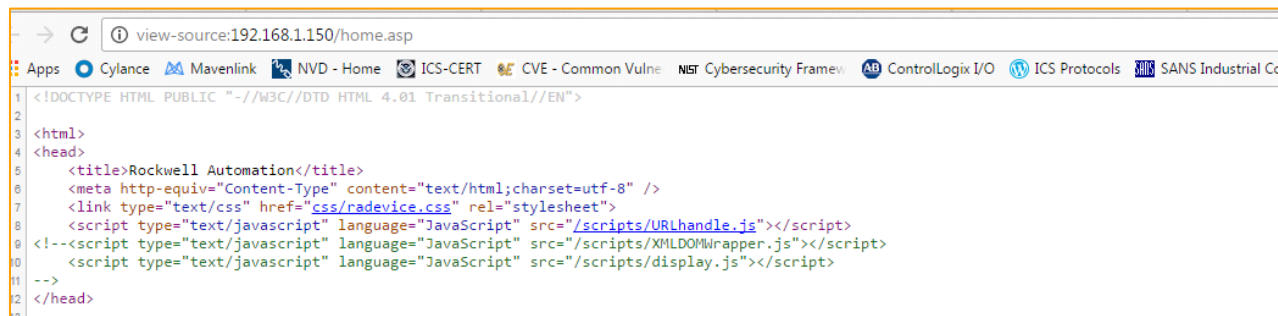
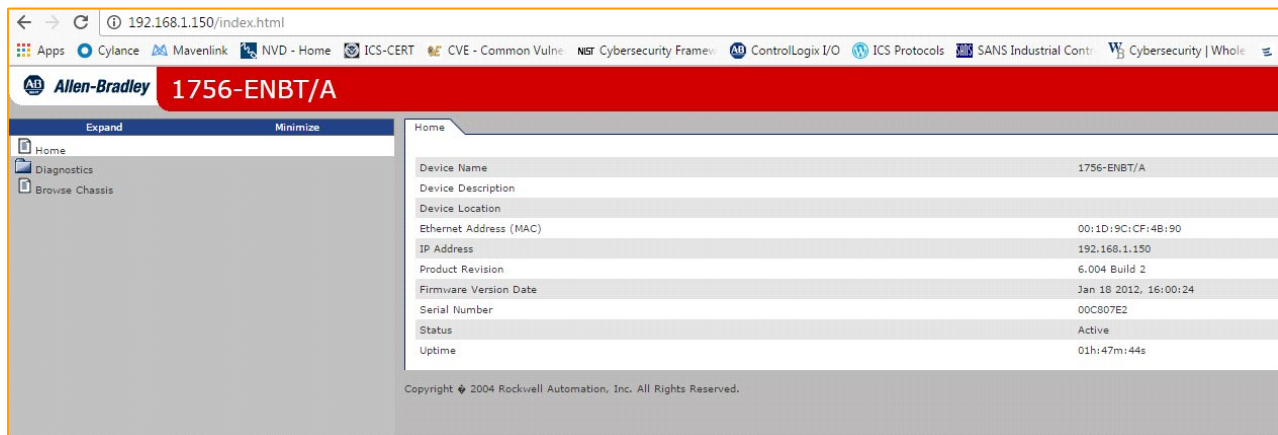
NOTE: *Most of the vulnerabilities identified through Google Searches will likely lead to the CISA.gov advisory pages, which will provide additional details about the vulnerability and affected products.*

ICS Cybersecurity Evaluation (401 Virtual) Training

Example

The following images show an example of a webpage and part of its source code presented by the web server running on the PLC. The title of the page is “Rockwell Automation,” which can be seen in the source code for the page. This is generally a good search term to start with.

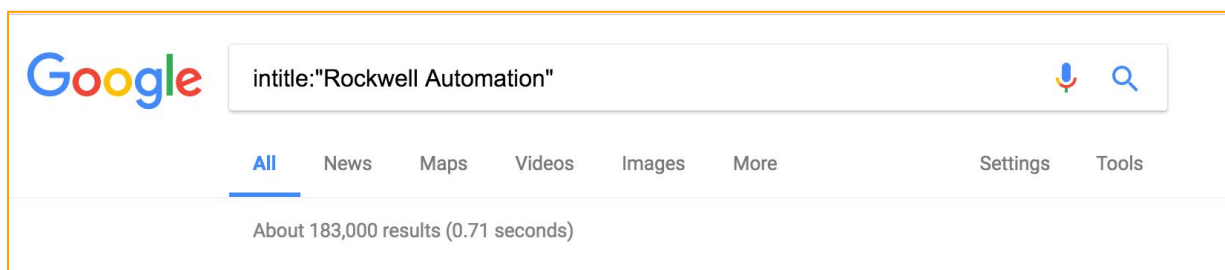
NOTE: View the source code or frame code by right-clicking on the page and selecting “view source.”



Searching for Targets Using Google

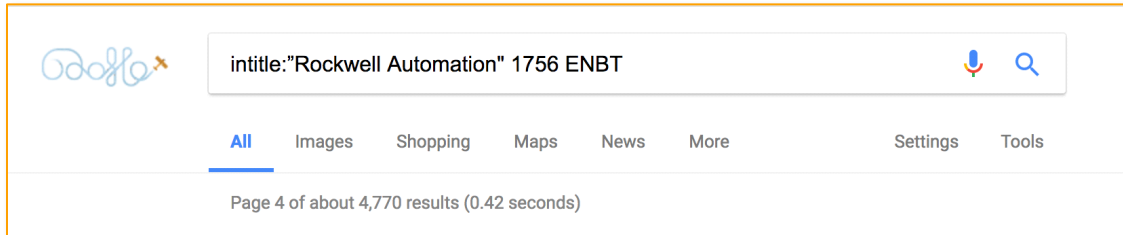
Using the example above you will now use Google to identify Internet-connected devices. Identifying information presented by web servers can be used to search for Internet-connected devices.

1. Search Google for keywords in the title of a page by using the advanced search parameter “intitle”
 - a. Type in the following search term
 - b. intitle:”Rockwell Automation”



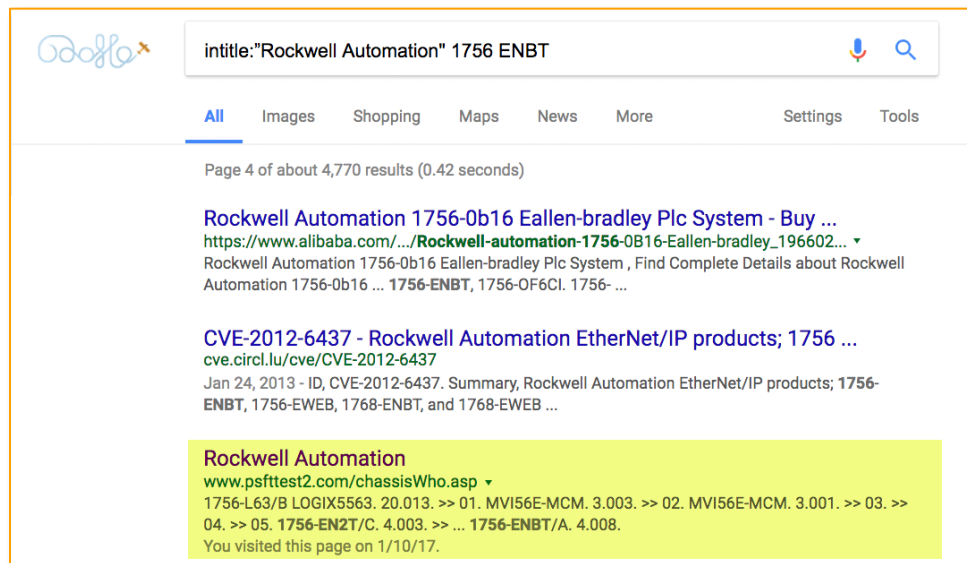
ICS Cybersecurity Evaluation (401 Virtual) Training

2. Add the model of the processor to narrow the previous search results
 - a. Type in the following search term
 - i. `intitle:"Rockwell Automation" 1756 ENBT`



3. Review the search results to identify an Internet-connected device. The highlighted result shown below appears to be a PLC connected to the Internet.

NOTE: *Your search results may vary. If the above query does not reveal any PLCs, try the following search term: `inurl:"Portal/Portal.mwsl"`*



***CAUTION*:** *Whenever connecting to any unfamiliar sites on the Internet, be very careful connecting to devices identified through Google. These could be live systems, they could be Honeypots used by researchers, or they could be a malicious attacker. There are many other Google search options that can help narrow down search results to find an Internet-connected device. Below are a few additional search options:*

“inurl:<search string>” – Use this option to search the URL for a specific word

This could be useful if the webpage is known to be located at a specific path on the web server

“site:<search string>” – Use this option to search for information on a specific domain

To limit the search to a particular domain (e.g., www.rockwellautomation.com), include “site:rockwellautomation.com” in the search query

Add a minus sign (-) at the beginning (e.g., `-site:<search string>`) to exclude a domain from the search results

ICS Cybersecurity Evaluation (401 Virtual) Training

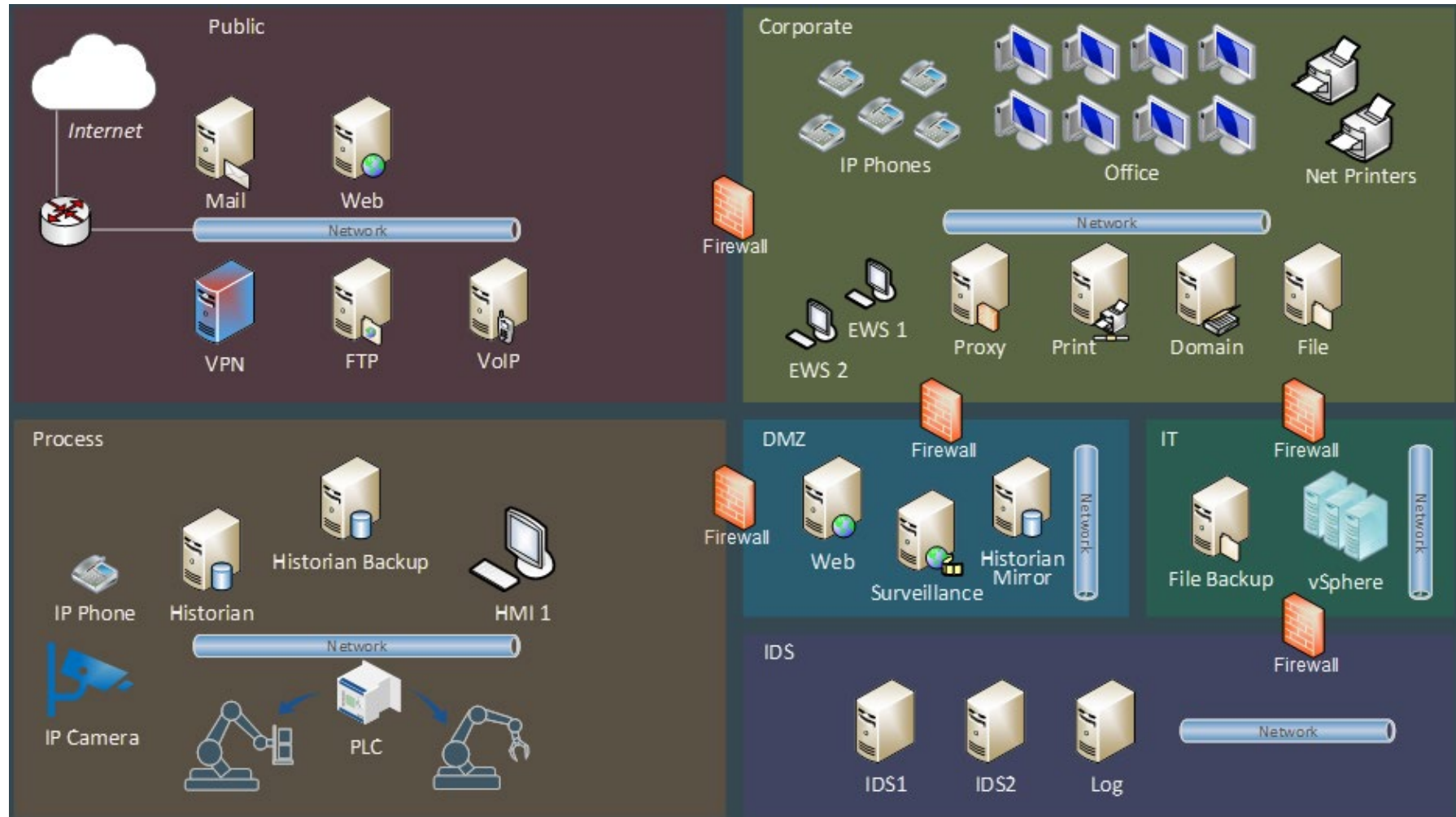
“filetype:<file type>” – Use this option to limit the search to a specific file type

This could be used to search for PLC configuration files being inadvertently hosted on a public web server.

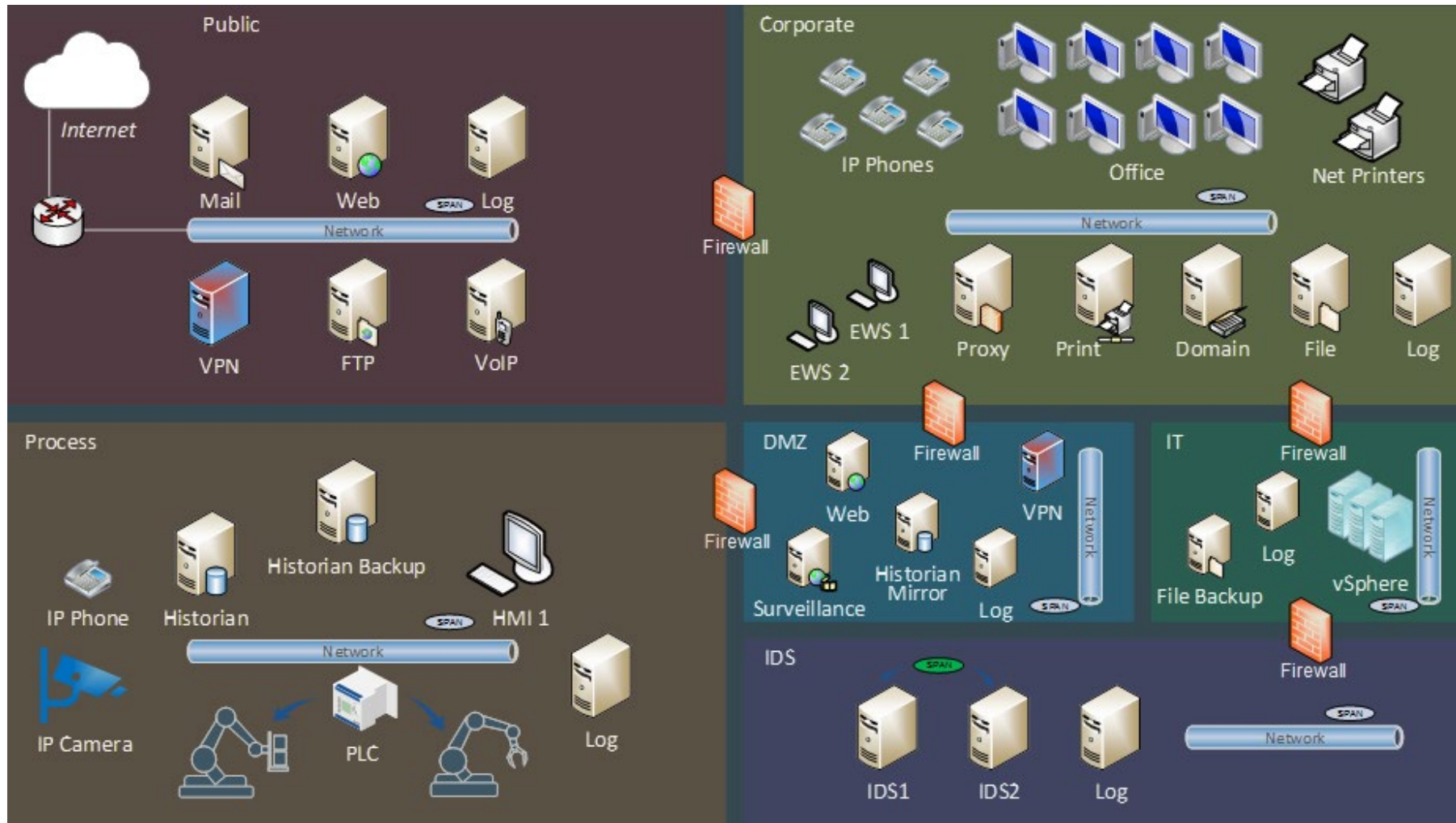
Try using some of these techniques to search your company domain to identify any Internet-connected devices attached to your network, or to see if any private information is being leaked.

ICS Cybersecurity Evaluation (401 Virtual) Training

Appendix C. Network Architecture Examples

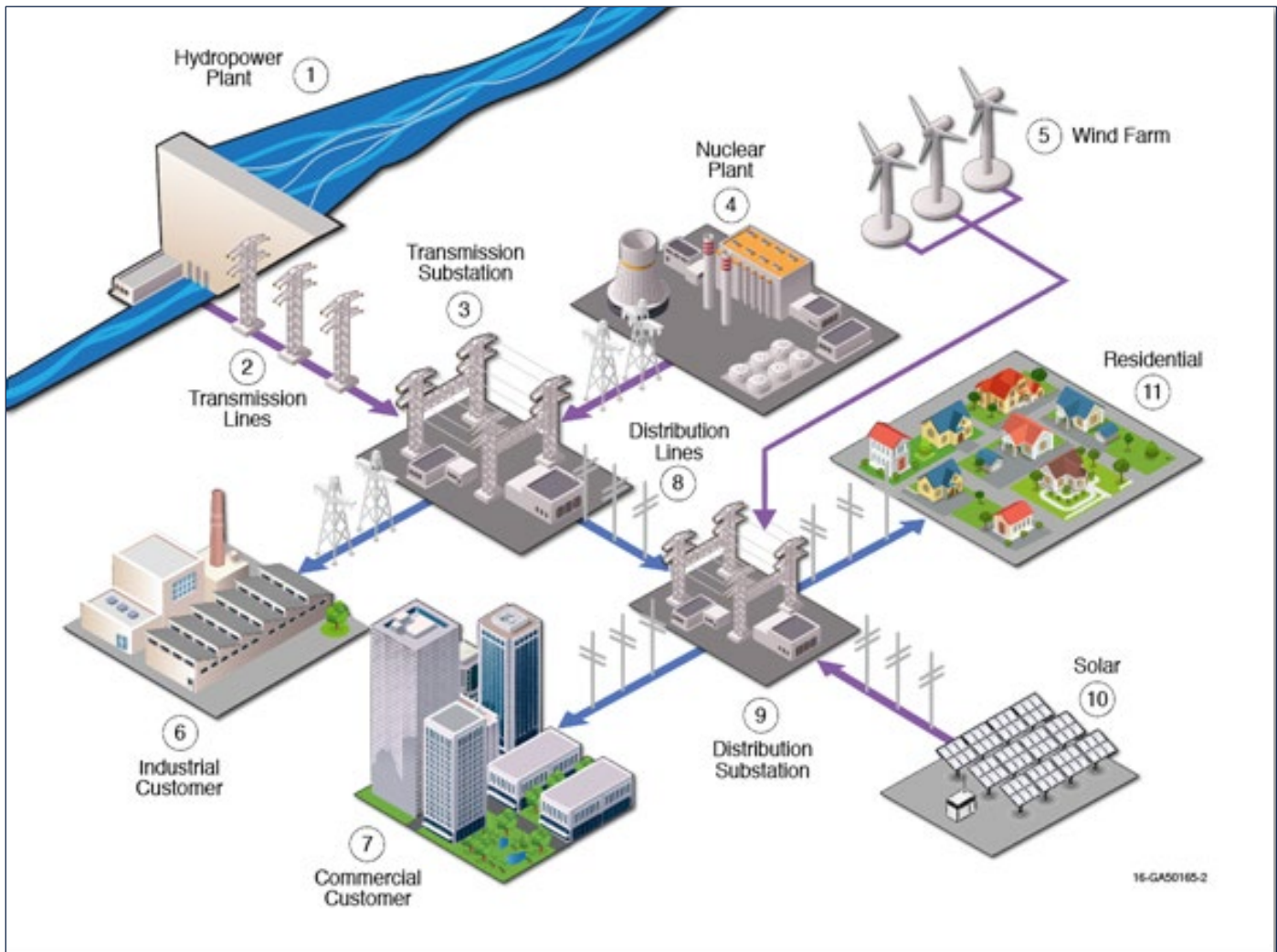


ICS Cybersecurity Evaluation (401 Virtual) Training



ICS Cybersecurity Evaluation (401 Virtual) Training

Appendix D: Cross-Sector Dependencies Sample Exercise Answer



ICS Cybersecurity Evaluation (401 Virtual) Training

Appendix E. Cybersecurity Performance Goals (CPGs)

ID (v.1.0.1)	Security Practice	Outcome	401 Learning Objective(s)
1.A	Asset Inventory	Better identify known, unknown (shadow), and unmanaged assets, and more rapidly detect and respond to new vulnerabilities.	LO 2 Identify Assets LO 4 Wireless
1.B	Organizational Cybersecurity Leadership	A single leader is responsible and accountable for cybersecurity within an organization.	
1.C	OT Cybersecurity Leadership	A single leader is responsible and accountable for OT-specific cybersecurity within an organization with OT assets.	
1.D	Improving IT and OT Cybersecurity Relationships	Improve OT cybersecurity and more rapidly and effectively respond to OT cyber incidents.	LO 1 Evaluate ICS Components
1.E	Mitigating Known Vulnerabilities	Reduce the likelihood of threat actors exploiting known vulnerabilities to breach organizational networks.	
1.F	Third-Party Validation of Cybersecurity Control Effectiveness	Identify TTPs that lack proper defenses and establish confidence in organizational cyber defenses.	
1.G	Supply Chain Incident Reporting	Organizations more rapidly learn about and respond to known incidents or breaches across vendors and service providers.	LO 9 Assess Supply Risk
1.H	Supply Chain Vulnerability Disclosure	Organizations more rapidly learn about and respond to vulnerabilities in assets provided by vendors and service providers.	LO 9 Assess Supply Risk
1.I	Vendor/Supplier Cybersecurity Requirements	Reduce risk by buying more secure products and services from more secure suppliers.	LO 9 Assess Supply Risk
2.A	Changing Default Passwords	Prevent threat actors from using default passwords to achieve initial access or move laterally in a network.	
2.B	Minimum Password Strength	Organizational passwords are harder for threat actors to guess or crack.	
2.C	Unique Credentials	Attackers are unable to reuse compromised credentials to move laterally across the organization, particularly between IT and OT networks.	LO 9 Assess Supply Risk

ICS Cybersecurity Evaluation (401 Virtual) Training

2.D	Revoking Credentials for Departing Employees	Prevent unauthorized access to organizational accounts or resources by former employees.	
2.E	Separating User and Privileged Accounts	Make it harder for threat actors to gain access to administrator or privileged accounts, even if common user accounts are compromised.	
2.F	Network Segmentation	Reduce the likelihood of adversaries accessing the OT network after compromising the IT network.	LO 3 Determine ICS Connectivity
2.G	Detection of Unsuccessful (Automated) Login Attempts	Protect organizations from automated, credential-based attacks.	LO 5 Evaluate Network Monitoring Capabilities
2.H	Phishing-Resistant Multifactor Authentication (MFA)	Add a critical, additional layer of security to protect assets accounts whose credentials have been compromised.	
2.I	Basic Cybersecurity Training	Organizational users learn and perform more secure behaviors.	LO 7 Evaluate Adversarial Risk
2.J	OT Cybersecurity Training	Personnel responsible for securing OT assets received specialized OT-focused cybersecurity training.	
2.K	Strong and Agile Encryption	Effective encryption deployed to maintain confidentiality of sensitive data and integrity of IT and OT traffic.	
2.L	Secure Sensitive Data	Protect sensitive information from unauthorized access.	
2.M	Email Security	Reduce risk from common email-based threats, such as spoofing, phishing, and interception.	
2.N	Disable Macros by Default	Reduce the risk from embedded macros and similar executive code, a common and highly effective threat actor TTP.	
2.O	Document device configurations	More efficiently and effectively manage, respond to, and recover from cyberattacks against the organization and maintain service continuity.	
2.P	Document Network Topology	More efficiently and effectively respond to cyberattacks and maintain service continuity.	
2.Q	Hardware and Software Approval Process	Increase visibility into deployed technology assets and reduce the likelihood of breach by users installing unapproved hardware, firmware, or software.	

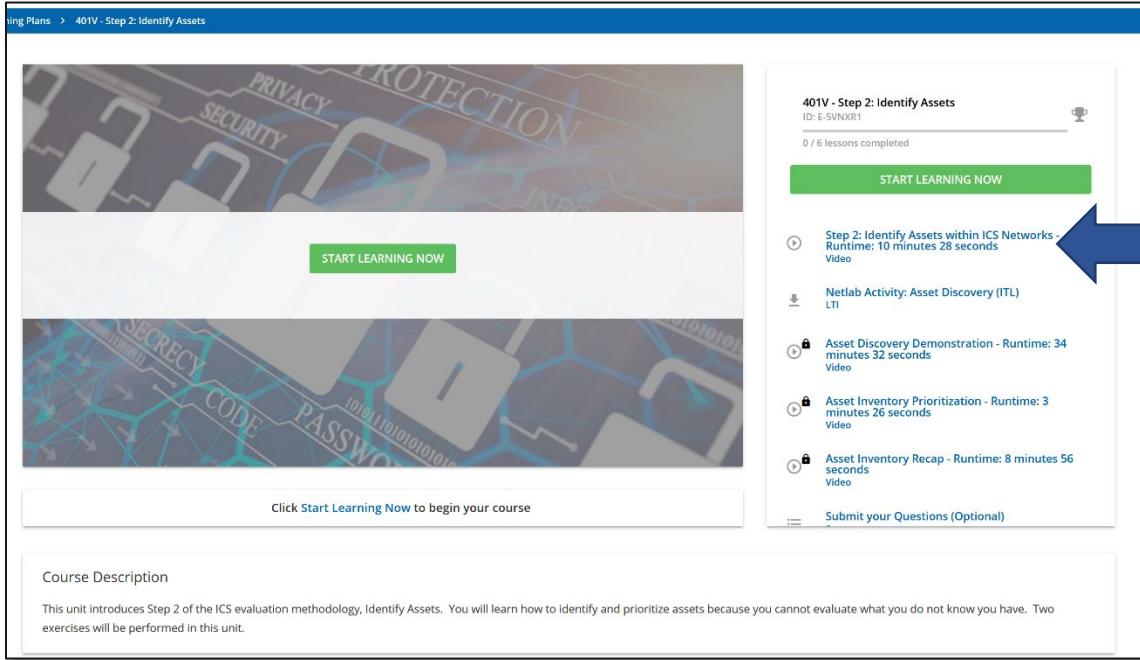
ICS Cybersecurity Evaluation (401 Virtual) Training

2.R	System Backups	Organizations reduce the likelihood and duration of data loss at loss of service delivery or operations.	
2.S	Incident Response (IR) Plans	Organizations maintain, practice, and update cybersecurity incident response plans for relevant threat scenarios.	LO 5 Evaluate Network Monitoring Capabilities
2.T	Log Collection	Achieve better visibility to detect and effectively respond to cyberattacks.	LO 5 Evaluate Network Monitoring Capabilities
2.U	Secure Log Storage	Organizations' security logs are protected from unauthorized access and tampering.	LO 5 Evaluate Network Monitoring Capabilities
2.V	Prohibit Connection of Unauthorized Devices	Prevent malicious actors from achieving initial access or data exfiltration via unauthorized portable media devices.	
2.W	No Exploitable Services on the Internet	Unauthorized users cannot gain an initial system foothold by exploiting known weaknesses in public-facing assets.	LO 6 OSINT and OPSEC
2.X	Limit OT Connections to Public Internet	Reduce the risk of threat actors exploiting or interrupting OT assets connected to the public Internet.	LO 6 OSINT and OPSEC
3.A	Detecting Relevant Threats and TTPs	Organizations are aware of and able to detect relevant threats and TTPs.	LO 7 Evaluate Adversarial Risk
4.A	Incident Reporting	CISA and other organizations are better able to provide assistance or understand the broader scope of a cyberattack.	
4.B	Vulnerability Disclosure/Reporting	Organizations more rapidly learn about vulnerabilities or weaknesses in assets discovered by security researchers; researchers are more incentivized to responsibly share findings.	
4.C	Deploy Security.txt Files	Allow security researchers to submit discovered weaknesses or vulnerabilities faster.	
5.A	Incident Planning and Preparedness	Organizations are capable of safely and effectively recovering from a cybersecurity incident.	

ICS Cybersecurity Evaluation (401 Virtual) Training

Appendix F. How to Login to NetLab

When you find a NetLab activity like the example below, make sure all previous items are completed. Then click on the NetLab activity.



The screenshot shows the NetLab interface for the course '401V - Step 2: Identify Assets' (ID: E-SVNXR1). The interface includes a 'START LEARNING NOW' button and a list of activities. A blue arrow points from a box labeled 'Previous Item' to the 'Netlab Activity: Asset Discovery (ITL)' item in the list.

401V - Step 2: Identify Assets
ID: E-SVNXR1
0 / 6 lessons completed

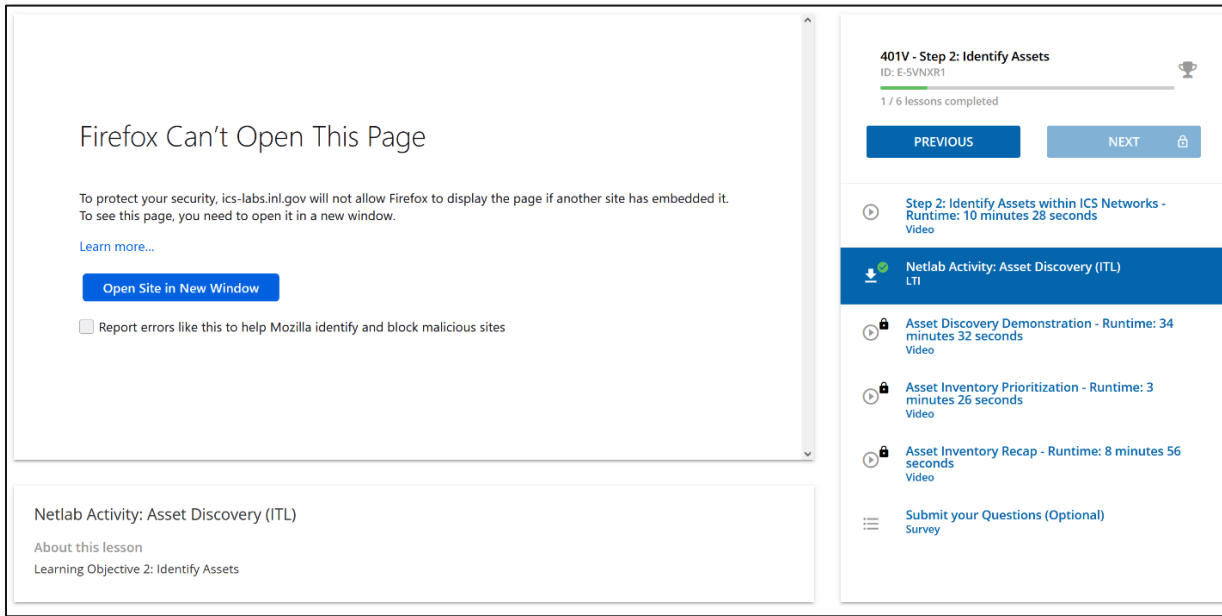
[START LEARNING NOW](#)

- Step 2: Identify Assets within ICS Networks - Runtime: 10 minutes 28 seconds Video
- Netlab Activity: Asset Discovery (ITL)** LTI
- Asset Discovery Demonstration - Runtime: 34 minutes 32 seconds Video
- Asset Inventory Prioritization - Runtime: 3 minutes 26 seconds Video
- Asset Inventory Recap - Runtime: 8 minutes 56 seconds Video

[Submit your Questions \(Optional\)](#)

Click [Start Learning Now](#) to begin your course

Course Description
This unit introduces Step 2 of the ICS evaluation methodology, Identify Assets. You will learn how to identify and prioritize assets because you cannot evaluate what you do not know you have. Two exercises will be performed in this unit.



The screenshot shows the NetLab interface for the course '401V - Step 2: Identify Assets' (ID: E-SVNXR1). The interface displays a 'Firefox Can't Open This Page' error message. A blue arrow points from a box labeled 'Previous Item' to the 'Netlab Activity: Asset Discovery (ITL)' item in the list.

401V - Step 2: Identify Assets
ID: E-SVNXR1
1 / 6 lessons completed

[PREVIOUS](#) [NEXT](#)

- Step 2: Identify Assets within ICS Networks - Runtime: 10 minutes 28 seconds Video
- Netlab Activity: Asset Discovery (ITL)** LTI
- Asset Discovery Demonstration - Runtime: 34 minutes 32 seconds Video
- Asset Inventory Prioritization - Runtime: 3 minutes 26 seconds Video
- Asset Inventory Recap - Runtime: 8 minutes 56 seconds Video

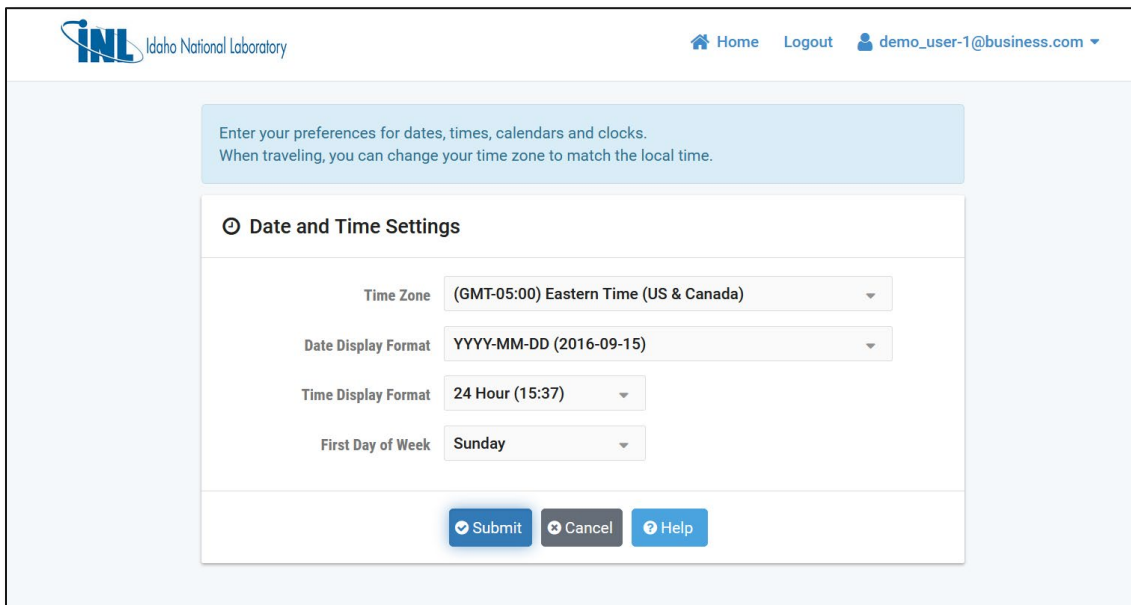
[Submit your Questions \(Optional\)](#)
Survey

Firefox Can't Open This Page
To protect your security, ics-labs.inl.gov will not allow Firefox to display the page if another site has embedded it. To see this page, you need to open it in a new window.
[Learn more...](#)
[Open Site in New Window](#)
☐ Report errors like this to help Mozilla identify and block malicious sites

Netlab Activity: Asset Discovery (ITL)
About this lesson
Learning Objective 2: Identify Assets

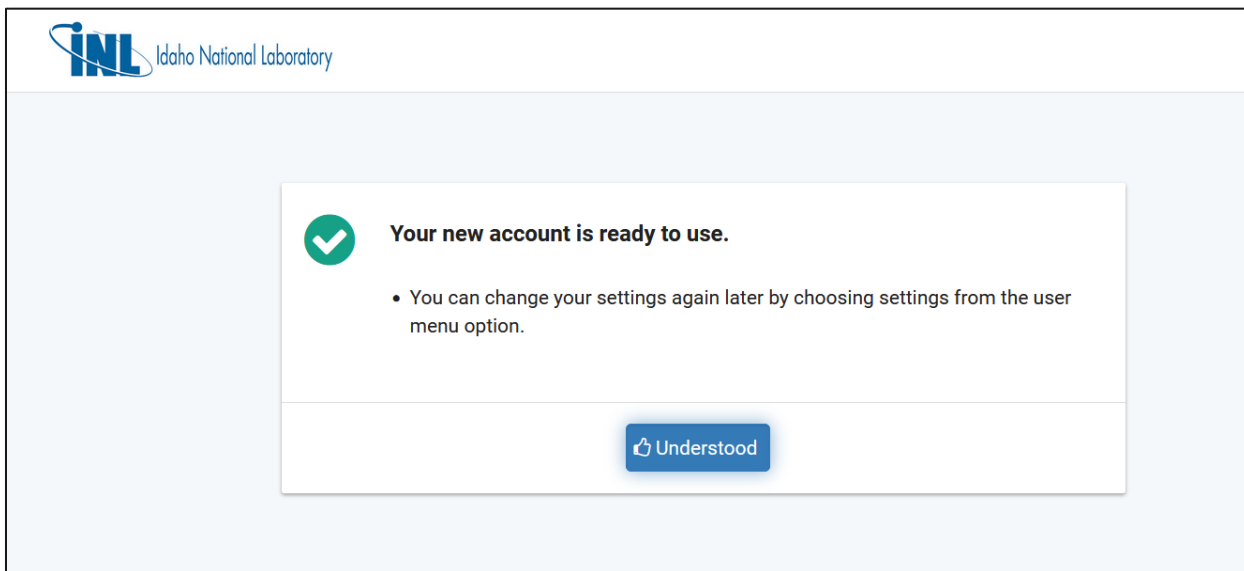
Depending on the browser and your security settings, you may get an error stating the site cannot be opened. Click on "Open Site In New Window" and the site will open. Your pop-up blocker will also need to be disabled. Do not close course lesson tab.

ICS Cybersecurity Evaluation (401 Virtual) Training



The screenshot shows the INL (Idaho National Laboratory) user interface. At the top, there is a navigation bar with the INL logo, a "Home" link, a "Logout" link, and a user profile dropdown for "demo_user-1@business.com". Below the navigation bar, a light blue box contains the text: "Enter your preferences for dates, times, calendars and clocks. When traveling, you can change your time zone to match the local time." The main content area is titled "Date and Time Settings" with a clock icon. It contains four dropdown menus: "Time Zone" set to "(GMT-05:00) Eastern Time (US & Canada)", "Date Display Format" set to "YYYY-MM-DD (2016-09-15)", "Time Display Format" set to "24 Hour (15:37)", and "First Day of Week" set to "Sunday". At the bottom of the settings panel are three buttons: "Submit" (blue), "Cancel" (grey), and "Help" (blue).

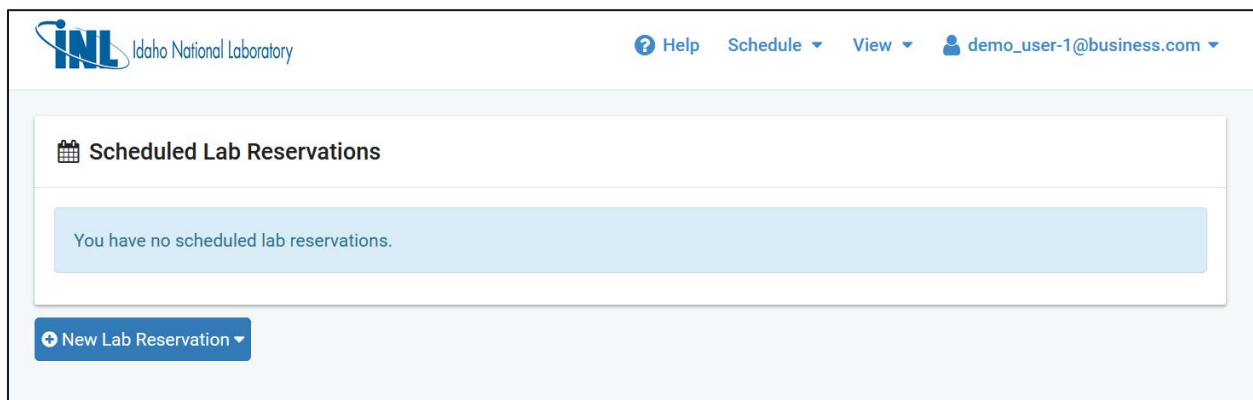
The first time you use NetLab, you will need to set your Time Zone. After setting your preference, click "Submit"



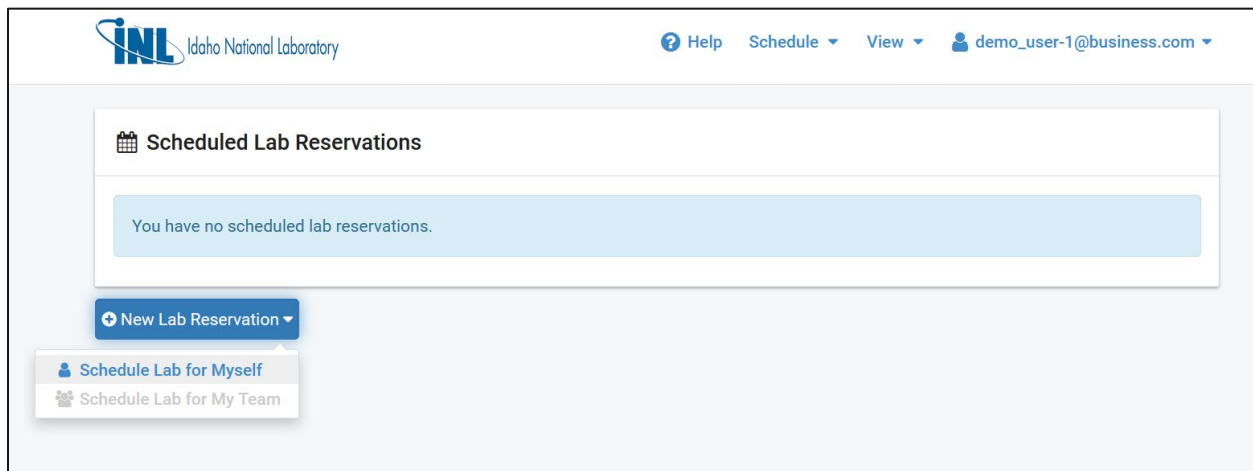
The screenshot shows a success message box with a green checkmark icon. The text reads: "Your new account is ready to use." Below this, a bullet point states: "• You can change your settings again later by choosing settings from the user menu option." At the bottom of the message box is a blue button with a thumbs-up icon and the text "Understood".

You will receive this message. Click "Understood"

ICS Cybersecurity Evaluation (401 Virtual) Training



This is the NetLab Homepage and where you can reserve a lab.



Click on “New Lab Reservation,” Click on “Schedule Lab for Myself”

ICS Cybersecurity Evaluation (401 Virtual) Training

Home demo_user-1@business.com

Select Lab (Learning Objective 2: Identify Assets) > Reserve Pod

 Pod Scheduler

August - 2021

Sun	Mon	Tue	Wed	Thu	Fri	Sat
1	2	3	4	5	6	7
8	9	10	11	12	13	14
15	16	17	18	19	20	21
22	23	24	25	26	27	28
29	30	31	1	2	3	4

Selected Day

August

25

2021

Current Time



19:10

Eastern Time (US & Canada)

	CISA_401IdentifyAssets_23401	CISA_401IdentifyAssets_23402	CISA_401IdentifyAssets_23403	CISA_401IdentifyAssets_23404
				
	Reservation 10606	Reservation 10608		
10:00				
11:00	Reservation 10600			
12:00	Reservation 10625			
13:00				
14:00				
15:00				
16:00				
17:00				
18:00				
19:00				
20:00				
21:00				
22:00				
23:00				

Previous Cancel

This image shows the “Pod Scheduler.” Click on your desired time slot. If your time slot is taken in the farthest left column, you may choose a column to the right of the desired time as the NetLab Introduction video described.

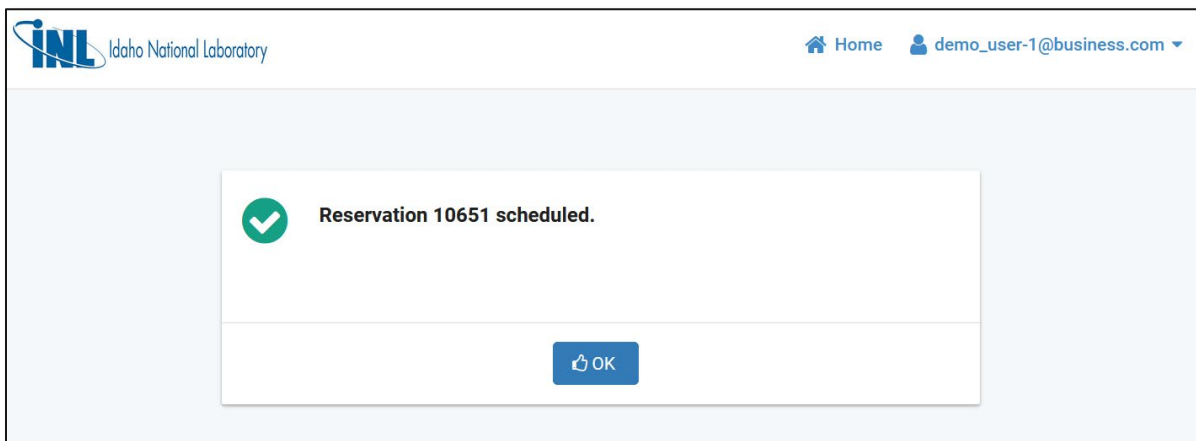
ICS Cybersecurity Evaluation (401 Virtual) Training

The screenshot shows the 'Add Reservation' form in the INL system. The form is titled 'Add Reservation' with a calendar icon. It contains the following fields and values:

- Pod: CISA_401IdentifyAssets_23401
- Reservation Type: Individual Self Study
- Class Name: CISA 401 - ITL
- Reserve For: Demo User
- Lab Exercise: Learning Objective 2: Identify Assets
- Time Zone: Eastern Time (US & Canada)
- Start Time: 2021-08-25 19:11
- End Time: 2021-08-25 20:00
- Length of Reservation: 38 mins.

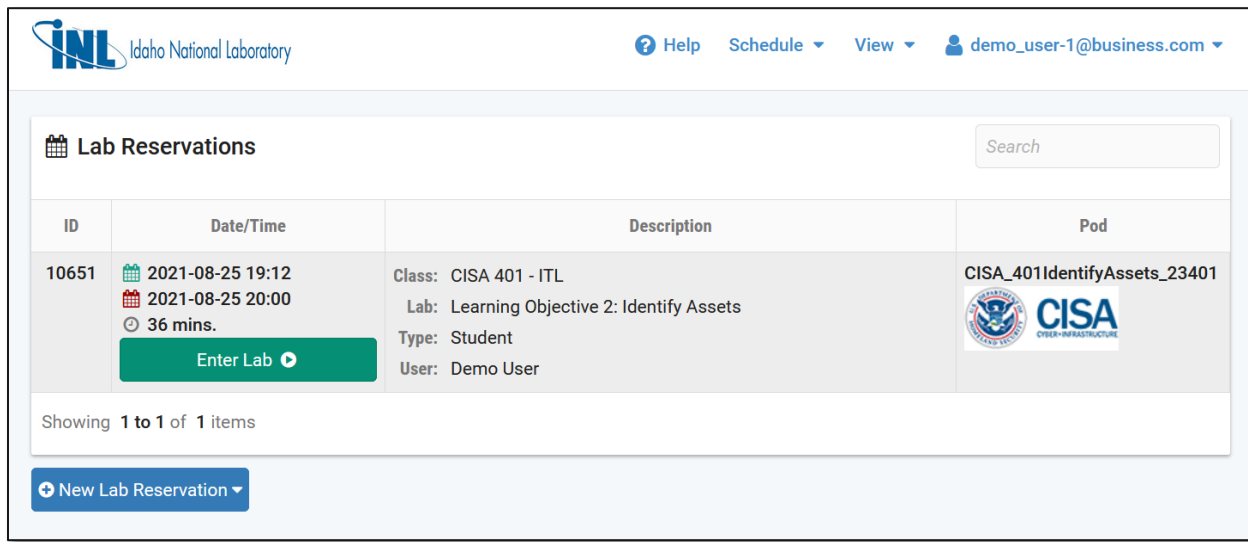
At the bottom of the form, there are three buttons: 'Submit' (with a checkmark icon), 'Previous' (with a left arrow icon), and 'Cancel' (with an X icon).

Once a time slot is selected, the above image will appear. Verify your start time and click “Submit”



A notification will appear. Click “OK”

ICS Cybersecurity Evaluation (401 Virtual) Training



INL Idaho National Laboratory

Help Schedule View demo_user-1@business.com

Lab Reservations

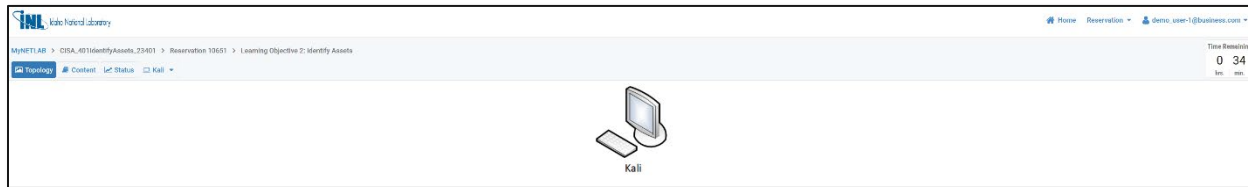
Search

ID	Date/Time	Description	Pod
10651	 2021-08-25 19:12  2021-08-25 20:00 36 mins. Enter Lab	Class: CISA 401 - ITL Lab: Learning Objective 2: Identify Assets Type: Student User: Demo User	CISA_401IdentifyAssets_23401 

Showing 1 to 1 of 1 items

[+ New Lab Reservation](#)

During your scheduled time slot, the green **Enter Lab** button will appear on the NetLab home screen. Click to enter the lab.



INL Idaho National Laboratory

Home Reservation demo_user-1@business.com

MYNETLAB > CISA_401IdentifyAssets_23401 > Reservation 10651 > Learning Objective 2: Identify Assets

[Topology](#) [Content](#) [Lab Status](#) [Kali](#)

Kali

Time Remaining
0:34

The “Topology” page inside each lab shows you what devices are in this lab.

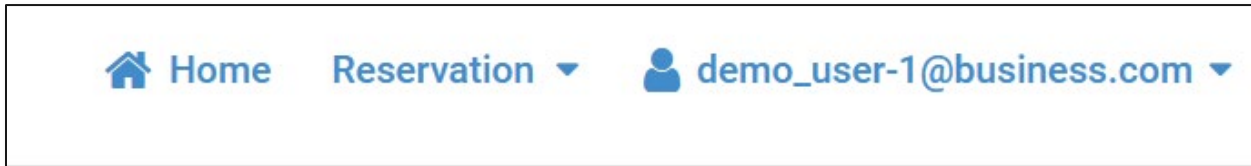
Please send any questions to nhs-training@inl.gov

Thank you.

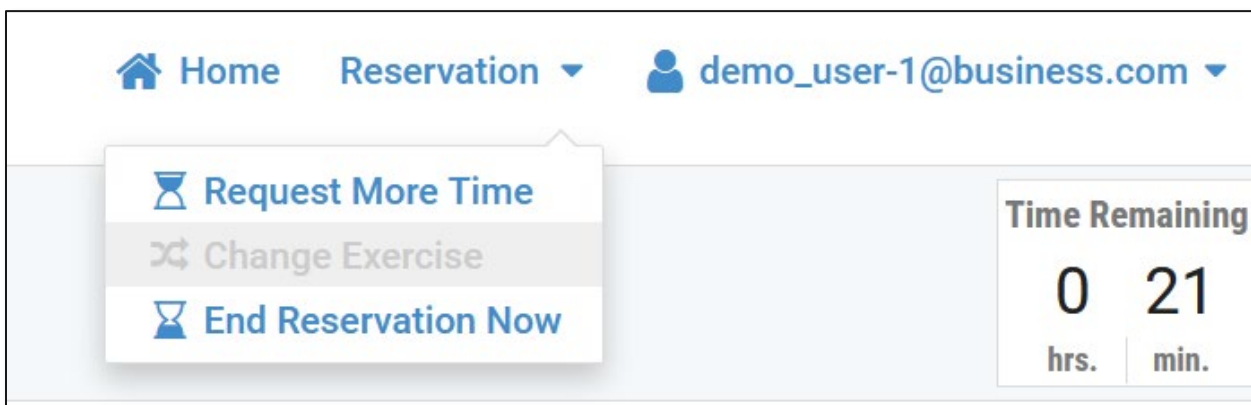
ICS Cybersecurity Evaluation (401 Virtual) Training

To End a NetLab Reservation Early

When you have finished recording any required data in your Trainee Guide to close NetLab, go to the upper-right of the browser window.



Click the Reservation drop-down.



Click “End Reservation Now”

ICS Cybersecurity Evaluation (401 Virtual) Training

End Reservation

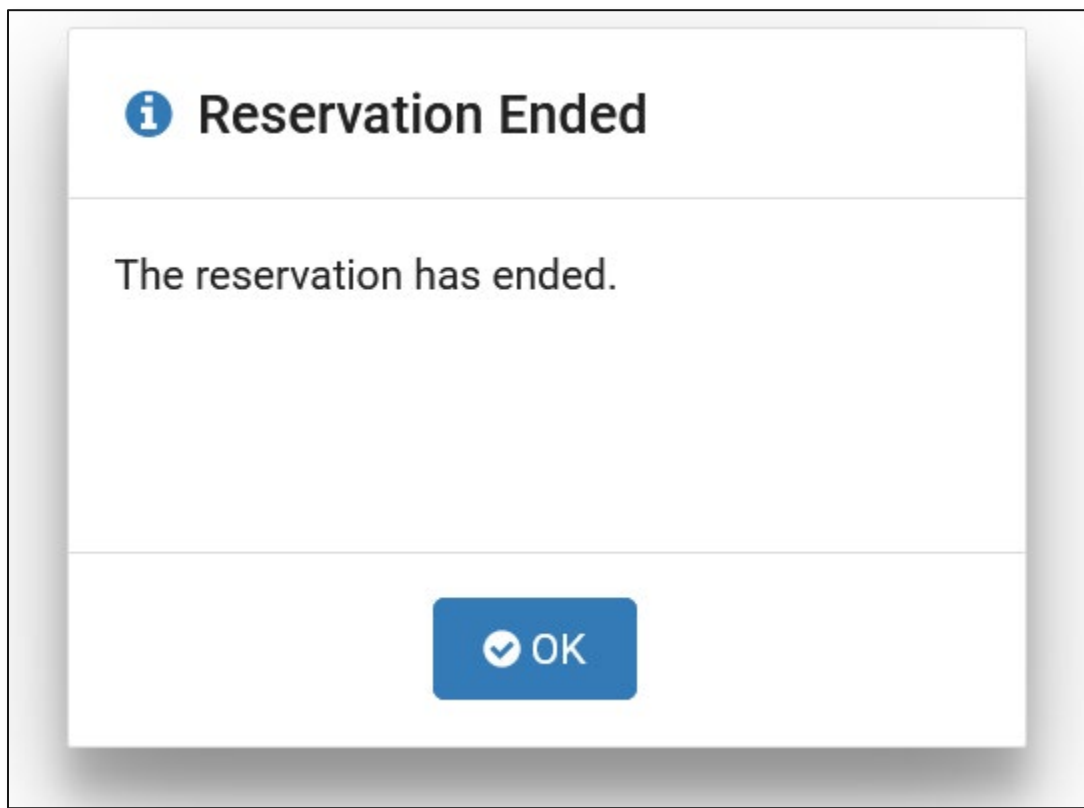
This will end the current reservation.
Are you sure you are finished with this pod?

 Yes

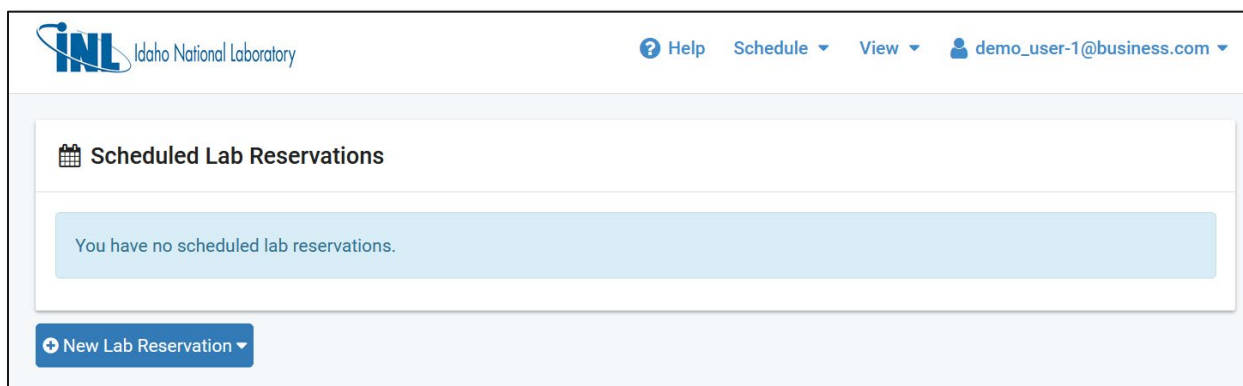
 No

A warning will display. Click "Yes"

ICS Cybersecurity Evaluation (401 Virtual) Training



A notification the Reservation has ended will appear. Click “OK”



You will be returned to the NetLab homepage. You can now exit from this tab or window. Be careful not to close your course’s training tab in the CISA VLP.

ICS Cybersecurity Evaluation (401 Virtual) Training

My Courses and Learning Plans > 401V - Step 2: Identify Assets

Learning Objective 2: Identify Assets

Scheduled Lab Reservations

ID	Date/Time	Description	Pod
10651	2021-08-25 19:12 2021-08-25 20:00 27 mins.	Class: CISA 401 - ITL Lab: Learning Objective 2: Identify Assets Type: Student User: Demo User	CISA_401IdentifyAssets_23401

[Enter Lab](#)

[New Lab Reservation](#)

Lab History

Reservation	Exercise	Date	Hours Attended
10651	Learning Objective 2: Identify Assets	2021-08-25	0.00

Netlab Activity: Asset Discovery (ITL)

About this lesson
Learning Objective 2: Identify Assets

401V - Step 2: Identify Assets
ID: E-SVNXR1
2 / 6 lessons completed

[PREVIOUS](#) [NEXT](#)

- Step 2: Identify Assets within ICS Networks - Runtime: 10 minutes 28 seconds Video
- Netlab Activity: Asset Discovery (ITL) LTI**
- Asset Discovery Demonstration - Runtime: 34 minutes 32 seconds Video
- Asset Inventory Prioritization - Runtime: 3 minutes 26 seconds Video
- Asset Inventory Recap - Runtime: 8 minutes 56 seconds Video
- [Submit your Questions \(Optional\) Survey](#)

After returning from the lab, click the next item in your list to proceed with the course.

Please send any questions to nhs-training@inl.gov. Thank you.